EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL

Ensuring High Assurance of EUDI Wallets
& the NL National eID Scheme



NL-P-04W

NL EUDI Wallet Certification System

EUDIW Lifecycle Specification

RC1.0

2026.11.01

Document reference	NL-P-04W
Version	RC1.0
Status	Release Candidate
Date	01/11/2026
Document type	Requirements (Wallet Onboarding & Lifecycle Management)
Parent framework	NL-SYS-01 NL-P-W
Scheme Owner	Kingdom of the Netherlands Minister of Economic Affairs
Certification target	Wallet Providers under the NL EUDI Wallet Certification System
Primary audience	Wallet Providers, CABs and Scheme Owners
Secondary audience	PID Provider, Supervisory bodies, accreditation bodies and EUDI Wallet ecosystem stakeholders
Assurance level <identity proofing CIR 2015/1502> and <evaluation, EU Regulation 2019/881>	High/High
Related Documents	NL-P-01 NL-P-02 NL-P-03

Version	**RC1.0**	State	Date
RC1.0	Transmission of working doc into Certification System Template	Release Candidate	2026-10-31

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Table of Contents

1 Introduction 6
1.1 Foreword 6
1.2 Scope 6
2 References 8
2.1 Normative References 8
2.2 Informative References 9
3 Terms & Abbreviations 10
3.1 Terms 10
3.2 Abbreviations 11
3.3 Modal verbs terminology 12
3.4 Notations 12
3.5 Symbols 13
4 Relation to Resilience & High Assurance 14
4.1 Resilience 14
4.2 High Assurance 15
5 Lifecycle Event: Wallet Instance Installation 17
5.1 Secure Software Distribution and Delivery 17
5.2 Device Security Pre-Checks 20
5.3 Installation Process Security 23
5.4 Wallet User Information and Consent 25
6 Lifecycle Event: Wallet Unit Activation 28
6.1 WSCD/WSCA Initialisation 28
6.2 Wallet Instance Attestation and Key Attestation Issuance 29
6.3 Wallet Instance – Wallet Unit Binding 35
6.4 Wallet User Account Setup with Wallet Provider 37
6.5 Wallet User Authentication Setup 40
6.6 Migration Object import 42
6.7 Migration Object Setup 44
7 Lifecycle Event: Operational State (Without PID) 48
7.1 Security Requirements for Non-PID Use Cases 48
7.2 Preparedness for PID Issuance 49
8 Lifecycle Event: PID Storage and Transition to Valid State 51
8.1 PID Issuance request 51
8.2 Binding Wallet Unit to Wallet User Identity Verification 52
8.3 Secure PID Reception Process 55
8.4 PID Storage and Protection 60
8.5 Wallet User Activation of PID 62
9 Lifecycle Event: Wallet Unit Management and Maintenance 64
9.1 Software Updates and Patches 64

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

9.2 Re-authentication and Session Management 66
9.3 Key Rotation and Renewal 68
9.4 PID and EAA Lifecycle Management 70
9.5 Wallet User Support 73
9.6 Backup and Restore 76
9.7 Security and Compliance Monitoring 80
9.8 Data Management and Retention 81
9.9 Trust Anchor Management 82
10 Lifecycle Event: Device Change / Migration 85
10.1 Migration Initiation and Authorisation 85
10.2 Secure Data Transfer Mechanisms 85
10.3 New Device Security Verification 88
10.4 Wallet Unit Re-establishment on New Device 89
10.5 Old Device Decommissioning 90
10.6 Secure Deletion of Keys and Attestations on Old Device 92
10.7 Recovery to a New Device When the Source Device Is Unavailable 94
11 Lifecycle Event: Uninstallation 97
11.1 Wallet User-Initiated Uninstallation 97
11.2 Pre-Uninstallation Security Measures 98
11.3 Data Cleanup and Deletion 99
11.4 Revocation and Deregistration 101
11.5 Verification of Complete Removal 102
12 Lifecycle Event: Revocation (Permanent) 103
12.1 Revocation Triggers and Conditions 103
12.2 Revocation Procedures 106
12.3 Impact on PIDs and Attestations 110
12.4 Data Deletion Requirements 112
13 Monitoring and Fraud Management 114
13.1 General Monitoring and Fraud Detection 114
13.2 State-Specific Monitoring Inputs 115
13.3 Monitoring of the Application and Web Ecosystem 116
13.4 Wallet User Warning Channel 118
Annex A (informative): Lifecycle State Diagram 119
Annex B (informative): Risk Register Cross-Reference 121

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

1 Introduction

1.1 Foreword

The European Digital Identity Wallet (EUDIW) is a new concept introduced by Regulation (EU) 2024/1183 (eIDAS 2) that enables European citizens, residents and businesses to use a digital identity wallet for identification, authentication, and storage of electronic attestations of attributes. The EUDIW framework introduces novel security, privacy, and interoperability challenges that require clear, well-structured technical requirements.

A Wallet Instance is the software application installed on a Wallet User's device, while a Wallet Unit is the personalised, Wallet User-bound instance of that software which has undergone activation and binding to the Wallet User's cryptographic material and identity. The lifecycle of both the Wallet Instance and the Wallet Unit encompasses multiple stages, from initial installation through to permanent revocation, each presenting distinct security risks and operational requirements.

This specification addresses the lifecycle events of Wallet Instances and Wallet Units. It establishes security requirements that Wallet Providers must implement to ensure that wallet onboarding and lifecycle management processes meet the required security level of as foreseen in the eIDAS, whereby --even if the Wallet Provider strictly speaking is not subject to Commission Implementing Regulation (EU) 2015/1502-- a compromise of a citizen's wallet will have dire consequences.

This specification was developed to define security requirements to cover the risks that can arise during the lifecycle events of Wallet Instances and Wallet Units. It is intended to serve as a normative basis for conformity assessment of EUDIW solutions with respect to wallet onboarding and lifecycle management processes.

The requirements defined in this specification are risk-based and have been derived from an analysis of applicable legislation, reference frameworks, and threat models relevant to the EUDIW ecosystem. A companion risk register documents the risk analysis underpinning the requirements and is maintained as a separate deliverable.

This specification is intended to be used by Wallet Providers (as a normative framework for implementation) and by Conformity Assessment Bodies (CABs) as a basis for conformity assessment of the Wallet Provider's implementation.

1.2 Scope

This specification defines the normative requirements applicable to Wallet Providers for secure onboarding and lifecycle management of Wallet Instances and Wallet Units within the NL EUDI Wallet Certification System. It is a subsidiary requirements specification under NL-P-W, the applicable Wallet Provider certification scheme, and the relevant functional and cybersecurity certification requirements for the Wallet Solution.

The specification addresses the provider-operated processes, controls and interfaces by which a Wallet Instance is securely distributed and installed, a Wallet Unit is activated and bound to its Wallet User and cryptographic environment, and the Wallet Unit remains secure, controlled, available and correctly revoked or decommissioned throughout its lifetime.

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

The scope covers the lifecycle events listed below and the associated operational controls, including security checks, attestation and key management, Wallet User authentication, software maintenance, credential protection, migration and recovery, monitoring, support, uninstallation and revocation:

- Wallet Instance Installation: requirements for the secure distribution, delivery, and installation of Wallet Instance software on Wallet User devices;
- Wallet Unit Activation: requirements for the initialisation, cryptographic binding, and authentication setup that constitute the activation of a Wallet Unit;
- Operational State (Without PID): requirements applicable to a Wallet Unit that is active but has not yet received a Person Identification Data (PID) credential;
- PID Storage and Transition to Valid State: requirements governing the secure storage of a PID and the transition of the Wallet Unit to a fully operational valid state;
- Wallet Unit Management and Maintenance: requirements for ongoing operations including software updates, key rotation, attestation renewal, and account recovery;
- Device Change / Migration: requirements for the secure migration of a Wallet Unit to a new device, including decommissioning of the old device;
- Uninstallation: requirements for the secure removal of a Wallet Instance from a device;
- Revocation (Permanent): requirements for the permanent invalidation of a Wallet Unit.

The object addressed by this specification is the Wallet Provider's onboarding and lifecycle-management service and its controlled interaction with the Wallet Instance, Wallet Unit, WSCA/WSCD, Wallet User, PID Provider and other relevant ecosystem parties. Requirements allocated to the PID Provider remain outside the Wallet Provider's responsibility. Nevertheless, this specification defines the controls that the Wallet Provider and Wallet Unit shall apply at their side of those interactions because weaknesses or compromise in the wallet environment can invalidate the security assumptions on which PID issuance, storage, presentation and revocation rely.

The following are explicitly out of scope of this specification:

- Wallet Solutions where it is possible that there is more than one Wallet Instance per Wallet Unit active at the same time;
- PID Provider processes, including identity verification (ID proofing) and PID issuance;
- The lifecycle events of the Wallet Solution (build, versioning, solution suspension, solution revocation,…);
- Wallet Solution-level requirements, including organisational, security policy, hardware, software and infrastructure requirements applicable to the Wallet Solution as a whole;
- Lifecycle events of Electronic Attestations of Attributes (EAA) issued by Attestation Service Providers;
- Relying Party requirements;
- Requirements for the interoperability of Wallet Instances across Member States, which are addressed in the Architecture and Reference Framework.

NOTE: This specification does not preclude implementations from imposing additional requirements beyond those specified herein, provided such requirements do not conflict with the provisions of this specification or applicable regulatory requirements.

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

2 References

2.1 Normative References

The following referenced documents are indispensable for the application of this specification.

Reference	Document
[1]	Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework.
[2]	Commission Implementing Regulation (EU) 2015/1502 of 8 September 2015 on setting out minimum technical specifications and procedures for assurance levels for electronic identification means.
[3]	Commission Implementing Regulation (EU) 2024/2981 of 4 December 2024 laying down rules as regards the certification of European Digital Identity Wallets
[4]	ETSI EN 319 401: "Electronic Signatures and Trust Infrastructures (ESI); General Policy Requirements for Trust Service Providers"
[5]	ETSI TS 119 472-3: "Electronic Signatures and Trust Infrastructures (ESI); Profiles for Electronic Attestation of Attributes; Part 3: Profiles for issuance of EAA or PID"
[6]	European Cybersecurity Certification Group (ECCG): "Agreed Cryptographic Mechanisms", ENISA, latest version. Available at https://www.enisa.europa.eu/publications/agreed-cryptographic-mechanisms
[7]	European Digital Identity Framework Technical Specification TS10, "Data Portability and Download (Export)", https://github.com/eu-digital-identity-wallet/eudi-doc-standards-and-technical-specifications/blob/main/docs/technical-specifications/ts10-data-portability-and-download-(export).md
[8]	ETSI TS 119 612: "Electronic Signatures and Trust Infrastructures (ESI); Trusted Lists".
[9]	ETSI TS 119 471: "Electronic Signatures and Trust Infrastructures (ESI); Policy and security requirements for Attestation Providers".
[10]	Internet Engineering Task Force: "Token Status List", latest version.
[11]	ISO/IEC 18013-5: "Personal identification — ISO-compliant driving licence — Part 5: Mobile driving licence (mDL) application".
[12]	Commission Implementing Regulation (EU) 2024/2979 laying down rules for the application of Regulation (EU) No 910/2014 as regards the integrity and core functionalities of European Digital Identity Wallets, as amended.
[13]	Commission Implementing Regulation (EU) 2024/2977 laying down rules for the application of Regulation (EU) No 910/2014 as regards person identification data and electronic attestations of attributes issued to European Digital Identity Wallets, as amended.

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

2.2 Informative References

The following referenced documents are not essential for the application of this specification but may assist the reader in understanding the context and background of the requirements defined herein.

Reference	Document
[i.1]	Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market.
[i.2]	European Digital Identity Wallet Architecture and Reference Framework, Version 3.0.0 (2026-07-21), published by the European Commission.
[i.3]	ETSI SR 001 262: ETSI drafting rules

3 Terms & Abbreviations

3.1 Terms

For the purposes of this specification, the following definitions apply. Terms defined in eIDAS [1] and the Architecture and Reference Framework (ARF) [i.2] are used in accordance with those documents unless otherwise stated.

Term	Definition
Wallet Instance	The application installed and configured on a Wallet User's device or environment, which is part of a Wallet Unit and which the Wallet User uses to interact with that Wallet Unit.
Wallet Unit	A unique configuration of a Wallet Solution that includes one or more Wallet Instances, Wallet Secure Cryptographic Applications and Wallet Secure Cryptographic Devices, provided by a Wallet Provider to an individual Wallet User.
Wallet Unit Attestation (WUA)	A data object, issued by the Wallet Provider, that describes the components of a Wallet Unit and allows their authentication and validation; in this specification it is not one single object but consists of one or more Wallet Instance Attestations and one or more Key Attestations.
Key Attestation (KA)	An attestation issued by the Wallet Provider certifying, for one or more public keys, that the corresponding private keys are generated within and are non-extractable from an identified keystore, and describing the storage type and the security certification of that keystore.
Wallet Instance Attestation (WIA)	An attestation issued by the Wallet Provider certifying that a Wallet Instance is a genuine instance of the Wallet Solution, and carrying the information required to determine its revocation status.
List of Trusted Entities (LoTE)	A list published by the European Commission identifying the entities recognised for a given role in the European Digital Identity framework, together with the trust anchors to be used to authenticate them.
Trust Anchor	Public key material, together with the identity of the entity to which it belongs, used as the starting point for validating a certification path.
Wallet Provider	A natural or legal person who provides Wallet Solutions.
Wallet Secure Cryptographic Device (WSCD)	A tamper-resistant device that provides an environment, linked to and used by the Wallet Secure Cryptographic Application, to protect critical assets and provide cryptographic functions for the secure execution of critical operations.
Wallet Secure Cryptographic Application (WSCA)	The application component that manages critical assets by being linked to and using the cryptographic and non-cryptographic functions provided by the Wallet Secure Cryptographic Device.
Person Identification Data (PID)	A set of data enabling the identity of a natural or legal person to be established, issued by a PID Provider in accordance with eIDAS 2.
PID Provider	A natural or legal person responsible for issuing and revoking Person Identification Data and for ensuring that the Person Identification Data of a Wallet User is cryptographically bound to a Wallet Unit; typically a Member State authority or body, or a private entity designated by a Member State.
Electronic Attestation of Attributes (EAA)	A set of data in electronic form that allows attributes about a natural or legal person to be authenticated, issued by a (Qualified) Attestation Provider.

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Term	Definition
Conformity Assessment Body (CAB)	A body that performs conformity assessment activities in accordance with applicable standards and legislation.
Activation	The process by which a Wallet Unit is initialised, configured, and bound to a specific Wallet User, device, and cryptographic key material, rendering it operational.
Revocation	A permanent, irreversible invalidation of a Wallet Unit, after which the Wallet Unit cannot be reinstated.
Migration	The process of transferring the state of a Wallet Unit from one device to another while maintaining continuity of the Wallet User's wallet identity and credentials.
Key Material	Cryptographic keys and associated data generated, stored, and managed within the WSCD for the purpose of securing Wallet Unit operations.
Assurance Level	A classification of the degree of confidence in the claimed or asserted identity of a person, expressed as assurance level 'low', 'substantial' or 'high' in accordance with Article 8 of Regulation (EU) No 910/2014 and specified in Commission Implementing Regulation (EU) 2015/1502.

3.2 Abbreviations

For the purposes of this specification, the following abbreviations apply:

Abbreviation	Expansion
ARF	Architecture and Reference Framework
CAB	Conformity Assessment Body
CIR	Commission Implementing Regulation
EAA	Electronic Attestation of Attributes
eIDAS	Electronic Identification, Authentication and Trust Services Regulation [1]
EUDIW	European Digital Identity Wallet
HSM	Hardware Security Module
KA	Key Attestation
LoTE	List of Trusted Entities
WIA	Wallet Instance Attestation
PID	Person Identification Data
QTSP	Qualified Trust Service Provider
SE	Secure Element
TEE	Trusted Execution Environment
TLS	Transport Layer Security
TSP	Trust Service Provider
WUA	Wallet Unit Attestation

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Abbreviation	Expansion
WSCA	Wallet Secure Cryptographic Application
WSCD	Wallet Secure Cryptographic Device

3.3 Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 23 of the ETSI Drafting Rules (Verbal forms for the expression of provisions) [i.3].

3.4 Notations

The requirements identified in the present document include:

a) requirements applicable to any EUDIW implementation. Such requirements are indicated without any additional marking;

b) requirements applicable to specific EUDIW implementations. Such requirements are marked by "[CONDITIONAL]" or indicated by clauses introduced by "[CONDITIONAL]".

The requirements in the present document are identified as follows:

<the 3 to 5 letters identifying the lifecycle> - < the clause number> - <2 digit number – incremental>

This identifier may be used in the companion Assessment Checklist to cross-reference individual requirements.

The lifecycle event identifiers are as follows:

Identifier	Lifecycle Event
INST	Wallet Instance Installation
ACT	Wallet Unit Activation
OPS	Operational State (Without PID)
PID	PID Storage and Transition to Valid State
MAINT	Wallet Unit Management and Maintenance
MIG	Device Change / Migration
UNINST	Uninstallation
REV	Revocation (Permanent)

The management of the requirement identifiers for subsequent editions of the present document is as follows:

- When a requirement is inserted at the end of a clause, the 2 digit number above is incremented to the next available digit.
- When a requirement is inserted at the start of a clause, the 2 digit number 00 is used.

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- When a requirement is inserted between two existing requirements, capital letters appended to the previous requirement identifier are used to distinguish new requirements.
- The requirement identifier for a deleted requirement is left and completed with "VOID".
- When a requirement is modified from the previous edition of the present document, the requirement number is amended by a capital 'X' letter.

3.5 Symbols

No symbols specific to this specification are defined. Mathematical and cryptographic notation follows standard conventions.

4 Relation to Resilience & High Assurance

4.1 Resilience

For the purpose of this specification, resilience refers to the ability of the Wallet onboarding and lifecycle-management processes to maintain the security, integrity and trustworthiness of a Wallet Unit throughout its lifecycle, including when those processes are exposed to attack, compromise, failure or misuse.

Wallet onboarding establishes the initial conditions under which a Wallet Instance becomes a Wallet Unit that can subsequently receive, store and use PID and other attestations. Lifecycle management preserves those conditions as the Wallet Unit moves through the lifecycle events specified in this document, including activation, operational use, maintenance, migration and recovery, uninstallation and revocation.

Resilience therefore depends on more than the security of the Wallet Solution as a product. A Wallet Solution that has been successfully functionally and cybersecurity evaluated can nevertheless cease to provide the intended level of security if the processes through which it is installed, activated, bound, authenticated, maintained, migrated, recovered or revoked can be manipulated or bypassed. The requirements in this specification consequently address the controls necessary to preserve the security properties of the Wallet Unit throughout these processes.

The lifecycle requirements in the following chapters establish defence in depth against attacks on, or misuse of, the individual lifecycle processes. Depending on the lifecycle event, this includes controls intended to:

- prevent counterfeit, modified or otherwise unauthorised Wallet Instances from becoming operational Wallet Units;
- prevent activation or continued operation in an environment that no longer satisfies the required security conditions;
- preserve the binding between the Wallet Instance, Wallet Unit, WSCA/WSCD, protected cryptographic keys and the applicable Wallet User authentication mechanisms;
- prevent cloning, unauthorised transfer or unauthorised use of a Wallet Unit or its cryptographic material;
- preserve the security properties established during initial onboarding when software, cryptographic material, attestations or credentials are updated or renewed;
- ensure that migration, recovery and replacement do not provide a weaker alternative route for establishing control over a Wallet Unit;
- detect conditions indicating that the assumptions underlying the trustworthy operation of a Wallet Unit may no longer hold;
- provide mechanisms for responding to loss, compromise or suspected fraudulent use; and
- ensure that a Wallet Unit that can no longer be trusted can be securely and effectively revoked or decommissioned.

These controls are mutually reinforcing. Resilience is therefore an end-to-end property of the onboarding and lifecycle-management processes rather than the result of any single technical control or lifecycle event. A weakness in one lifecycle process can undermine security properties established by another. For example, strong protection of cryptographic

keys during normal operation would not provide the intended protection if an attacker could obtain control through a weaker migration or recovery process, while secure initial installation would not preserve trust if a compromised Wallet Unit could remain operational because revocation was ineffective.

The requirements in the following chapters shall consequently be assessed both individually and in their lifecycle context. The CAB shall evaluate whether the Wallet Provider's implementation maintains the security properties required for the Wallet Unit across the applicable lifecycle transitions and whether alternative, exceptional and recovery paths introduce opportunities to bypass controls applying during the normal lifecycle path.

This concept of resilience is specific to Wallet onboarding and lifecycle management under this specification. It does not refer to the broader organisational cyber-resilience requirements applicable to the Wallet Provider or to requirements governing secure product development and vulnerability management, which are addressed elsewhere within the NL EUDI Wallet Certification System. The purpose of this clause is instead to establish the security rationale connecting the lifecycle requirements that follow: the Wallet Unit should remain trustworthy not only when initially established, but throughout every subsequent lifecycle event that can affect its security or control.

4.2 High Assurance

The Wallet Provider is not, in its capacity as Wallet Provider, subject to the requirements for assurance levels established by Commission Implementing Regulation (EU) 2015/1502. In particular, the Wallet Provider does not thereby assume the responsibilities of the PID Provider for identity proofing, identity verification or the issuance of Person Identification Data (PID). These responsibilities remain allocated to the PID Provider in accordance with the applicable regulatory and certification framework.

Nevertheless, the onboarding and lifecycle-management processes performed by the Wallet Provider can have a material impact on the continuing trustworthiness of the digital identity of the Wallet User. Once a PID has been issued to a Wallet Unit following the applicable identity-proofing and issuance processes, the security of that digital identity depends not only on the correctness of the original identity-proofing process, but also on the continued integrity of the Wallet Unit and on the effectiveness of the processes through which that Wallet Unit is activated, maintained, authenticated, migrated, recovered and eventually revoked or decommissioned.

A compromise of these lifecycle processes could undermine the relationship between the verified identity, the Wallet User and the Wallet Unit. For example, an attacker who succeeds in obtaining unauthorised control over a Wallet Unit, its protected cryptographic material or an inadequately secured recovery or migration process could potentially exercise capabilities associated with a digital identity that was originally issued following a correctly performed identity-proofing process. Consequently, the assurance established during PID issuance can be undermined in practice if the Wallet lifecycle processes fail to preserve the security conditions on which subsequent use of that PID relies.

The requirements specified in Chapters 5 to 13 therefore aim to ensure that the Wallet Provider preserves, throughout the applicable lifecycle events, the security properties necessary to protect the relationship between the Wallet User, the Wallet Unit and the digital

identity represented by the PID. This includes, as applicable, maintaining the integrity and authenticity of the Wallet Instance and Wallet Unit, protecting cryptographic keys and authentication mechanisms, preserving relevant bindings, preventing unauthorised transfer or takeover, securely managing maintenance and changes, protecting migration and recovery processes, and enabling effective response to loss, compromise and revocation.

In this context, high assurance is not a separate assurance level assigned to the Wallet Provider under CIR (EU) 2015/1502. Rather, it expresses the security objective that Wallet onboarding and lifecycle-management processes shall not introduce weaknesses that could materially undermine the assurance associated with the Wallet User's digital identity. The controls specified in this document are therefore intended to preserve the security conditions necessary for that identity to remain trustworthy throughout the operational lifecycle of the Wallet Unit.

The CAB shall assess the requirements in the following chapters from this perspective. The assessment shall determine whether the Wallet Provider's lifecycle processes adequately protect against circumstances in which compromise, misuse, failure or circumvention of those processes could result in loss of control over the Wallet Unit, unauthorised use of the Wallet User's digital identity, or continued reliance on a Wallet Unit for which the required security conditions can no longer be assured.

5 Lifecycle Event: Wallet Instance Installation

5.1 Secure Software Distribution and Delivery

INST-5.1-01: The Wallet Provider shall sign the Wallet Instance software package using a private key associated with the Wallet Provider's registered identity in the target distribution platform's certificate infrastructure, such that the distribution platform or device can verify the signature before permitting installation.

Guidelines

- *Code signing creates a cryptographic link between each published Wallet Instance software package and the Wallet Provider's registered developer identity. The target platform verifies the signature as part of the installation process and rejects packages whose signatures cannot be validated or do not correspond to the registered developer identity. This requirement applies to every release of the Wallet Instance software, including updates and patches.*
- *Without code signing, an attacker could substitute a modified Wallet Instance software — for example, via a phishing download link, a compromised mirror, or a malicious app store listing — and users would have no technical means to detect the substitution before installation.*
- *On Android, code signing is implemented via Android App Signing, where the Wallet Provider registers a signing key or upload key with the distribution channel. On iOS, signing uses an Apple Developer certificate issued to the Wallet Provider. For direct or enterprise distribution outside a platform app store, the platform's device management infrastructure or managed distribution mechanism provides equivalent signature verification. The specific mechanism depends on the distribution channel used.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's code signing configuration and confirming that the signing key is registered with the Wallet Provider's identity in the distribution platform. The CAB may also attempt to install a test package signed with an unregistered key and confirm that the target platform refuses installation.*

INST-5.1-02: The Wallet Provider shall distribute the Wallet Instance software exclusively through distribution channels that enforce signature verification of the software package as a condition of delivery to the Wallet User's device.

Guidelines

- *A distribution channel enforces signature verification when the channel itself, or the device's installation infrastructure, validates the Wallet Provider's code signature before making the Wallet Instance software available for installation. Official platform app stores enforce this verification as a core part of their delivery infrastructure.*
- *Without distribution channel controls, a modified or counterfeit Wallet Instance software can reach users through an unauthorized path that bypasses platform-level signature verification, giving users no technical means to detect that the package they install is not the legitimate Wallet Instance software.*
- *For direct distribution (e.g., a government-operated distribution mechanism for a national wallet), the Wallet Provider documents the integrity enforcement mechanism used by the distribution channel and confirms it is equivalent in effect to platform app*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

store enforcement. The list of approved distribution channels and their integrity mechanisms is maintained as part of the Wallet Provider's security documentation.

- *A CAB verifies this requirement by reviewing the Wallet Provider's documented distribution channels and confirming that each channel enforces signature verification prior to delivery. The CAB examines whether any unapproved distribution paths exist and whether the Wallet Provider has controls to detect and respond to use of unauthorized channels.*

INST-5.1-03: The Wallet Provider shall ensure that the Wallet Instance verifies the integrity of its own software prior to initializing any Wallet Unit functionality, by performing a cryptographic check of the installed package against a reference value established at install time and protected within the device's hardware-backed key store or WSCD.

Guidelines

- *Integrity verification at launch time detects modifications made to the installed software after it was placed on the device — for example by a malware application exploiting root or OS-level access, or by a supply-chain compromise targeting the device's file system after installation.*
- *Without this control, modifications to the Wallet Instance binary after installation would go undetected and could result in a compromised Wallet Instance operating with the Wallet User's credentials.*
- *Acceptable approaches include using platform-provided attestation APIs (e.g. Android Key Attestation with Play Integrity, iOS App Attest), hash verification of the application bundle against a signed reference value stored within the WSCD, or OS-level application integrity verification that is enforced prior to any Wallet Unit operation.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's technical documentation and confirming that an integrity check is performed at each application launch prior to any Wallet Unit operation. The CAB may corroborate this by inspecting the launch-time integrity-check configuration and, where feasible, by testing that a modified application binary causes the Wallet Instance to refuse to initialise Wallet Unit functionality.*

INST-5.1-04: The Wallet Provider shall hold the private signing key used for the Wallet Instance software package in a hardware security module (HSM) that requires multi-person authorisation for each signing operation and that is certified to FIPS 140-3 Level 3, Common Criteria EAL4+, or an equivalent recognised level.

Guidelines

- *Multi-person authorisation means that no single operator can produce a valid signature; at least two distinct authenticated operators are required for each signing event. The HSM enforces this in hardware so that operational compromise of one credential does not lead to unauthorised signing.*
- *Without this control, an attacker who obtains a single set of operator credentials -- or who exploits a misconfiguration that allows a build server to invoke signing automatically -- can produce signed Wallet Instance software packages that pass downstream signature verification, yielding a malware path indistinguishable from a legitimate release.*
- *Acceptable approaches include cloud-HSM offerings with quorum-based signing policies, on-premises HSMs with smart-card-based operator authentication, and code-signing services that combine HSM-resident keys with a release-officer approval workflow. The HSM certification level applies to the device itself, not just the cloud platform fronting it.*

- *A CAB verifies this requirement by reviewing the HSM certificate, the configured signing policy, and the access list for operators authorised to release a signature, and by sampling the audit log to confirm that recent signing events were performed under the multi-person policy.*

INST-5.1-05: The Wallet Provider shall record, in a tamper-evident log retained for at least 12 months, every administrative action that modifies the Wallet Instance software package, the code-signing infrastructure, or the configuration of the distribution channel, together with the identity of the operators and the time of the action.

Guidelines

- *A tamper-evident log is one whose entries can be independently shown to be unaltered since their creation, typically by chained hashes, append-only storage with cryptographic anchoring, or write-once media. The log captures both successful and rejected administrative actions.*
- *Without this control, an insider or an attacker who gains administrative access can modify the build, the signing key configuration, or the distribution settings and subsequently erase evidence of the change, leaving the Wallet Provider unable to detect the compromise during incident response or audit.*
- *Acceptable approaches include forwarding administrative actions to a central SIEM with cryptographic log integrity protection, using a managed cloud audit-log service with a customer-controlled retention lock, or operating an internal append-only ledger backed by a trusted timestamp authority. Twelve months is a minimum; longer retention may be required by the Wallet Provider's regulatory obligations.*
- *A CAB verifies this requirement by inspecting the log retention configuration and by sampling logs from the most recent 12 months for a selection of administrative event types to confirm they are retained and complete. The CAB may also review the tamper-evidence design and, where feasible, attempt under controlled conditions to alter a logged entry to confirm that tamper evidence is produced.*

INST-5.1-06: The Wallet Provider shall verify, before incorporating any third-party software component into a Wallet Instance software build, that the component's distribution origin is authenticated through a cryptographic signature or hash that traces to a publisher identity declared in the Wallet Provider's approved-supplier list.

Guidelines

- *An approved-supplier list is a controlled register of publishers and components that the Wallet Provider has assessed for security and ongoing maintenance. Verification requires that each component's signature or hash matches a value bound to a publisher in that list, preventing substitution of a similarly named but unverified package.*
- *Without this control, an attacker who tampers with an upstream component repository, performs a typosquatting attack against a package manager, or compromises a transitive dependency can introduce malicious code into the Wallet Instance software binary. The downstream signature on the Wallet Instance software package will still be technically valid, masking the supply-chain compromise.*
- *Acceptable approaches include a signed software bill of materials (SBOM) verified during build, integration with a binary repository that enforces signed-publisher policies, vendoring of dependencies into a Wallet Provider-controlled repository, or use of a build system that pins each dependency to a publisher-signed cryptographic hash.*
- *A CAB verifies this requirement by reviewing the approved-supplier list, the build configuration that enforces signature or hash verification, and the most recent SBOM produced by a build. Where feasible, the CAB may also attempt to introduce an*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

unsigned or wrong-hash component into the build to confirm that the build pipeline rejects it.

5.2 Device Security Pre-Checks

INST-5.2-01: The Wallet Provider shall ensure that the Wallet Instance, at installation and at each subsequent launch, verifies that the operating system version and security patch level of the host device meets the minimum requirements documented by the Wallet Provider, and refuses to activate Wallet Unit functionality on devices that do not meet those requirements.

Guidelines

- *Operating system security patch levels are published by platform vendors on a regular cycle. Devices that are significantly out of date are exposed to known vulnerabilities for which patches exist but have not been applied.*
- *Without this control, the Wallet Instance could operate on devices running OS versions with known critical vulnerabilities that could be exploited to extract key material or bypass Wallet Unit security controls.*
- *The Wallet Provider documents the minimum supported OS version and security patch level. The documented minimum is reviewed in response to newly disclosed vulnerabilities. When a new minimum is enforced, Users on non-compliant devices are notified before the change takes effect.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented minimum OS requirements and the implementation that enforces them, confirming that Wallet Unit functionality is not activated on a device that does not meet those requirements. Where feasible, the CAB may also test the Wallet Instance on such a device and confirm that the application refuses to activate Wallet Unit functionality.*

INST-5.2-02: The Wallet Provider shall ensure that the Wallet Instance detects the presence of root access or jailbreak conditions on the host device and, where such conditions are detected, refuses to finalize Wallet Instance Installation.

Guidelines

- *Root access on Android and jailbreak on iOS refer to conditions in which the device operating system's security boundaries have been removed, allowing any process on the device (including malicious applications) to access files and memory belonging to other applications, including the Wallet Instance.*
- *Without this control, on a rooted or jailbroken device, the file-system sandbox that protects Wallet Instance data from other applications is not enforced. An attacker with root access can directly read the Wallet Instance's data partition and extract keys from software-backed storage.*
- *The Wallet Provider documents the detection mechanism used and the response applied when root/jailbreak is detected and the mechanism that prevents Wallet Instance Installation.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented root/jailbreak-detection design and confirming that installation is refused on a rooted (Android) or jailbroken (iOS) device. Where feasible, the CAB may also attempt installation on a rooted or jailbroken test device to confirm that the Wallet Instance installation is impossible.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

INST-5.2-03: The Wallet Provider shall implement runtime anti-tampering controls in the Wallet Instance that detect attempts to instrument, hook, or modify the application's execution at runtime.

Guidelines

- *Runtime tampering refers to dynamic instrumentation (e.g. using Frida or similar tools), hooking of system APIs, or memory manipulation applied to a running process. These techniques are used to extract secrets, bypass authentication checks, or intercept cryptographic operations.*
- *Without runtime protection, an attacker who has obtained physical or logical access to the device can instrument the running Wallet Instance to extract credentials, observe authentication operations, or bypass security controls without modifying the installed binary.*
- *Acceptable controls include detection of debugger attachment, detection of instrumentation frameworks, integrity checks on critical code sections executed at runtime, and root/jailbreak detection linked to operation refusal.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented instrumentation-detection design and confirming that the application detects attachment of a dynamic instrumentation framework and refuses to process Wallet Unit operations. Where feasible, the CAB may also attach such a framework to a running test instance and confirm the detection and refusal.*

INST-5.2-04: The Wallet Provider shall ensure that the Wallet Unit refuses to finalize Wallet Instance installation when the runtime anti-tampering controls detect an attempt to instrument, hook, or modify the application's execution.

Guidelines

- *Where the runtime anti-tampering controls signal that the application is being instrumented, hooked, or otherwise modified as it runs, installation does not complete: the Wallet Unit stops short of finalising rather than activating on a device where tampering is already present.*
- *If installation completed despite a detected tampering attempt, the Wallet Unit would be activated inside an environment an attacker already controls, from which credentials and authentication factors could be observed or manipulated from the outset.*
- *The detection itself is provided by the runtime anti-tampering controls established earlier in this clause; this requirement governs the response to a positive detection, namely halting finalisation of the installation.*
- *A CAB verifies this requirement by reviewing the documented anti-tampering controls and confirming that installation performed under an instrumentation or hooking framework the controls detect does not finalise. Where feasible, the CAB may also run Wallet Instance installation under such a framework and confirm that installation does not finalise.*

INST-5.2-05: The Wallet Provider shall document and enforce minimum security requirements for devices on which the Wallet Instance may be installed and operated, including at minimum: a screen lock mechanism using a PIN, password, or biometric factor; the availability of a hardware-backed key store; and a supported operating system version receiving security updates from the platform vendor.

Guidelines

- *The minimum security baseline for the host device is a prerequisite for the Wallet Unit's security controls to function as intended. A device without a screen lock or*

hardware-backed key store cannot provide the level of physical security required for key material protection.

- *Without minimum device requirements, the Wallet Instance could be installed on devices that lack the hardware or OS features required to support the cryptographic operations and access controls on which the Wallet Unit's security model depends.*
- *The minimum requirements are documented in the Wallet Provider's public terms of use and technical documentation. The Wallet Instance enforces these requirements at installation and at each launch, refusing to activate Wallet Unit functionality on non-compliant devices.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented minimum device requirements and by confirming that the Wallet Instance refuses to activate Wallet Unit functionality on a test device that does not satisfy them.*

INST-5.2-06: The Wallet Provider shall ensure that the Wallet Secure Cryptographic Device used by the Wallet Unit is operated solely under the Wallet Provider's control, holds a valid security certification appropriate for the applicable Assurance Level prior to its first use by a Wallet Unit, and remains under the Wallet Provider's exclusive operational control throughout the entire lifetime of the Wallet Unit.

Guidelines

- *In the remote WSCD model, the Wallet Secure Cryptographic Device is not located on the Wallet User's device but is a cryptographic service operated by the Wallet Provider in a controlled infrastructure environment. The Wallet Provider selects, deploys, and maintains the WSCD independently of any Wallet User's device, and is therefore in a position to verify and enforce WSCD certification status and operational integrity at all times. This changes the security assurance model: security guarantees derive from the Wallet Provider's governance of the WSCD rather than from per-device verification at installation time.*
- *In the remote WSCD model, the Wallet User's device is not required to host a WSCD and the risk profile therefore does not include the possibility of an uncertified or missing on-device WSCD. The applicable risk is instead that the Wallet Provider fails to maintain the security properties of the remote WSCD — for example by operating an uncertified device or allowing the WSCD to become accessible to parties other than the Wallet Provider. This requirement directly addresses that risk.*
- *The Wallet Provider's WSCD certification is documented as part of the conformity assessment evidence for the applicable Assurance Level. The Wallet Provider maintains records of WSCD certification status, including certification expiry dates and renewal obligations, and includes WSCD governance in its ongoing compliance program. Where a WSCD certification approaches expiry, the Wallet Provider initiates recertification or replacement in advance to ensure continuity of conformance.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documentation of the WSCD used in production, confirming that a valid security certification appropriate for the applicable Assurance Level is current and on record, and verifying that the Wallet Provider's operational procedures ensure the WSCD remains under their exclusive control. The CAB also confirms that no pathway exists for parties other than the Wallet Provider to operate or access the WSCD.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

INST-5.2-07: The Wallet Provider shall implement mechanisms in the Wallet Instance to detect the presence of known malicious applications or anomalous runtime conditions on the host device that could expose Wallet Unit key material or credentials to unauthorised access, and shall, upon detection, prevent Wallet Unit operations involving access to key material until the threat is resolved.

Guidelines

- *Malicious applications on the same device as the Wallet Instance may use overlay attacks, accessibility service abuse, clipboard interception, or keystroke logging to observe or intercept Wallet Unit operations, including attempts to capture the Wallet User's authentication factors — for example reading the PIN as it is entered, through a window drawn over the PIN-entry screen or through logging of the keystrokes. The presence of such applications creates a threat to the confidentiality of credentials and of the authentication factors that protect them.*
- *Without threat detection, the Wallet Instance operates in the same environment as known malicious applications without awareness of the risk, relying solely on the OS sandbox. Where sandbox bypass techniques are available or where the malicious application has elevated privileges, this protection may be insufficient.*
- *Acceptable detection mechanisms include integration with platform-provided security APIs (e.g. Google Play Integrity, Android SafetyNet), detection of known malicious application signatures, monitoring for anomalous accessibility service configurations, and detection of overlay windows drawn over Wallet Unit screens and of input-capture conditions active during authentication-factor entry. The Wallet Provider documents the threats covered, including capture of authentication factors such as the PIN, and the detection mechanism used.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's threat detection implementation documentation and confirming that the Wallet Instance responds appropriately to a known malicious application signature or anomalous condition. Where feasible, the CAB may also test the Wallet Instance's behaviour when such a condition is simulated on the test device.*

5.3 Installation Process Security

INST-5.3-01: The Wallet Provider shall distribute the Wallet Instance exclusively through the official app store of the operating system of the Wallet User's device; or, where distribution through alternative channels is necessary, shall implement a mechanism enabling even a Wallet User with low digital savviness to verify the authenticity of the Wallet Instance prior to installation and shall provide the Wallet User with clear instructions for completing that verification.

Guidelines

- *Official app store distribution ensures that the operating system of the Wallet User's device can perform authenticity checks on the Wallet Instance before installation, reducing the risk of distributing a tampered or counterfeit application.*
- *Where side-loading is unavoidable — for instance, on platforms without an official app store, or for enterprise deployments — the Wallet Provider documents the verification mechanism and ensures that any OS limitations on side-loading are restored after installation.*
- *Typical verification mechanisms for alternative distribution include code-signing certificate checks, hash verification against a published manifest, or a dedicated authenticity check screen presented by the Wallet Instance on first launch.*

- *A CAB verifies this requirement by confirming: (i) the primary distribution channel is the official OS app store, or (ii) the alternative distribution mechanism and the verification instructions are documented and validated during certification.*

INST-5.3-02: The Wallet Provider shall ensure that the Wallet Instance requests only those device permissions strictly necessary for the functioning of declared Wallet Unit features, and shall present the Wallet User with a plain-language explanation of the purpose of each permission at the time it is requested.

Guidelines

- *Device permissions (such as camera, location, or biometric access) grant the Wallet Instance access to sensitive device resources. Requesting permissions beyond those required for declared functionality constitutes unnecessary data collection and conflicts with data minimisation obligations under GDPR Article 5(1)(c).*
- *Without this control, the Wallet Instance could accumulate permissions not required for its declared functions, creating unnecessary exposure of Wallet User data and expanding the application's attack surface.*
- *The set of permissions requested is reviewed and documented during each release cycle. Permission requests that cannot be directly linked to a declared Wallet Unit feature are removed before release. The explanation presented at each permission request is in plain language and accurately describes the specific feature requiring the permission.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's permission manifest and confirming that each declared permission is linked to a documented Wallet Unit feature, and by inspecting the installation flow to confirm that permission request screens include clear plain-language explanations. Where feasible, the CAB may also walk the installation flow on a test device to observe these explanations.*

INST-5.3-03: The Wallet Provider shall ensure that the Wallet Instance, at the time of installation, operates within an operating system-enforced isolation boundary that prevents co-located applications from accessing, reading, or modifying data stored by the Wallet Instance, including PID credentials, Electronic Attestations of Attributes, cryptographic key material, and any personal data processed by the Wallet Instance.

Guidelines

- *Operating system-enforced isolation takes the form of application sandboxing, confining each application's data to a private storage area inaccessible to other applications at the filesystem level. Mobile operating systems provide this mechanism through mandatory access controls. The Wallet Provider relies on this OS-level mechanism and must not operate on devices where OS-enforced isolation has been circumvented, such as rooted or jailbroken devices.*
- *Without this control, a malicious application installed on the same device as the Wallet Instance could read PID credentials or other personal data from the Wallet Instance's private storage, access authentication tokens or session state, or interfere with the Wallet Instance's operation. The risk is heightened on devices where the OS-enforced isolation has been removed entirely, enabling any application with elevated privileges to access any other application's data.*
- *The Wallet Provider may rely on the OS-level sandbox without additional cryptographic file-level isolation above it, provided that the installation-time device integrity assessment confirms that: (i) the OS enforces application sandboxing; (ii) the device shows no indicators of compromise that would undermine sandboxing. Communication between the Wallet Instance and the WSCA is performed through a secure inter-*

process communication channel that does not expose key material to other applications.

- *A CAB verifies this requirement by reviewing the Wallet Provider's technical specification to confirm that the Wallet Instance relies on OS-enforced application sandboxing and that installation is refused on devices where sandboxing cannot be confirmed. Where feasible, the CAB may also attempt to read the Wallet Instance's private data storage from a co-located test application on a compliant device and confirm that access is denied by the OS.*

INST-5.3-04: The Wallet Provider shall ensure that the Wallet Instance is shipped with a secure default configuration such that no Wallet Unit functionality is accessible prior to completion of the initial activation process and no personal data is transmitted by the Wallet Instance before the Wallet User has accepted all required privacy disclosures.

Guidelines

- *Secure-by-default configuration means the application's initial state requires active steps (activation, consent) before any functionality involving credentials or personal data is enabled. There is no partial activation path that bypasses security setup.*
- *Without this control, a partially configured Wallet Instance could expose default credentials, transmit device identifiers, or accept connections before the Wallet User has provided consent.*
- *The Wallet Provider documents the security configuration baseline applied to all shipped Wallet Instance builds, including network connectivity restrictions, credential access restrictions, and data transmission restrictions enforced prior to activation completion.*
- *A CAB verifies this requirement by reviewing the documented pre-activation behaviour of the Wallet Instance and confirming that, before activation is complete, no Wallet Unit functionality is accessible, no sensitive data is transmitted, and the application does not accept connections from external services. Where feasible, the CAB may also test a freshly installed Wallet Instance prior to completing activation to confirm this behaviour.*

5.4 Wallet User Information and Consent

INST-5.4-01: The Wallet Provider shall present the Wallet User, prior to completing installation of the Wallet Instance, with clear and comprehensible information about the nature of the wallet, the categories of personal data processed, the applicable terms and conditions, and the security responsibilities of the Wallet User.

Guidelines

- *The disclosure prior to installation covers the categories of personal data collected and processed during installation and ongoing use (including, for example, device identifiers and biometric data if used for authentication), the applicable terms and conditions of use, the Wallet User's security responsibilities including the obligation to protect access credentials, and any data sharing relationships with PID Providers, Attestation Providers, or other parties. The Wallet User's acceptance of the disclosures is recorded and retained by the Wallet Provider.*
- *In a scenario where a Wallet User installs a Wallet Instance without receiving adequate information about how the wallet processes personal data, the applicable terms and conditions, or their security responsibilities, the Wallet User could use the wallet in ways that expose them to unauthorised credential presentation or identity theft — for instance, by sharing their authentication credentials or installing the wallet on a*

compromised device without understanding the security implications. Absence of adequate disclosure also removes the legal basis for personal data processing under applicable data protection law.

- *Disclosure is typically implemented as a mandatory consent screen presented during the installation flow, before the installation can proceed. The privacy notice and terms of service are presented in plain, non-technical language. The implementation can use a multi-step presentation where different categories of disclosure are presented in sequence. All required disclosures are presented before the installation completes — deferred or post-installation disclosure does not satisfy this requirement. Versions in the Wallet User's preferred official language are provided.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documentation to confirm the content of the required disclosures - covering the categories of personal data, terms and conditions, and security responsibilities - and the mechanism for recording Wallet User consent. Where feasible, the CAB may also perform a fresh installation to confirm that all required disclosures are displayed before installation completes and that installation cannot proceed without acknowledgement of them.*

INST-5.4-02: The Wallet Provider shall ensure that the Wallet User is presented with the Wallet Provider's terms of service prior to completing installation of the Wallet Instance, that acceptance constitutes an explicit Wallet User action, and that the Wallet Instance is not operable until that acceptance has been recorded.

Guidelines

- *The terms of service set out the obligations of both the Wallet Provider and the Wallet User in relation to the Wallet Unit. Presenting them prior to completion of installation ensures the Wallet User is bound by those terms before any Wallet Unit functionality is available.*
- *Without this control, the Wallet User may begin using the Wallet Unit without having been informed of the applicable terms, creating uncertainty about the legal basis for the relationship between the Wallet User and the Wallet Provider.*
- *Acceptance is an explicit action — for example, ticking a checkbox or pressing a dedicated accept button — that is not pre-selected and cannot be bypassed. The Wallet Provider records the date and version of the terms accepted for each Wallet User.*
- *A CAB verifies this requirement by reviewing the documented installation flow and confirming that the terms are presented before it completes, that acceptance requires an explicit Wallet User action, and that the Wallet Instance cannot be used if the acceptance step is bypassed. Where feasible, the CAB may also perform a fresh installation to confirm this behaviour.*

INST-5.4-03: The Wallet Provider shall ensure that, prior to completing installation of the Wallet Instance, the Wallet User is provided with a clear and complete description of all categories of personal data processed by the Wallet Unit, the purposes for which each category is processed, and the legal basis under Article 6 of the GDPR applicable to each processing activity.

Guidelines

- *Transparency about data processing is required under GDPR Articles 12–14. The disclosure made at installation time constitutes the primary mechanism by which the Wallet User obtains the information required to exercise data subject rights.*
- *A disclosure that is incomplete, uses technical language without plain-language equivalents, or omits one or more processing activities does not meet the standard for*

transparency. The Wallet User cannot exercise rights in relation to processing they are not informed about.

- *The transparency disclosure covers at minimum: authentication data (device binding key, biometric template hash); operational metadata (session logs, transaction history); identifiers binding the Wallet User to the Wallet Provider; and data shared with third-party service providers. Where processing is based on consent, the disclosure must allow the Wallet User to withhold consent for individual activities without losing access to core Wallet Unit functionality.*
- *A CAB verifies this requirement by reviewing the data processing disclosure presented during installation and confirming that: all processing activities are described; the purpose and legal basis for each is stated; and the disclosure is presented in plain language prior to completion of installation.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

6 Lifecycle Event: Wallet Unit Activation

6.1 WSCD/WSCA Initialisation

ACT-6.1-01: The Wallet Provider shall ensure that all communication between the Wallet Instance (WI) and the Wallet Secure Cryptographic Application (WSCA) during Wallet Unit activation is conducted over a channel that is mutually authenticated and integrity-protected, so that activation data cannot be intercepted, replayed, or tampered with by a third party.

Guidelines

- *The WI-WSCA interface is the internal channel through which the Wallet Instance instructs the WSCA to perform key generation and other cryptographic setup operations. Because this channel is used to establish the foundational security of the Wallet Unit, it must itself be protected against interception and impersonation.*
- *Mutual authentication prevents a rogue application from impersonating either the Wallet Instance or the WSCA during activation. Integrity protection ensures that instructions and responses cannot be silently modified in transit.*
- *For remote HSM architectures, a TLS-based channel with certificate-pinned mutual authentication is typical.*
- *A CAB verifies this requirement by reviewing the technical specification of the WI-WSCA interface and confirming that mutual authentication and integrity protection are documented and implemented for all supported WSCD architecture types.*

ACT-6.1-02: The Wallet Provider shall ensure that all private keys attested in a Key Attestation and all private keys of device-bound PIDs and attestations are generated within the Wallet Secure Cryptographic Device (WSCD), and that those private keys are never extracted from the WSCD in the clear at any point during or after activation.

Guidelines

- *Generating keys within the WSCD ensures that the private key is protected by the hardware security boundary of the WSCD from the moment of creation. Keys that are generated outside the WSCD and then imported cannot benefit from the same level of protection.*
- *The prohibition on extracting private keys in the clear is absolute. If the WSCD supports key export in encrypted form, the resulting protection level must be equivalent to that of the key when stored inside the WSCD.*
- *For remote WSCD architectures (e.g., HSM), the key generation occurs on the remote device and the private key is never transmitted to the Wallet Instance or the Wallet Provider backend.*
- *A CAB verifies this requirement by reviewing the WSCD's certification documentation and confirming that key generation is an on-device operation and that no key extraction path exists in the clear.*

ACT-6.1-03: The Wallet Provider shall verify, before signing and issuing a Key Attestation, that the public keys to be included in that Key Attestation correspond to private keys that were generated by and are stored in the WSCA/WSCD described in that attestation, and that those private keys remain under the exclusive control of the Wallet User.

Guidelines

- *By signing a WUA, the Wallet Provider attests to the binding between the public keys in the WUA and the WSCA/WSCD that holds the corresponding private keys. This*

verification step is the Wallet Provider's mechanism for ensuring the accuracy of that attestation.

- *For remote HSMs, the HSM management interface provides the required assurance.*
- *Exclusive control by the Wallet User means that no party other than the Wallet User (including the Wallet Provider) can use the private key to perform cryptographic operations. The Wallet Provider must not hold a copy of or escrow the private key.*
- *A CAB verifies this requirement by examining the key attestation mechanism documented in the Wallet Provider's technical specification and confirming that verification occurs prior to each WUA issuance.*

6.2 Wallet Instance Attestation and Key Attestation Issuance

ACT-6.2-01: The Wallet Provider shall, before issuing a Wallet Instance Attestation, verify that the requesting Wallet Instance is a genuine instance of its Wallet Solution and that the attestation request has not been replayed, forged, or submitted by an unauthorised party.

Guidelines

- *Verifying the authenticity of the Wallet Instance before WUA issuance prevents an attacker from obtaining a WUA for a fake or modified wallet application, which could then be used to fraudulently request PIDs or attestation.*
- *Replay protection ensures that a previously captured valid WUA request cannot be resubmitted. This is typically achieved through the use of short-lived nonces or challenge-response mechanisms.*
- *The Wallet Provider's verification method may rely on an app attestation mechanism provided by the OS (e.g., Android Play Integrity API, Apple App Attest), a challenge-response protocol using the Wallet Instance's signing key, or a combination of both.*
- *A CAB verifies this requirement by reviewing the technical design of the WUA issuance protocol and confirming that both app authenticity verification and replay protection mechanisms are implemented and tested.*

ACT-6.2-02: The Wallet Provider shall ensure that the Wallet Instance, during Wallet Unit activation, authenticates the Wallet Provider backend before transmitting any device or WSCD information, so that the Wallet Instance can verify it is communicating with the genuine Wallet Provider and not an impostor.

Guidelines

- *Without Wallet Provider authentication, an attacker could set up a rogue backend that collects WSCD characteristics and device data from a Wallet Instance, enabling targeted attacks on the activation process.*
- *Authentication of the Wallet Provider backend is typically achieved via TLS with server certificate validation against a pinned or well-known trust anchor associated with the Wallet Provider.*
- *The Wallet Instance must verify the server certificate before the first data transmission. Certificate pinning or HPKP-equivalent mechanisms are recommended in addition to standard PKI validation to reduce the risk of MITM attacks.*
- *A CAB verifies this requirement by reviewing the activation protocol specification and confirming that the Wallet Instance performs backend authentication prior to any transmission of device or WSCD data during activation.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

ACT-6.2-03: The Wallet Provider shall ensure that each Key Attestation is cryptographically bound to the keystore of the Wallet Unit by including one or more public keys in the Key Attestation whose corresponding private keys are generated by and stored exclusively in the WSCA/WSCD of the Wallet Unit, so that each Key Attestation is tied to a specific, unique WSCD instance.

Guidelines

- *Device binding ensures that a WUA cannot be transferred to or used from a different device or WSCD instance. Combined with key attestation, it allows PID Providers and Attestation Providers to verify that the Wallet Unit they are issuing to is the genuine device-bound unit they expect.*
- *A WSCA/WSCD generates a dedicated key pair for the WUA at activation. The Wallet Provider attests — by signing the WUA — that the private keys corresponding to the public keys in the WUA are stored in the specific WSCA/WSCD described in that WUA.*
- *If a Wallet Unit contains both a WSCA/WSCD and one or more keystores, a separate WUA is issued for each. The Wallet Unit internally tracks which PIDs and attestations are bound to which WSCA/WSCD or keystore.*
- *A CAB verifies this requirement by examining the WUA issuance protocol and confirming that each WUA contains at least one public key with a corresponding private key provably stored in the described WSCA/WSCD.*

ACT-6.2-04: The Wallet Provider shall ensure that each Key Attestation contains, at minimum: (a) information describing the storage type and the security certification of the WSCA/WSCD or keystore in which the attested private keys are stored; and (b) one or more public keys corresponding to private keys generated by and stored in that WSCA/WSCD or keystore.

Guidelines

- *The certification information in the WUA (item a) allows PID Providers and Attestation Providers to verify that the WSCA/WSCD complies with the requirements for Level of Assurance High.*
- *The Wallet Unit identifier (item d) enables PID Providers to request revocation of the Wallet Unit but must be designed so that it cannot be used to correlate the Wallet User's transactions across different PID or attestation providers.*
- *Where the WSCA/WSCD supports export of private keys in encrypted form, the Wallet Provider shall include this capability as an attribute in the WUA.*
- *A CAB verifies this requirement by inspecting sample WUAs against the mandatory content list above and confirming compliance with the format specified in* [5].

ACT-6.2-05: The Wallet Provider shall ensure that each Wallet Instance Attestation contains, at minimum: (a) information enabling PID Providers and Attestation Providers to check the revocation status of that Wallet Instance Attestation; and (b) a Wallet Unit identifier that does not enable tracking of the Wallet User across transactions.

Guidelines

- *The Wallet Instance Attestation carries the information that describes the Wallet Unit as a whole, while the Key Attestation carries the information that describes the keystore and the keys it protects. Separating the two allows a Wallet Unit to present key-related evidence to a provider without disclosing more about the Wallet Unit than that provider needs.*
- *Without revocation status information, a PID Provider or Attestation Provider has no means of establishing that the Wallet Unit it is issuing into has already been revoked, so an attacker who retains a revoked Wallet Unit can continue to obtain new*

attestations. Without a non-correlatable Wallet Unit identifier, the same value presented to several providers allows those providers to link the transactions of one Wallet User.

- *Revocation status information is commonly conveyed as a reference to a status list together with an index into that list. A non-correlatable identifier is commonly obtained by deriving a value that is not reused across attestation batches. The corresponding key-related content is specified in* **ACT-6.2-04***.*
- *A CAB verifies this requirement by inspecting the content of Wallet Instance Attestations issued in production, by confirming that a revocation status reference is present and resolvable, and by confirming that the Wallet Unit identifier is not reused in a form that permits correlation between providers.*

ACT-6.2-06: The Wallet Provider shall sign each Wallet Instance Attestation and each Key Attestation using only cryptographic algorithms included in the ECCG Agreed Cryptographic Mechanisms [6].

Guidelines

- *Using only approved cryptographic algorithms ensures that the WUA signature cannot be forged or weakened by cryptographic attacks. The ECCG Agreed Cryptographic Mechanisms* [6] *list is maintained by ENISA and represents the current European consensus on safe algorithm choices.*
- *Binding the WUA to the specific issuance context prevents replay attacks in which a previously issued WUA is resubmitted to a different PID Provider or Attestation Provider to obtain an unauthorised credential.*
- *Two context-binding methods are defined in* [5]*: (1) the Wallet Provider signs a fresh WUA containing the nonce during the issuance process; (2) the Wallet Unit presents a pre-issued WUA alongside a Proof-of-Possession signature over the nonce, using a private key whose public key is attested in the WUA.*
- *A CAB verifies this requirement by reviewing the cryptographic algorithm selection documented in the Wallet Provider's security specification and confirming that context-binding is implemented for all WUA presentations.*

ACT-6.2-07: The Wallet Provider shall bind each Key Attestation to the specific issuance context in which it is presented, either by incorporating a nonce provided by the PID Provider or Attestation Provider into the Key Attestation, or by presenting the Key Attestation together with a Proof-of-Possession signed over that nonce using a private key attested in that Key Attestation.

Guidelines

- *Binding a Key Attestation to its issuance context ties that attestation to the specific request it answers, so it cannot be lifted from one issuance exchange and replayed in another. The binding is achieved either by carrying a nonce chosen by the receiving Provider inside the attestation, or by accompanying the attestation with a proof of possession signed over that nonce.*
- *Without context binding, an attestation captured in one issuance exchange could be replayed to a different Provider or in a later exchange, letting an attacker present a genuine attestation that does not correspond to the request in front of the Provider.*
- *The two acceptable approaches are those named in the requirement: embedding the Provider-supplied nonce in the Key Attestation, or presenting the attestation together with a proof of possession signed over that nonce using a key the attestation covers. The choice follows the issuance protocol in use.*
- *A CAB verifies this requirement by reviewing the WUA issuance protocol design and confirming that a Key Attestation presented in an exchange other than the one it was*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

issued for is rejected in the absence of the matching nonce or proof of possession. Where feasible, the CAB may also capture a Key Attestation from one issuance exchange and attempt to present it in a different exchange to confirm that the Provider rejects it.

ACT-6.2-08: The Wallet Provider shall ensure that all unique elements of each Wallet Instance Attestation and each Key Attestation — including the attestation identifier used for revocation status checking, the attested public keys, and the Wallet Provider's signature — have a negligible probability of having the same value across all such attestations issued by that Wallet Provider.

Guidelines

- *Uniqueness of WUA elements prevents two distinct Wallet Units from sharing identifiable values that could enable correlation or impersonation.*
- *Cryptographically secure pseudo-random number generators (CSPRNGs) should be used to generate all randomised fields, including revocation identifiers and salts.*
- *The uniqueness requirement applies to the entire set of WUAs issued over the lifetime of the Wallet Provider's service, not only to the current deployment.*
- *A CAB verifies this requirement by reviewing the WUA generation implementation and confirming that CSPRNGs are used for all unique elements.*

ACT-6.2-09: The Wallet Provider shall manage the validity periods of Wallet Instance Attestations and Key Attestations such that a non-revoked Wallet Unit can at all times present a Wallet Instance Attestation and a Key Attestation each with a remaining validity period of at least 31 days, and shall set validity periods taking into account the risk that such an attestation could become a vector for tracking the Wallet User across multiple issuance transactions.

Guidelines

- *PID Providers are required to revoke a PID when the WUA under which it was issued expires. A minimum remaining validity of 31 days is therefore necessary to prevent disruption of PID validity through WUA expiry.*
- *Longer validity periods reduce the frequency of WUA re-issuance but increase the window during which a compromised WUA could be misused. The Wallet Provider must balance these competing risks in its WUA validity period policy.*
- *The validity period policy must account for offline usage: a Wallet User who is offline for an extended period must still be able to present a valid WUA when they reconnect.*
- *A CAB verifies this requirement by reviewing the WUA validity period policy and confirming that renewal processes are tested to ensure uninterrupted WUA availability.*

ACT-6.2-10: The Wallet Provider shall re-issue Wallet Instance Attestations and Key Attestations to a non-revoked Wallet Unit as needed throughout the lifetime of the Wallet Unit, ensuring continuity of the Wallet Unit's ability to receive PIDs and device-bound attestations without requiring re-activation.

Guidelines

- *WUA re-issuance is distinct from Wallet Unit re-activation. Re-issuance updates the WUA (including new public keys and extended validity) while preserving the existing Wallet Unit state, Wallet User account, and enrolled authentication factors.*
- *The re-issuance process must apply the same security verifications as initial issuance, including verification that the WSCA/WSCD is still available and compliant, and that the Wallet Instance is genuine.*
- *The Wallet Unit must proactively notify the Wallet Provider when its WUA is approaching expiry so that re-issuance can be completed before the WUA expires.*

- *A CAB verifies this requirement by confirming that the WUA renewal workflow is documented and tested, and that no degradation in security verification occurs during renewal compared to initial activation.*

ACT-6.2-11: The Wallet Provider shall ensure that device binding for all PIDs and device-bound attestations is implemented by having the WSCA/WSCD or keystore generate a dedicated public-private key pair for each PID or device-bound attestation, and by ensuring that the corresponding private key is generated within and remains protected by the WSCA/WSCD or keystore throughout the lifetime of the attestation.

Guidelines

- *A dedicated key pair per attestation cryptographically ties each credential to the specific WSCA/WSCD or keystore from which it was issued. This prevents a private key that was used to bind one credential from being reused to bind a different credential on a different Wallet Unit, which would make the two credentials appear to originate from the same device without actually doing so.*
- *Without this control, a single shared key pair could be reused across attestations, enabling correlation of a Wallet User's credentials across different providers, or allowing an attacker who recovers one binding private key to forge possession proofs for all credentials on the Wallet Unit.*
- *Each PID or device-bound attestation issuance flow begins with the WSCA/WSCD generating a fresh key pair. The public key is included in the issuance request together with a proof of possession and, where required, a key attestation signed by the Wallet Provider. The private key never leaves the WSCA/WSCD. This applies equally to initial issuance and to re-issuance.*
- *A CAB verifies this requirement by reviewing the issuance protocol documentation for each attestation type and confirming that a new key pair is generated per issuance, by requesting sample issuance transactions and verifying that the public keys differ, and by confirming that the Wallet Provider's WSCA/WSCD architecture prevents key pair reuse across attestation instances.*

ACT-6.2-12: The Wallet Provider shall ensure that every public key to which a PID or a device-bound attestation is bound at issuance is a public key attested in a Key Attestation issued to that Wallet Unit.

Guidelines

- *The Key Attestation is the evidence on which a PID Provider or Attestation Provider relies to establish that the key it binds a credential to is protected by a certified keystore under the exclusive control of the Wallet User. A credential bound to a key that no Key Attestation covers leaves that provider without any such evidence.*
- *Without this constraint, an attacker able to substitute a public key of their own into the issuance request obtains a credential bound to a key held outside the certified keystore, which can then be used from a device the attacker controls while appearing to originate from the legitimate Wallet Unit.*
- *A conformant implementation generates the binding key pair inside the keystore and includes its public key in the Key Attestation presented with the issuance request. The dedicated key pair per attestation is specified in* **ACT-6.2-11***.*
- *A CAB verifies this requirement by comparing, for a sample of issuances, the public key in the issued credential against the set of public keys attested in the Key Attestation presented during that issuance, and by reviewing the issuance logic that enforces this correspondence. Where feasible, the CAB may also attempt an issuance with a key that is absent from the Key Attestation to confirm that it is refused.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

ACT-6.2-13: The Wallet Provider shall establish and maintain a documented policy governing the issuance of Wallet Instance Attestations and Key Attestations that satisfies the requirements of clauses 6 and 7 of [9].

Guidelines

- *The policy states how the Wallet Provider operates the attestation issuance service: the practices applied, the obligations accepted, the controls in place, and the terms under which the attestations may be relied upon.*
- *Without a documented and maintained policy there is no declared baseline against which the practices actually applied can be compared, so a gradual degradation of those practices goes unnoticed by the Wallet Provider, by the providers relying on its attestations and by the supervisory body.*
- *The attestation issuance policy is normally maintained alongside the general policy requirements applicable to the Wallet Provider as a trust service provider set out in* [4].
- *A CAB verifies this requirement by reviewing the attestation issuance policy against clauses 6 and 7 of* [9] *and by confirming that the version in force corresponds to the practices observed during the assessment.*

ACT-6.2-14: The Wallet Provider shall ensure that the revocation-status-maintenance period of each Wallet Instance Attestation and each Key Attestation it issues to a Wallet Unit is at least as long as the longest administrative validity period of any PID or device-bound Electronic Attestation of Attributes issued into that Wallet Unit on the basis of that Wallet Instance Attestation or Key Attestation, and that the revocation status is maintained throughout that period.

Guidelines

- *A PID or device-bound Electronic Attestation of Attributes is bound to keys attested by a Key Attestation and is issued after validation of a Wallet Instance Attestation. A PID Provider or Attestation Provider relies on the revocation status reference of that Wallet Instance Attestation, and of the Key Attestation, to detect revocation of the Wallet Unit for the whole life of the credential it issues, as required by* **REV-12.2-08***. The technical validity period of a Wallet Instance Attestation or Key Attestation is short and the attestation is re-issued as needed under* **ACT-6.2-10***, but the revocation-status-maintenance period — the period during which the Wallet Provider commits to keeping the revocation status resolvable — is separate and is generally longer. Setting it to cover the longest-lived credential in the Wallet Unit keeps the recorded reference usable until that credential expires.*
- *Without this control, the maintenance period could lapse while a PID or device-bound Electronic Attestation of Attributes issued into the Wallet Unit is still valid. After that lapse a PID Provider or Attestation Provider checking the recorded reference could no longer resolve the revocation status, so a later revocation of the Wallet Unit would go undetected and the credential would continue to be accepted.*
- *Acceptable approaches include deriving the maintenance period at issuance from the maximum administrative validity that a PID or device-bound Electronic Attestation of Attributes may have in the ecosystem, and extending it whenever a Wallet Instance Attestation or Key Attestation is re-issued so that it continues to cover the longest-lived credential in the Wallet Unit. Where the ecosystem defines no maximum administrative validity, the Wallet Provider maintains the revocation status for as long as any PID or device-bound Electronic Attestation of Attributes issued into the Wallet Unit remains within its administrative validity period.*

- *A CAB verifies this requirement by reviewing the Wallet Provider's documented policy for setting the revocation-status-maintenance period of Wallet Instance Attestations and Key Attestations and confirming that it is at least as long as the longest administrative validity period of the PIDs and device-bound Electronic Attestations of Attributes issued into the Wallet Unit, and by inspecting issuance records to confirm the committed periods. Where feasible, the CAB may issue a device-bound credential with a long administrative validity and confirm that the maintenance period committed in the corresponding Wallet Instance Attestation and Key Attestation is at least as long.*

6.3 Wallet Instance – Wallet Unit Binding

ACT-6.3-01: The Wallet Provider shall establish the binding between the Wallet Instance and the Wallet Unit by issuing a Wallet Unit Attestation only to a Wallet Instance whose installation has been successfully verified through a platform-level attestation mechanism provided by the device operating system.

Guidelines

- *Platform-level attestation provides a verifiable proof from the device operating system that the Wallet Instance software is the genuine, unmodified version distributed by the Wallet Provider, running on an uncompromised device.*
- *Without this verification, an attacker could install a modified or counterfeit Wallet Instance and interact with the WSCA/WSCD to obtain a WUA, bypassing the Wallet Provider's security controls. Platform attestation prevents this by ensuring that only the genuine Wallet Instance as distributed by the Wallet Provider can be associated with a WUA.*
- *Platform attestation mechanisms include the Play Integrity API (Android) and DCAppAttest (iOS). The attestation result is used as evidence during the WUA issuance protocol; it may be embedded in the WUA or verified by the Wallet Provider backend before the WUA is signed and returned. Where the device does not support a platform attestation API, the Wallet Provider should document the alternative means used to verify Wallet Instance authenticity and the associated residual risk.*
- *A CAB verifies this requirement by reviewing the WUA issuance protocol specification and confirming that a platform attestation step is performed before any WUA is issued. Where feasible, the CAB may also test whether the activation process rejects a modified Wallet Instance or one running on an environment that does not produce a valid platform attestation.*

ACT-6.3-02: The Wallet Provider shall not use persistent device fingerprinting for fraud monitoring or risk assessment purposes; where device-specific identifiers are collected during activation for legitimate operational purposes, the Wallet Provider shall limit collection to the minimum necessary, shall not derive or retain a persistent fingerprint for Wallet User tracking, and shall inform the Wallet User in accordance with the requirements of the General Data Protection Regulation.

Guidelines

- *The Wallet Provider maintains an authoritative list of devices with an active Wallet Instance, making fingerprint-based identification redundant.*
- *Device identifiers collected during activation — such as a platform-assigned identifier used to associate the Wallet Instance with the correct Wallet User account — serve a legitimate purpose but must not be combined into a behavioural fingerprint.*

- *Where the Wallet Provider processes any device-level data beyond what is strictly necessary for Wallet Unit management, Wallet User consent must be obtained and the purpose must be disclosed in the Wallet Provider's privacy notice.*
- *A CAB verifies this requirement by reviewing the data processing inventory of the Wallet Provider and confirming that no persistent device fingerprinting mechanism is implemented for fraud or risk monitoring.*

ACT-6.3-03: The Wallet Provider shall ensure that each Wallet Instance holds cryptographic material that can be used to identify unambiguously the Wallet Instance in a way that this cryptographic data cannot be cloned to another device.

Guidelines

- *The Wallet Instance cryptographic material uniquely identifies this specific Wallet Instance installation on this specific device. This is the primary mechanism that prevents Wallet Instance cloning.*
- *A scenario that this requirement is intended to prevent is one in which an attacker backs up the Wallet Instance application data from a rooted device and restores it to an attacker-controlled device. Without a hardware-bound identity key, the attacker could operate a fully functional copy of the Wallet Instance and interact with Wallet Provider services as the legitimate Wallet User from an unregistered device.*
- *One approach to satisfying this requirement is to store a private key within the device's Secure Storage facility, such as a hardware-backed keystore backed by a Trusted Execution Environment (TEE) or a Secure Element. Such storage prevents extraction or copying of the private key to another device, ensuring that the cryptographic data cannot be cloned. Platform-provided hardware-backed key storage solutions available on modern mobile operating systems can serve as an implementation basis, as can solutions that build authentication layers on top of such platform facilities, provided the underlying private cryptographic material is held in a way that prevents extraction.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's technical architecture for the Wallet Instance cryptographic material and confirming in the design documentation that the material is generated and stored protected at the level specified in the risk analysis. Where feasible, the CAB may also test that the Wallet Instance cannot be successfully authenticated from a device that lacks the required protection or from a copy of the application data restored to a different device.*

ACT-6.3-04: The Wallet Provider shall ensure that the WSCA authenticates the Wallet Instance before performing any cryptographic operation on its behalf, by challenging the Wallet Instance to produce a proof of possession of the cryptographic data mentioned in ACT-5.3-03.

Guidelines

- *Before the WSCA performs any sensitive operation requested by the Wallet Instance — such as key generation, signing, or providing access to WSCA-managed key material — it verifies that the requesting entity is the legitimate Wallet Instance bound to this Wallet Unit at activation time. This verification is based on the hardware-bound Wallet Instance cryptographic materual, the protection of which is specified in ACT-5.3-03.*
- *Without this control, a malicious application on the same device that gains access to the WSCA interface could request WSCA operations on behalf of a legitimate Wallet User. The WSCA would be unable to distinguish between the genuine Wallet Instance and the rogue application, potentially allowing the rogue application to generate binding proofs or access credential material.*

- *Various approaches can achieve the required authentication of the Wallet Instance. One approach is a challenge-response protocol in which the WSCA issues a fresh, session-bound nonce to the Wallet Instance; the Wallet Instance uses its identity private key to produce a cryptographic proof of possession over that nonce; and the WSCA verifies the proof against the corresponding identity public key registered during activation. Other implementation approaches that achieve equivalent proof-of-possession authentication are also acceptable.*
- *A CAB verifies this requirement by reviewing the WSCA-to-Wallet-Instance interface protocol specification and confirming that a challenge-response step is performed before each WSCA operation. Where feasible, the CAB may also test that the WSCA rejects requests accompanied by an invalid or absent identity signature.*

6.4 Wallet User Account Setup with Wallet Provider

ACT-6.4-01: The Wallet Provider shall offer the Wallet User the opportunity to authenticate to an existing Wallet User account before offering the creation of a new Wallet User account during Wallet Unit activation.

Guidelines

- *A Wallet User who already holds an account with the Wallet Provider, for example because a Wallet Unit was previously activated on another device, is directed to that account rather than to a second, parallel one.*
- *Without this ordering, a Wallet User activating a replacement device silently creates a second account and the Wallet Provider loses the association between the two Wallet Units. The earlier Wallet Unit then remains active and unrevoked while the Wallet User believes it has been replaced, and the revocation and support mechanisms attached to the original account become unreachable from the new one.*
- *The account selection step is placed before any account creation step in the activation flow, so that state and entitlements already associated with an existing account are attached to the correct account.*
- *A CAB verifies this requirement by reviewing the documented activation flow for a Wallet User who already holds an account and confirming that authentication to the existing account is offered before the option to create a new account. Where feasible, the CAB may also walk the activation flow on a test device to confirm this ordering.*

ACT-6.4-02: The Wallet Provider shall not collect or process personal identity data about the Wallet User during Wallet Unit activation beyond what is strictly necessary to complete the activation process and to comply with applicable legal obligations.

Guidelines

- *Wallet Unit activation does not require identity verification of the Wallet User in the sense of confirming who the Wallet User is — that step occurs during PID issuance in a later lifecycle phase. Data collection at activation should therefore be limited to what is functionally necessary to establish the Wallet Unit: typically a contact address for security notifications and device-level identifiers required for WUA issuance.*
- *Collecting unnecessary personal data at activation creates an unjustified data protection risk: if the Wallet Provider's systems are compromised, collected data could be disclosed.*
- *The Wallet Provider's Data Protection Impact Assessment shall document each personal data element collected at activation, the legal basis for processing it, and its retention period. The principle of data minimisation (processing only data that is*

adequate, relevant, and limited to what is necessary) shall be applied to the activation data set.

- *A CAB verifies this requirement by reviewing the Wallet Provider's activation data processing inventory and confirming that each data element has a documented necessity and legal basis. Where feasible, the CAB may also test the activation flow to confirm that no personal identity data beyond the documented minimum is requested or stored.*

ACT-6.4-03: The Wallet Provider shall ensure that any modification to the Wallet Unit account configuration after activation requires authenticated and authorised proof from the Wallet Unit or, for emergency procedures, a fresh verification of the Wallet User's identity, and cannot be performed unilaterally by the Wallet Provider without the Wallet User's involvement.

Guidelines

- *Account configuration changes — such as associating a different device or Wallet Instance with the account, changing notification contact details, or altering account security settings — must require cryptographic proof from the current Wallet Unit before the Wallet Provider backend accepts them. This prevents fraudulent account changes by insiders or by an attacker who has compromised the Wallet Provider's administrative systems.*
- *Without this control, a malicious or compromised insider at the Wallet Provider could silently modify a Wallet User's account to associate a different Wallet Instance with it. If the new Wallet Instance is attacker-controlled, the attacker can receive credentials issued to the Wallet User's account and impersonate the Wallet User.*
- *For routine account modifications, the Wallet Unit presents a proof of possession of the WUA private key as authorisation. For emergency scenarios (such as account recovery after loss of the device), the Wallet Provider's documented recovery procedure shall require at minimum a fresh Wallet User identity verification step before the account is modified.*
- *A CAB verifies this requirement by reviewing the account management procedures and confirming that modification requests submitted to the Wallet Provider backend without a valid Wallet Unit proof of possession are rejected and that the emergency recovery procedure requires documented identity re-verification. Where feasible, the CAB may also test that such a modification request without valid proof of possession is rejected.*

ACT-6.4-04: The Wallet Provider shall present the Wallet User with configurable privacy settings during activation, and shall ensure that the default configuration of any optional data processing activity is set to the option that minimises data collection unless the Wallet User has explicitly selected otherwise.

Guidelines

- *Privacy settings at activation give the Wallet User control over optional data processing activities — such as analytics, crash reporting, or usage monitoring — that are not strictly necessary for the Wallet Unit to function. Presenting these settings during activation ensures that the Wallet User makes an informed choice before any such processing begins, in line with the requirement for a valid legal basis under applicable data protection law.*
- *Without explicit privacy settings presented at activation, the Wallet Provider might default to enabling optional data collection features, which may lack a valid legal basis (e.g., if consent is required). It also denies the Wallet User the opportunity to exercise their data subject rights before data collection begins.*

- *Optional data processing features shall be disabled by default and shall require an affirmative opt-in action by the Wallet User during or after activation. The settings shall be accessible and modifiable after activation via the Wallet Unit settings interface. The Wallet Provider shall retain a record of the Wallet User's privacy choices and the time at which they were made.*
- *A CAB verifies this requirement by reviewing the activation Wallet User interface flow and confirming that optional data processing settings are presented and default to the most privacy-protective option, and that the post-activation settings interface allows the Wallet User to view and change privacy choices. Where feasible, the CAB may also exercise the settings interface on a test device to confirm this.*

ACT-6.4-05: The Wallet Provider shall establish and maintain a Wallet User account mechanism that enables the Wallet User to request revocation of the Wallet Unit independently of physical access to the device on which the Wallet Instance is installed.

Guidelines

- *The Wallet User account for revocation provides a means by which the Wallet User can initiate revocation of the Wallet Unit without relying on the device — for example in the event of loss or theft. The account is separate from the Wallet Instance application and is accessible through a web interface or alternative communication channel maintained by the Wallet Provider. The account must be established during Wallet Unit activation, not on demand after a loss event.*
- *Without this mechanism, a Wallet User who loses access to their device has no means to revoke the Wallet Unit, leaving it active and potentially usable by a person who gains physical possession of the device. This creates a window of exposure that cannot be closed without Wallet Provider intervention, which may be slow, inconsistent, or difficult to initiate under stress, while the stolen or lost Wallet Unit remains valid for credential presentations or approval of payment or other transactions.*
- *Acceptable implementation approaches include a password-protected web portal accessible from any device and browser, a verified email- or SMS-based revocation trigger, or a phone-based revocation process through a verified support channel. The Wallet User account must be created and its revocation credentials confirmed during the Wallet Unit activation flow, so that the mechanism is tested and available before any loss event occurs.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documentation for a Wallet User account facility that enables device-independent revocation and confirming that the account is established during the activation flow rather than on first use after a loss event. Where feasible, the CAB may also test that the revocation mechanism can be successfully invoked from a device other than the one hosting the Wallet Instance.*

ACT-6.4-06: The Wallet Provider shall design the Wallet User account for revocation such that the revocation mechanism is accessible to the Wallet User under adverse conditions — including loss of the device, physical displacement, limited access to communications, or a state of stress — while being sufficiently protected against unauthorised use to prevent a third party from revoking the Wallet Unit of another person without that person's authorisation.

Guidelines

- *This requirement recognises that revocation may need to occur under conditions that are inherently difficult for the Wallet User. A Wallet User who discovers that their device has been stolen, or who suspects they have been subject to a phishing attack, may be in a state of stress, may lack access to specific communication channels, and*

may be in an unfamiliar location. The revocation mechanism must function under such conditions and must not presuppose possession of the device, access to a specific phone number, or access to any resource that may itself have been compromised.

- *The risk of a Wallet User being unable to revoke their Wallet Unit because the revocation mechanism is too restrictive is greater than the risk of a third party being able to maliciously revoke the Wallet Unit of another person. Design guidelines must reflect this risk asymmetry: the Wallet Provider's guidelines must state that the risks of not being able to revoke the Wallet Unit outweigh the risks of malicious revocation by a third party, and the design of the revocation mechanism must reflect this assessment.*
- *Wallet Providers should ensure that the revocation mechanism does not rely on anything that might be inaccessible to the user. A password will probably be forgotten or (if written down) be lost or stolen together with the device, the Wallet Holder will probably not have access to his phone for receiving an SMS (as that is the device that is lost or stolen) and might not have access to his e-mail. A potential implementation is a public website where revocation can be requested, that verifies whether the user knows information about the Wallet Holder that the Wallet Holder certainly will know and that that is not overly easy to obtain by others, provided that it is monitored that the revocation system is not abused. Alternatively, the user might be requested to deliver some questions and answers during the setup of the revocation account.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's threat model and design documentation to confirm that the revocation mechanism has been assessed against multiple adverse-condition scenarios, and that the documented design guidelines explicitly acknowledge the risk asymmetry between inaccessibility and unauthorised revocation.*

6.5 Wallet User Authentication Setup

ACT-6.5-01: The Wallet Provider shall ensure that all authentication verification data associated with authentication factors enrolled during activation is stored either within the WSCA/WSCD or in platform-provided hardware-backed key storage, and is not accessible to any application other than the Wallet Instance.

Guidelines

- *Authentication verification data — such as biometric templates, PIN hashes, or authentication private keys — must be protected against extraction with the same rigour as the private key material used for credential binding. If authentication data can be extracted, an attacker can construct an artefact that passes the authentication check without the Wallet User's participation.*
- *Authentication verification data stored in unprotected application storage can be read by any application with file-system access on a rooted device. A stolen biometric template or PIN hash can be replayed or used to bypass authentication, allowing an attacker to access the Wallet Unit and present credentials on the Wallet User's behalf.*
- *For biometric authentication, the biometric template and matching logic shall reside within a Trusted Execution Environment or equivalent hardware-isolated environment, where they are inaccessible to the normal application environment. For PIN/password-based authentication, the Wallet Provider shall use a salted, hardware-bound verification scheme that does not allow offline brute-force without physical access to the device hardware.*
- *A CAB verifies this requirement by reviewing the design documentation for authentication credential storage and confirming that the storage location is hardware-*

backed or WSCA-resident and that no third-party application on the device can read it. Where feasible, the CAB may also attempt to extract authentication verification data from a test device using known extraction techniques to confirm it is not recoverable.

ACT-6.5-02: The Wallet Provider shall ensure that each authentication factor enrolled during Wallet Unit activation is cryptographically bound to that specific Wallet Unit, such that the same factor presented from any other device, copy, or instance cannot authenticate the holder for actions performed by the Wallet Unit.

Guidelines

- *Cryptographic binding means that the authentication factor's verification depends on a secret or key held inside the Wallet Unit's cryptographic boundary (typically the WSCD), so that even if the factor itself (PIN, biometric template, password) were copied to another device, the verification step on that other device would fail because the device-specific key material is not present.*
- *Without this control, an attacker who obtained a copy of the Wallet User's authentication factor -- for example by observing a PIN, copying a biometric image, or exfiltrating an authentication password -- could enrol that factor on a duplicate Wallet Instance under the attacker's control and authorise transactions or PID presentations as the legitimate holder, defeating the regulatory requirement that the eID means be under the holder's exclusive control.*
- *Acceptable approaches include using a WSCD-resident Wallet User authentication key as part of every factor verification step, deriving factor-verification keys from a Wallet Unit-specific seed inaccessible outside the WSCD, or constructing the authentication protocol so that successful factor presentation produces a signature over a Wallet Unit-bound nonce that the Wallet Provider verifies before granting access.*
- *A CAB verifies this requirement by reviewing the design documentation of the Wallet Unit's authentication subsystem and inspecting how factor verification material is stored and protected, confirming that a clone cannot authenticate as the original holder. Where feasible, the CAB may also attempt to perform authentication on a clone of an enrolled Wallet Unit on a separate device using captured factor presentation data and confirm that the clone cannot authenticate.*

ACT-6.5-03: The Wallet Provider shall ensure that the Wallet Unit limits the number of consecutive unsuccessful authentication attempts for each knowledge-based factor to a value not exceeding ten, beyond which the factor is locked until the Wallet User re-establishes proof of holder identity through an out-of-band procedure operated by the Wallet Provider.

Guidelines

- *A knowledge-based factor is one the Wallet User proves by remembering a secret, including PINs, passwords, and answers to challenge questions. The lock takes effect on the device and persists across Wallet Unit restarts; counters are not reset by re-installing or re-loading the Wallet Instance. The out-of-band recovery procedure ties unlock to verified holder identity, not merely to possession of the device.*
- *Without this control, an attacker who obtains the device -- through theft, loss, or temporary access -- can mount an offline or online brute-force search of a four- or six-digit PIN within minutes, exercising the Wallet User's authentication factor and authorising transactions or PID presentations as the holder.*
- *Acceptable approaches include WSCD-enforced attempt counters, exponential attempt delays after a small number of failures combined with a hard lock after the limit, and integration with the Wallet Provider's account-recovery flow for unlock authorisation.*
- *A CAB verifies this requirement by reviewing the Wallet Unit's design documentation for the attempt counter and the documented out-of-band unlock procedure, confirming*

that lock-out is triggered at the limit and that unlock is bound to verified holder identity. Where feasible, the CAB may also attempt on a test Wallet Unit to enter wrong PINs up to and beyond the limit and confirm that lock-out is triggered.

ACT-6.5-04: The Wallet Provider shall ensure that the Wallet User authentication mechanism established during Wallet Unit activation consists of at least two factors of different categories, each verified by the Wallet Secure Cryptographic Application of the Wallet Unit, such that no Wallet Unit operation involving Person Identification Data, the Wallet Unit Attestation, or other attestations at security level High can complete based solely on the Wallet User-device operating-system authentication mechanism.

Guidelines

- *At activation, the Wallet User enrolls at least one factor in each of two distinct authentication categories, and the WSCA verifies each factor itself when the Wallet User authenticates for a Wallet Unit operation. Operating-system authentication on its own -- including device biometrics released by the OS without WSCA verification -- does not constitute a factor satisfying this requirement for operations at security level High.*
- *Without this control, the Wallet Unit could rely on the device's operating-system authentication -- which on some contemporary smartphones is not sufficiently strong and which is often not unique to the Wallet Unit Holder (often children or spouses also have access to the device) -- to authorize PID issuance, presentation, or WUA use. An attacker with access to the device, paired with a high-quality image of the legitimate holder, or a person like a child or spouse that was allowed device access by the Wallet Holder, could thereby cause the Wallet Unit to release PID data or perform Relying Party transactions as the holder, even though no factor verified inside the WSCA was ever satisfied.*
- *A conformant implementation enrolls a Wallet-Unit-internal PIN or password verified by the WSCA as the knowledge factor, in combination with the WSCD-resident PID and WUA private keys as the possession factor. Cross-reference:* **ACT-6.6-01** *establishes the binding of each enrolled factor to the specific Wallet Unit.*
- *A CAB verifies this requirement by reviewing the design documentation for the authentication subsystem and confirming that for PID, WUA, and security-level-High attestation operations the WSCA performs verification of the Wallet User factor itself rather than relying on the OS authentication result alone. Where feasible, the CAB may also attempt on a test Wallet Unit to perform such an operation while supplying only an OS-level authentication and confirm that the operation is rejected.*

6.6 Migration Object import

ACT-6.6-01: The Wallet Provider shall present the Wallet User with the option to restore a Migration Object from another Wallet Unit from the Wallet User.

Guidelines

- *Offering restore means the Wallet Unit presents, as part of the activation flow, an explicit choice to bring in a Migration Object previously produced by another Wallet Unit of the same Wallet User, rather than starting from an empty Wallet Unit.*
- *Without an offered restore path, a Wallet User replacing a device could be forced to obtain every attestation again from scratch, and might instead resort to insecure ad-hoc copying of data between devices to avoid that effort.*
- *The restore option is presented alongside the option to activate a fresh Wallet Unit, so that the choice is made deliberately by the Wallet User.*

- *A CAB verifies this requirement by reviewing the documented activation flow and confirming that the Wallet User is offered the option to restore from a Migration Object before the Wallet Unit is activated empty. Where feasible, the CAB may also run the activation flow on a test device to confirm the option is offered.*

ACT-6.6-02: When the Wallet User provides a Migration Object, the Wallet Unit shall, upon receiving the decryption password from the Wallet User, import all data from the Migration Object.

Guidelines

- *Import proceeds only once the Wallet User supplies both the Migration Object and the decryption password that protects it, so that the data can be decrypted and read into the new Wallet Unit.*
- *If the object could be imported without the Wallet User's password, anyone who obtained a copy of the Migration Object — from cloud storage, a backup, or an intercepted transfer — could load the previous Wallet User's data into a Wallet Unit under their own control.*
- *The decryption password is held only by the Wallet User; the Wallet Provider does not store it. Import decrypts the object in the Wallet Unit and populates the application-layer stores, while key material that cannot be transferred is handled through the re-issuance step that follows.*
- *A CAB verifies this requirement by reviewing the documented import procedure and confirming that the correct password is required for a Migration Object to be imported. Where feasible, the CAB may also attempt an import without the password to confirm it fails, then supply the correct password and confirm the data is imported.*

ACT-6.6-03: After import of the data from a Migration Object, the Wallet Unit shall offer to guide the Wallet User through the re-issuance of the key bound PID and attestations, allowing the Wallet User to select which PID and EAA to have re-issued at that moment.

Guidelines

- *After the data is imported, the Wallet Unit leads the Wallet User through re-issuance of the credentials that are bound to keys, and lets the Wallet User choose which PID and attestations to re-issue at that moment.*
- *Key-bound credentials cannot be moved between devices because their private keys never leave the secure hardware they were created in; if re-issuance were not offered, the imported Wallet Unit would appear populated but its bound credentials would be unusable.*
- *Re-issuance runs the normal issuance flow for each selected credential, generating fresh binding keys in the new device's secure hardware. Selective re-issuance lets the Wallet User restore the most important credentials first and defer the rest, as provided for in the following requirement.*
- *A CAB verifies this requirement by reviewing the documented restore procedure and confirming that the Wallet Unit guides the Wallet User through re-issuance and allows a subset of credentials to be selected. Where feasible, the CAB may also import a Migration Object on a test device to confirm this behaviour.*

ACT-6.6-04: If the Wallet User has not chosen to re-issue all PID and EAA in one go, the Wallet User should have the opportunity to restart the process at a later stage.

Guidelines

- *Where the Wallet User re-issues only some credentials during the initial restore, the Wallet Unit lets the Wallet User resume and complete re-issuance of the remaining credentials later.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *If re-issuance could only be done in a single pass during activation, a Wallet User who deferred or was interrupted would be left with credentials that can never be restored without repeating the whole activation.*
- *The Wallet Unit retains, from the imported Migration Object, the metadata needed to identify which credentials remain to be re-issued, and presents a way to resume the process at a later time.*
- *A CAB verifies this requirement by reviewing the documented restore procedure and confirming that, when only part of the credential set is re-issued, the Wallet Unit offers a way to re-issue the remaining credentials in a later session. Where feasible, the CAB may also re-issue only part of the credential set during a restore and confirm the remaining credentials can be re-issued later.*

ACT-6.6-05: The Wallet Unit shall support all restore mechanisms specified in [7].

Guidelines

- *The Wallet Unit supports the full set of restore mechanisms defined for the Migration Object, so that any object a Wallet User legitimately holds can be restored regardless of which supported mechanism produced it.*
- *If the Wallet Unit supported only some restore mechanisms, a Wallet User whose Migration Object was produced by a different but equally valid mechanism would be unable to restore, and could lose access to recoverable data.*
- *The restore mechanisms are those defined for the Migration Object referenced in this clause; the Wallet Unit implements each of them so that import succeeds for every conformant object.*
- *A CAB verifies this requirement by reviewing the documented set of supported Migration Object mechanisms and confirming that the Wallet Unit imports an object produced by each. Where feasible, the CAB may also restore Migration Objects produced by each supported mechanism and confirm that the Wallet Unit imports each correctly.*

6.7 Migration Object Setup

ACT-6.7-01: The Wallet Provider shall present the Wallet User with an explicit choice about whether to create a Migration Object during the Wallet Unit activation process, before the activation process is considered complete.

Guidelines

- *The choice is presented as a distinct step in the activation flow, not as a pre-ticked option or default selection. The activation flow records which choice the Wallet User made for audit purposes.*
- *Without an explicit choice mechanism, users may proceed through the activation flow without becoming aware that no backup mechanism for their credentials has been created. If the device is subsequently lost or fails, PID credentials and transaction history become permanently irrecoverable. This requirement addresses the risk identified in LR-052 specifically in the Wallet Unit Activation lifecycle event.*
- *Both options — create Migration Object and skip Migration Object — are displayed with equal prominence on a dedicated screen. Pre-selecting either option, or embedding the choice within a longer set of activation consents or terms and conditions, does not satisfy this requirement. The activation record includes the Wallet User's selection for subsequent audit.*
- *A CAB verifies this requirement by reviewing the documented activation flow and confirming that: (i) a dedicated Migration Object choice screen is present; (ii) neither*

option is pre-selected; (iii) the flow cannot advance past this screen without a positive selection by the Wallet User; (iv) the selected option is retrievable from the activation log. Where feasible, the CAB may also exercise the activation flow in a conformance environment to confirm this behaviour.

ACT-6.7-02: When presenting the Migration Object choice, the Wallet Provider shall inform the Wallet User in plain language that without a Migration Object: (a) there will be no list of PID and Wallet Bound EAA for the new Wallet Unit to request reissuance; (b) the transaction log will not be preserved, and the Wallet User will have no means to demonstrate past transactions in the event of a dispute, fraud, or security incident; (c) there will be no mechanism for migrating the non Wallet Bound EAA to a new Wallet Unit.

Guidelines

- *The three-item disclosure is presented in plain, non-technical language. Technical descriptions of the Migration Object structure can be included as supplementary information, but are not a substitute for the three items listed in this requirement.*
- *The disclosure is presented in full each time the Wallet User encounters the Migration Object choice, including any repeated activation flow following a reset.*
- *Users who proceed without a Migration Object without having been given the full three-item disclosure cannot be considered to have made an informed choice. The disclosure ensures that both the immediate and the delayed consequences of forgoing backup protection are understood before the choice is recorded.*
- *A CAB verifies this requirement by reviewing the Migration Object choice screen text and confirming that all three consequence items are explicitly and separately stated in Wallet User-facing language. In localised implementations, each language version is assessed for completeness of all three items.*

ACT-6.7-03: The Wallet Provider shall not complete Wallet Unit activation until the Wallet User has explicitly confirmed their choice regarding the Migration Object.

Guidelines

- *Explicit confirmation means a distinct Wallet User action (e.g. tapping a confirmation button) that is separate from any other activation step. Passive progression through the activation screen without a distinct confirmation action does not satisfy this requirement.*
- *Activation flows that allow passive progression — for example by auto-advancing after a display timeout, or by treating a navigation gesture as an implicit confirmation — do not satisfy this requirement. The risk is that a Wallet User who did not actively engage with the Migration Object choice screen would later dispute that they consented to forgoing backup protection.*
- *This requirement acts as the completion gate for* **ACT-6.7-01** *and* **ACT-6.7-02***. Where the Wallet User confirms the creation of a Migration Object,*
- *A CAB verifies this requirement by reviewing the activation flow and confirming that: (i) a distinct Migration Object choice screen is present; (ii) the disclosure covers all three items of ACT-5.7-02; (iii) the activation process cannot be completed without a distinct confirmation action by the Wallet User; (iv) the confirmation is recorded in the activation log.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

ACT-6.7-04: [CONDITIONAL] Where the Wallet User chooses to create a Migration Object during activation, the Wallet Unit shall require the Wallet User to designate a storage location for the Migration Object before the activation process is considered complete.

Guidelines

- *Storage location selection is performed before the activation process completes, ensuring that the Migration Object has a valid target location from the point the Wallet Unit is first activated.*
- *Without a designated storage location confirmed at activation time, the Migration Object has no valid target for its first update. A failure to designate storage at activation creates the risk that the first transaction after activation produces an update that cannot be written, causing the Migration Object to never be initialised despite the Wallet User's choice to create one.*
- *Acceptable storage locations include personal cloud accounts under the Wallet User's control, device-external encrypted storage, or third-party escrow services the Wallet User has independently enrolled in. As required by* **ACT-6.7-05***, at least one option offered must be under the Wallet User's exclusive control and independent of the Wallet Provider's infrastructure.*
- *A CAB verifies this requirement by confirming that: (i) when the Wallet User selects the option to create a Migration Object, a storage location selection step is present in the activation flow; (ii) activation cannot complete without a storage location being confirmed; (iii) the designated storage location is recorded in the Wallet Unit's activation record.*

ACT-6.7-05: The Wallet Provider shall ensure that at least one storage option offered for the Migration Object is EU based and under the Wallet User’s exclusive control and is not a location controlled by the Wallet Provider.

Guidelines

- *The Wallet Provider’s own storage infrastructure is acceptable as one option among several. Offering only Wallet Provider-controlled storage as the sole option is not acceptable under this requirement, as this gives the Wallet Provider exclusive custody over the Migration Object.*
- *Wallet User-controlled storage is characterised by the Wallet User's ability to independently access, copy, or delete the Migration Object without the Wallet Provider's involvement. Acceptable examples include personal cloud storage accounts, encrypted local storage on a device under the Wallet User's physical control, or hardware security devices under the Wallet User's exclusive possession.*
- *Without at least one Wallet User-controlled storage option, the Wallet Provider holds exclusive custody of the Migration Object. This creates a single point of dependency: if the Wallet Provider ceases operation, is compromised, or restricts access, the Wallet User has no independent path to recover their Migration Object data. The requirement ensures that the Wallet User retains meaningful sovereignty over their own credential backup.*
- *A CAB verifies ACT-5.7-04 and ACT-5.7-05 together by confirming that: (i) the activation flow presents a storage location selection step when the Wallet User chooses to create a Migration Object; (ii) at least one option is under the Wallet User’s exclusive control; (iii) activation cannot be completed without a storage location being selected.*

ACT-6.7-06: The Wallet Unit shall create the Migration Object in accordance with [7].

Guidelines

- *The Wallet Unit produces the Migration Object using the defined structure and protection for that object, so that the object it exports can later be imported by any conformant Wallet Unit.*
- *A Migration Object that departed from the defined structure or protection could fail to import on a replacement device, leaving the Wallet User unable to recover, or could be created without adequate encryption and expose the Wallet User's data.*
- *Creation encrypts the object under a password held only by the Wallet User and includes the data and re-issuance metadata needed for a later restore, mirroring the import behaviour described in clause 6.6.*
- *A CAB verifies this requirement by creating a Migration Object on a test Wallet Unit and confirming that its structure and protection conform and that it imports successfully on a second Wallet Unit.*

7 Lifecycle Event: Operational State (Without PID)

7.1 Security Requirements for Non-PID Use Cases

OPS-7.1-01: The Wallet Provider shall ensure that non-identity attestations stored in the Wallet Unit are protected against unauthorised access or modification by mechanisms equivalent to those applied to PID credentials stored in the same Wallet Unit.

Guidelines

- *Non-identity attestations held before or without a PID — such as loyalty cards, tickets, or membership credentials — receive the same protection against unauthorised access or modification as PID credentials in the same Wallet Unit.*
- *If non-identity attestations were protected more weakly than PID, an attacker who compromised the weaker store could read or alter the Wallet User's data, and could use a foothold there to work towards the more sensitive credentials.*
- *The same storage protection, access control, and integrity mechanisms applied to PID data are applied to non-identity attestations, without a separate, weaker regime for the latter.*
- *A CAB verifies this requirement by reviewing the storage and access-control design and confirming that non-identity attestations are held under the same protections as PID credentials and that access to them requires the same controls. Where feasible, the CAB may also test that access to non-identity attestations requires the same controls.*

OPS-7.1-02: The Wallet Provider shall ensure that the Wallet Unit discloses data from non-identity attestations only in response to a verified relying party request and only to the minimum extent necessary to fulfil that request.

Guidelines

- *The Wallet Unit releases data from a non-identity attestation only after the relying party has been verified and only to the minimum extent needed for the request, rather than disclosing the whole attestation by default.*
- *Without verification and minimisation, a Wallet User presenting a loyalty or membership credential could have the full contents harvested by an unverified party, or disclose far more than the transaction required.*
- *The Wallet Unit checks the relying party before disclosure and supports selective release of individual data elements, so that only the elements the relying party legitimately requires are sent.*
- *A CAB verifies this requirement by issuing presentation requests from verified and unverified test relying parties and confirming that disclosure occurs only for the verified party and is limited to the requested elements.*

OPS-7.1-03: The Wallet Provider shall ensure that the Wallet Unit in the operational state without PID does not complete presentations of credentials or attestations whose issuance or validity depends on a PID credential bound to that Wallet Unit.

Guidelines

- *In the operational state without PID, the Wallet Unit is permitted to store and present non-identity attestations such as loyalty cards, membership credentials, or access tickets that do not require PID binding. This requirement establishes that credentials*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

or attestations requiring PID as a prerequisite for their issuance or validity cannot be presented before PID issuance to the Wallet Unit has been successfully completed.

- *A Wallet Unit without a PID is not allowed to complete transactions or interactions designed to require identity verification through a bound PID. An attacker or an uninstructed Wallet User might initiate presentation flows using pre-PID wallet capabilities in a way that accesses services or provides identity claims that the Wallet User has not been verified to make.*
- *In practice, the Wallet Unit maintains a clear distinction between attestations that are independent of PID (e.g., loyalty cards, transport tickets) and those that depend on PID binding (e.g., age verification derived from PID, EAAs requiring identity confirmation). The dependency relationship is determined at attestation issuance: attestations issued conditional on PID binding cannot be presented when the Wallet Unit's PID binding state is absent.*
- *A CAB verifies this requirement by reviewing the design of the operational state and confirming that a Wallet Unit without PID refuses to present attestations whose issuance requires PID binding and does not allow the relying party interaction to proceed to the presentation of PID-dependent credentials. Where feasible, the CAB may also deploy a Wallet Unit in the operational state without PID and attempt such a presentation to confirm it is refused.*

7.2 Preparedness for PID Issuance

OPS-7.2-01: The Wallet Provider shall ensure that the Wallet Unit generates and securely stores within the WSCD all key material required for PID issuance before initiating a PID issuance request with a PID Provider.

Guidelines

- *Before a PID issuance request is sent to a PID Provider, the Wallet Unit has already generated and stored, inside the secure cryptographic hardware, all key material the issuance will need.*
- *If key material were generated only after the issuance request, the Wallet Unit might receive a PID it cannot bind to a hardware-protected key, or bind it to a key generated outside the secure hardware and therefore extractable.*
- *The binding key pair is created within the secure cryptographic device so that its private half cannot leave the hardware, and the issuance request carries proof of possession of the corresponding public key.*
- *A CAB verifies this requirement by inspecting the issuance flow and confirming that the binding key material exists in the secure cryptographic device before the issuance request is sent.*

OPS-7.2-02: The Wallet Provider shall ensure that the Wallet Unit presents the Wallet User with a clear description of the PID issuance process and obtains the Wallet User's explicit consent before initiating a PID issuance request with a PID Provider.

Guidelines

- *Before initiating PID issuance, the Wallet Unit shows the Wallet User a clear description of what the process entails and obtains explicit consent to proceed.*
- *Without a clear description and explicit consent, a Wallet User could be led into issuing a PID — a step that establishes a strong identity credential — without understanding what is happening, or an application could initiate issuance on the Wallet User's behalf without their agreement.*

- *The description covers what a PID is, which party issues it, and what it will be used for; consent is a deliberate action by the Wallet User rather than a pre-ticked default.*
- *A CAB verifies this requirement by reviewing the documented PID issuance flow and confirming that a description is shown and that issuance does not proceed until the Wallet User has given explicit consent. Where feasible, the CAB may also run the PID issuance flow to confirm the description is shown and consent is required.*

8 Lifecycle Event: PID Storage and Transition to Valid State

8.1 PID Issuance request

PID-8.1-01: The Wallet Unit shall obtain the registration certificate of a PID Provider exclusively from the credential issuer metadata published by that PID Provider, as profiled in [5].

Guidelines

- *The registration certificate states the registered identity of the PID Provider and the attributes it is registered to issue. Taking it from the credential issuer metadata means the Wallet Unit reads it from the same authenticated source it uses to discover the issuance endpoints.*
- *Where a Wallet Unit is permitted to fall back to an online query against a registration service when the metadata carries no registration certificate, an attacker who suppresses the certificate in the metadata can steer the Wallet Unit towards a substituted or unreachable service and so obtain an issuance flow whose registration was never actually checked or deny the Wallet User the possibility to obtain a PID.*
- *The credential issuer metadata is retrieved over an authenticated channel and the registration certificate it carries is validated before any issuance request is composed. No alternative retrieval path is implemented.*
- *A CAB verifies this requirement by reviewing the provider verification logic of the Wallet Unit and confirming that no alternative retrieval is attempted when the registration certificate is absent from the credential issuer metadata. Where feasible, the CAB may also present the Wallet Unit with credential issuer metadata from which the registration certificate has been removed and confirm that no alternative retrieval is attempted.*

PID-8.1-02: The Wallet Unit shall verify, prior to submitting a PID issuance request, that the registration certificate and the access certificate of the PID Provider contain the same unique identifier for that PID Provider.

Guidelines

- *Two independent certificates are involved in an issuance: the access certificate, which authenticates the channel to the provider, and the registration certificate, which evidences the provider's registration. The check establishes that both describe the same legal entity.*
- *Without the check, an attacker who holds a valid access certificate of their own can present the registration certificate of an unrelated, legitimately registered provider. The Wallet Unit then treats the attacker as a registered PID Provider and submits an issuance request, together with the identity evidence it carries, to a party that is not registered to receive it.*
- *The comparison is made on the unique identifier of the provider, not on the trade name, since several providers can share a trade name while identifiers are unique. The verification is performed after both certificates have been validated against their trust anchors.*
- *A CAB verifies this requirement by reviewing the comparison logic and confirming that a mismatched pair of certificates is detected. Where feasible, the CAB may also*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

present the Wallet Unit with a matched and a deliberately mismatched pair of certificates and confirm that the mismatch is detected in the second case.

PID-8.1-03: The Wallet Unit shall not submit a PID issuance request where the verification specified in **PID-8.1-02** does not confirm that both certificates contain the same unique identifier.

Guidelines

- *Detection alone is not sufficient: the flow stops before any request leaves the Wallet Unit, so that no identity evidence reaches a provider whose registration has not been established.*
- *Where a mismatch produces only a warning that the Wallet User can dismiss, an attacker relies on the Wallet User accepting the warning under time pressure and the request is submitted regardless, which defeats the purpose of the comparison.*
- *A conformant implementation treats the mismatch as a terminal condition of the issuance flow rather than as a Wallet User decision. The Wallet User is informed as specified in* **PID-8.1-04**.
- *A CAB verifies this requirement by reviewing the issuance logic and confirming that no issuance request is transmitted when a mismatched pair of certificates is present. Where feasible, the CAB may also present the Wallet Unit with a mismatched pair of certificates and confirm, by observing the network traffic, that no issuance request is transmitted.*

PID-8.1-04: The Wallet Unit shall inform the Wallet User where verification of the PID Provider's registration certificate does not confirm that the PID Provider is registered and explain the danger to the Wallet User.

Guidelines

- *The Wallet User is told that the provider could not be confirmed as registered, in language that identifies the party involved and the consequence, rather than through a generic technical failure message.*
- *Where the flow simply terminates without explanation, the Wallet User attributes the failure to a defect and retries, potentially through a different route offered by the same attacker, instead of recognising that the provider itself could not be confirmed.*
- *The notification names the provider as it appears in the certificate presented, states that its registration could not be confirmed, and does not offer a continuation path for the issuance.*
- *A CAB verifies this requirement by reviewing the documented handling of a failed registration verification and the message it presents to the Wallet User. Where feasible, the CAB may also trigger a failed registration verification on a test Wallet Unit and inspect the message presented to the Wallet User.*

8.2 Binding Wallet Unit to Wallet User Identity Verification

PID-8.2-01: The Wallet Provider shall ensure that the Wallet Unit accepts PID only after the PID Provider has confirmed, through identity proofing at Level of Assurance High as specified in [2], that the Wallet User is the natural person to whom the PID data uniquely and unambiguously corresponds.

Guidelines

- *Identity proofing at LoA High is performed by the PID Provider and is out of scope of this specification. However, PID is not accepted into the Wallet Unit unless the Wallet Provider has received reliable confirmation from the PID Provider that identity proofing*

at LoA High was completed successfully for the Wallet User of that specific Wallet Unit. This can be by process design instead of transaction based.

- *A conformant implementation might achieve this by verifying that the PID credential contains a confirmation claim, signed by the PID Provider, asserting that LoA High identity proofing was completed, and that this claim is cryptographically bound to the Wallet Unit receiving the PID. Or it can be part of the process design where the PID Provider guarantees to the Wallet Provider that no PID will be shared that does not comply to correct ID proofing level.*
- *This requirement is intended to prevent a scenario in which an attacker activates a Wallet Unit and then succeeds in binding the PID of a different real person to it, whether through social engineering of the PID Provider, relay attacks, or exploitation of weaknesses in the identity proofing flow.*
- *A CAB verifies compliance by reviewing the Wallet Provider's documented procedure for accepting PID and confirming that PID is not accepted when the LoA High confirmation is absent or cryptographically invalid. Where feasible, the CAB may also test whether the Wallet Unit accepts PID when the LoA High confirmation is absent or cryptographically invalid.*

PID-8.2-02: The Wallet Provider shall ensure that the identity proofing result presented by the PID Provider refers unambiguously to the same Wallet User session and Wallet Unit that initiated the PID issuance request, such that the result of identity proofing performed for one Wallet User cannot be redirected to a different Wallet Unit.

Guidelines

- *This requirement addresses the risk that an attacker intercepts or replays an identity proofing result that was originally performed for a different Wallet User, binding it to their own Wallet Unit.*
- *A conformant implementation cryptographically binds the identity verification session to the specific Wallet Unit through a mechanism such as a challenge-response protocol or by including the Wallet Unit's public key in the identity proofing session, ensuring that the resulting PID can only be issued to the Wallet Unit that was present during the proofing.*
- *The binding mechanism ensures that even if the identity proofing result is intercepted in transit, it cannot be used to issue PID to any Wallet Unit other than the one that participated in the session.*
- *A CAB verifies this requirement by reviewing the technical design of the PID issuance flow and confirming that a valid identity proofing result cannot be redirected to a different Wallet Unit. Where feasible, the CAB may also attempt, in a test environment, to redirect a valid identity proofing result to a different Wallet Unit and confirm that this fails.*

PID-8.2-03: The Wallet Provider shall implement controls to detect and interrupt PID issuance flows that exhibit patterns inconsistent with legitimate first-time or renewal issuance for a single Wallet Unit, including repeated rapid issuance attempts and concurrent issuance sessions for the same Wallet Unit.

Guidelines

- *Anti-fraud controls on the PID issuance flow are a Wallet Provider-side safeguard that complements the identity proofing performed by the PID Provider. Even when a PID Provider implements LoA High proofing, automated or coordinated fraud attempts may exploit weaknesses in the overall issuance process. Rate limiting and pattern detection at the Wallet Provider layer add a defence-in-depth barrier against such exploitation.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *Automated or coordinated fraud attempts may exploit weaknesses in the overall issuance process even when a PID Provider implements LoA High proofing — for example, by submitting the same forged identity document against multiple Wallet Units in rapid succession, or by running concurrent issuance sessions to increase the probability of a fraudulent verification succeeding.*
- *Implementation involves defining a per-Wallet-Unit rate limit for PID issuance attempts within a rolling time window, and detecting concurrent or overlapping issuance sessions for the same Wallet Unit identity. The specific thresholds are documented in the Wallet Provider's security policy and calibrated to the expected legitimate issuance frequency. Anomalous issuance events trigger interruption of further attempts and notification to the Wallet Provider's monitoring infrastructure.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented rate-limiting and anomaly detection policy for PID issuance and confirming that the Wallet Provider has a documented process for responding to detected anomalous issuance patterns. Where feasible, the CAB may also test the issuance flow with rapid repeated attempts on a single Wallet Unit to confirm that the rate limit is enforced and further attempts are interrupted.*

PID-8.2-04: The Wallet Provider shall ensure that PID binding is initiated only upon verified and cryptographically confirmed successful completion of the required identity verification steps, and that any PID issuance session associated with a failed, interrupted, or unverifiable identity verification result is rejected and cancelled prior to PID storage.

Guidelines

- *Successful completion of the required identity verification steps is confirmed when the Wallet Provider receives and validates a session-bound cryptographic assertion from the identity verification service, linking the specific verification outcome to the in-progress PID issuance request. The PID binding step is triggered only after this assertion has been validated; a missing, expired, or invalid assertion prevents the binding from proceeding.*
- *A scenario this requirement addresses is one in which an attacker replays a verification assertion from a legitimate session conducted by a different Wallet User, or intercepts and modifies the verification result in transit between the identity verification service and the Wallet Provider. Without a binding between the assertion and the specific issuance session, there is no means to detect such substitution, and a PID credential could be issued to a Wallet Unit whose holder has not completed the required verification.*
- *The session binding is typically implemented by including a nonce or a transaction identifier, generated at the start of the PID issuance request, within the signed verification assertion. The Wallet Provider checks that the nonce in the assertion matches the one issued for the current session before proceeding. The verification controls established for the identity proofing mechanism are complementary to the binding check described here.*
- *A CAB verifies this requirement by reviewing the PID issuance protocol specification and confirming that the protocol includes a step in which the Wallet Provider validates a session-bound assertion before initiating binding. Where feasible, the CAB may also test the scenario in which the identity verification service returns an error or no response and confirm that no PID credential is bound to the Wallet Unit in this case.*

PID-8.2-05: The Wallet Provider shall ensure that the Wallet Unit does not simultaneously store more than one active PID credential purporting to identify the same natural person, and shall require the Wallet User to remove any existing active PID credential issued by a different PID Provider before a new PID credential from that different PID Provider can be accepted and stored.

Guidelines

- *An EUDIW solution may, in principle, hold PID credentials issued by different PID Providers across different Member States, each representing the same natural person under that Member State's national identity schema. Holding more than one active PID simultaneously, where each purports to be the holder's primary identity, creates a condition under which conflicting or inconsistent identity attributes could be presented to different relying parties, undermining the integrity of the identity assurance provided by each credential.*
- *Without this control, an actor could attempt to hold two PID credentials that do not represent consistent identity data — for example, by using one Member State's PID for transactions in one jurisdiction and a different Member State's PID, with inconsistent identity attributes, for transactions in another. The inconsistency could arise from genuine cross-border differences in national identity data schemas or from deliberate exploitation of those differences to maintain distinct identity presentations in different contexts.*
- *A PID credential is considered active for the purposes of this requirement when it has been accepted and stored in the Wallet Unit following the full issuance process and its validity period has not expired. The comparison of PID credentials to determine whether they purport to identify the same natural person is based on the set of mandatory identity attributes present in both credentials. Where the applicable trust framework explicitly permits holding two PID credentials from different Member States simultaneously as part of a recognised cross-border identity schema, this requirement does not apply to that specific combination.*
- *A CAB verifies this requirement by reviewing the documented issuance procedure and status handling and confirming that, when a Wallet Unit already holds an active PID credential, a second PID from a different PID Provider is handled by either (i) prompting the Wallet User to remove the existing PID before the new one can be accepted, or (ii) rejecting the second PID credential if the first is still present, and that the second PID is accepted once the first has been removed. Where feasible, the CAB may also test this scenario on a Wallet Unit that already holds an active PID credential.*

8.3 Secure PID Reception Process

PID-8.3-01: The Wallet Unit shall verify, prior to accepting a PID credential, that the signing certificate of the PID Provider that issued the credential traces to a trust anchor published by the European Commission in the list of trusted entities applicable to PID Providers.

Guidelines

- *The EUDIW Trusted List is the authoritative source for identifying legitimate PID Providers. A PID credential from an entity that is not listed as an authorised PID Provider in the applicable trusted list at the time of issuance is rejected without being accepted or stored.*
- *Verification of the PID Provider’s identity includes validation of the certificate chain of the PID Provider’s signing key against the trust anchor published in the trusted list. A certificate that is expired, revoked, or not traceable to a recognised trust anchor results in rejection of the PID.*

- *This requirement prevents a scenario in which a rogue issuer generates a PID credential for a fake or non-existent identity and presents it to the Wallet Unit as a legitimate PID. By verifying the issuer against the trusted list before acceptance, the Wallet Unit ensures that only authorised PID Providers can bind PID to it.*
- *A CAB verifies this requirement by reviewing the credential validation logic and confirming that a PID credential signed by a key not registered in the trusted list is rejected without being accepted or stored. Where feasible, the CAB may also present such a credential to the Wallet Unit and confirm that it is rejected without being accepted or stored.*

PID-8.3-02: The Wallet Unit shall reject a PID credential whose signing certificate traces to a trust anchor other than a trust anchor published by the European Commission in the list of trusted entities applicable to PID Providers, established in accordance with [12].

Guidelines

- *The set of acceptable trust anchors is closed: the Wallet Unit accepts the trust anchors published for PID Providers and no others, including anchors that were valid previously or that reach the Wallet Unit by another route.*
- *Where the Wallet Unit accepts any trust anchor it happens to hold, an attacker who succeeds in installing an additional anchor — through a manipulated configuration profile, a compromised update, or a locally installed certificate — can issue credentials that the Wallet Unit accepts as genuine PID.*
- *A conformant implementation validates the certification path of the credential against the current set of anchors distributed for this purpose and treats any other anchor as untrusted. The provenance of that set is specified in* **PID-8.3-01***.*
- *A CAB verifies this requirement by reviewing the trust anchor validation logic and confirming that a credential signed under an anchor not sourced from the trusted list is rejected. Where feasible, the CAB may also install an additional trust anchor on a test device, present a credential signed under that anchor, and confirm that the Wallet Unit rejects the credential.*

PID-8.3-03: The Wallet Provider shall ensure that, for each PID issuance, the Wallet Unit generates a dedicated asymmetric key pair (the PID binding key pair) within the Wallet Secure Cryptographic Device (WSCD), and that the PID issuance request submitted to the PID Provider includes a cryptographic proof of possession of the PID binding private key together with a Key Attestation from the Wallet Provider confirming that the PID binding private key is generated, stored within, and non-extractable from the WSCD.

Guidelines

- *The PID binding key pair is distinct from the Wallet Unit Attestation (WUA) key pair and all other key material in the Wallet Unit. It is generated specifically for binding a single PID credential and differs across multiple PID credentials held by the same Wallet Unit.*
- *The proof of possession is a cryptographic signature over a nonce provided by the PID Provider (as specified in OpenID4VCI), created using the PID binding private key. It demonstrates to the PID Provider that the requestor controls the private key to which the PID credential will be bound.*
- *The Key Attestation is a JWT issued and signed by the Wallet Provider attesting that the PID binding private key was generated within a certified WSCD and cannot be extracted. The PID Provider relies on this attestation to verify that the key meets the security requirements applicable to PID storage at Level of Assurance High.*

- *A CAB verifies this requirement by reviewing the technical specification of the PID issuance flow and confirming the presence of proof of possession and Key Attestation in the issuance request.*

PID-8.3-04: The Wallet Provider shall ensure that the PID Provider binds the issued PID credential to the PID binding public key, such that the credential can only be presented by the Wallet Unit holding the corresponding PID binding private key.

Guidelines

- *Binding the PID credential to the PID binding public key means that the credential contains a confirmation claim (or equivalent mechanism depending on the credential format) that encodes the PID binding public key. A Verifier receiving a PID presentation is thereby able to require proof of possession of the corresponding private key, confirming that the presenter is the Wallet Unit to which the PID was issued.*
- *Without binding the credential to a key held by the Wallet Unit, a PID intercepted or copied in transit could be presented by a party other than the Wallet User, since nothing would tie possession of the credential to possession of the corresponding private key.*
- *For SD-JWT VC format, binding is achieved through the cnf (confirmation) claim in the JWT payload. For ISO/IEC 18013-5 (mdoc) format, the device key embedded in the Mobile Security Object (MSO) fulfills this role. The functional requirement applies regardless of credential format.*
- *A CAB verifies this requirement by reviewing the presentation validation logic and confirming that a PID credential cannot be presented from a Wallet Unit that does not hold the PID binding private key corresponding to the public key in the credential.*

PID-8.3-05: The Wallet Provider shall ensure that, upon any PID issuance or re-issuance, the Wallet Unit generates a PID binding key pair that is unique to that issuance event and has not been used as the PID binding key pair for any other PID credential issued to the same Wallet Unit, so that the compromise of one PID binding private key does not affect the security of any other PID credential.

Guidelines

- *Key pair uniqueness per issuance ensures security isolation between individual PID credentials. If a PID binding private key is compromised, the impact is limited to the single PID credential bound to that key and does not affect other PID credentials held by the same Wallet Unit (potentially at other moments in time).*
- *If a single binding key pair were reused across successive PID issuances, compromise or extraction of that one key would expose every credential bound to it, and successive credentials would be cryptographically linkable to one another.*
- *In the case of PID re-issuance (for example, upon expiry of an existing PID credential or at the Wallet User's request), the issuance flow triggers the generation of a fresh PID binding key pair within the WSCD before submitting the issuance request. Reuse of a PID binding key pair from a previously issued credential is not permitted, even if that key is still technically valid.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's technical specification and confirming that it mandates fresh key generation for every PID issuance event. Where feasible, the CAB may also initiate two successive PID issuances for the same Wallet Unit and compare the PID binding public keys included in the respective proof of possession claims, expecting the two public keys to be different.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

PID-8.3-06: The Wallet Unit shall verify the cryptographic integrity and authenticity of a received PID credential before storing it, including verification of the PID Provider's digital signature over the credential, the credential's validity period, and conformance of the credential format with the applicable technical specification.

Guidelines

- *For SD-JWT VC format credentials, integrity and authenticity verification includes verification of the issuer's digital signature over the payload. For ISO/IEC 18013-5 (mdoc) format credentials, this includes verification of the Mobile Security Object (MSO) signed by the PID Provider. A credential with an invalid, missing, or unverifiable signature is rejected.*
- *Validity period verification requires that the credential's notBefore date is in the past and the notAfter date (if present) is in the future at the time of storage. A credential that is not yet valid or has already expired is rejected.*
- *This requirement complements* **PID-8.2-01***: even when a PID credential is received from a listed PID Provider, the Wallet Unit independently verifies that the specific credential has not been tampered with or forged after issuance by that provider.*
- *A CAB verifies this requirement by reviewing the credential validation logic and confirming that a PID credential with a tampered payload that invalidates the issuer signature is detected and rejected without being stored. Where feasible, the CAB may also present such a tampered credential and confirm that the Wallet Unit detects the invalid signature and rejects the credential without storing it.*

PID-8.3-07: The Wallet Provider shall ensure that the delivery of a PID credential from the PID Provider to the Wallet Unit takes place in conformance with the requirements specified in ETSI TS 119 472-3 [5], applying any additional protective measures required to prevent observation, modification, or interception of the credential payload by parties intermediating the communication path.

Guidelines

- *ETSI TS 119 472-3 [5] profiles the OpenID4VCI issuance protocol for the EUDIW ecosystem, building on the OpenID4VC High Assurance Interoperability Profile (HAIP). For the Wallet Instance, the key obligations include sending the Wallet Instance Attestation (WIA) at the authorisation and token endpoints to authenticate the wallet application, sending the Wallet Unit Attestation (WUA) with proof of possession of the binding private key at the credential endpoint, and supporting the authorisation code flow. Transport security and mutual authentication are inherent in the protocol as profiled: the PID Provider authenticates to the Wallet Instance through its access certificate included in the signed Issuer Metadata, and the Wallet Instance authenticates to the PID Provider through the WIA and WUA.*
- *In a scenario where the PID issuance protocol is not correctly implemented — for instance, where the Wallet Instance does not verify the PID Provider's access certificate in the signed Issuer Metadata, or where the Wallet Instance does not provide a valid WUA at the credential endpoint — an attacker positioned in the communication path can deliver fabricated credentials, or redirect a legitimate PID credential to a different Wallet Unit. An attacker positioned on the network path between the PID Provider and the Wallet Unit -- through a compromised carrier gateway, a malicious WiFi access point, or a misconfigured corporate proxy -- can observe the PID credential as it is delivered, modify it in transit before it reaches the Wallet Unit's integrity verification step, or inject a substituted credential. Even if the Wallet Unit later detects integrity violation, the original credential's contents have already been exposed. ETSI TS 119 472-3 [5] is designed to close these attack*

surfaces within the EUDIW ecosystem by requiring authenticated exchanges and channel-security at each step of the issuance flow.

- *ETSI TS 119 472-3 [5] builds on OpenID4VCI via the HAIP protocol. The wallet-side obligations are anchored in GEN-REQ-4.1-01 of ETSI TS 119 472-3 [5], which requires the EUDI Wallet to implement the protocol requirements defined for the Wallet in OpenID4VC-HAIP, clause 3.5 and its subclauses, unless specified otherwise in ETSI TS 119 472-3 [5] itself. Conformance testing of implementations is available through the OpenID Foundation self-certification programme, which opened in February 2026 for OpenID4VP 1.0, OpenID4VCI 1.0, and HAIP 1.0.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's technical documentation to confirm that the PID issuance protocol implemented by the Wallet Instance conforms to the requirements defined for the Wallet in ETSI TS 119 472-3 [5]. The CAB verifies that the solution passed the OpenID Foundation self-certification positively. The CAB additionally examines functional test results for the issuance flow, covering the authorisation code flow and, where applicable, the pre-authorised code flow, and confirms correct handling of the WIA, WUA, and access certificate verification steps specified in ETSI TS 119 472-3 [5].*

PID-8.3-08: The Wallet Provider shall ensure that, before the Wallet Unit signs the proof of possession that binds a PID credential to the Wallet Unit, the Wallet User has successfully authenticated to the Wallet Unit using the authentication mechanism established during Wallet Unit activation.

Guidelines

- *The proof of possession is the cryptographic signature produced by the Wallet Unit using the PID binding private key, demonstrating to the PID Provider that the Wallet Unit holds the key to which the credential is being bound. This signing operation is a Wallet Unit operation involving a critical asset and therefore requires Wallet User authentication. The authentication uses the same authentication mechanism the Wallet User established during Wallet Unit activation; no separate authentication is set up for the binding step.*
- *Without this control, an attacker who momentarily controls the Wallet Unit could obtain the binding signature without the legitimate Wallet User authenticating. The resulting credential is then bound to a Wallet Unit that is, at the moment of binding, under attacker control, even if the Wallet User subsequently uses the credential normally.*
- *Acceptable approaches include integration of the binding-step authentication into the issuance flow such that the Wallet User cannot proceed past the binding event without active authentication, and use of a fresh challenge for the binding signature so the authentication artefact is not replayable.*
- *A CAB verifies this requirement by reviewing the issuance flow documentation and confirming that the Wallet Unit signing event for the proof of possession is gated by Wallet User authentication. Where feasible, the CAB may also attempt on a test Wallet Unit to trigger PID binding from a state in which no recent authentication has occurred and confirm that the binding does not proceed without prompting the Wallet User to authenticate.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

8.4 PID Storage and Protection

PID-8.4-01: The Wallet Provider shall ensure that the PID binding private key associated with each issued PID credential is generated within the WSCD of the Wallet Unit, stored exclusively within that WSCD, and protected from extraction in plaintext form throughout the lifecycle of that PID credential.

Guidelines

- *The PID binding private key provides cryptographic proof of possession of the PID credential. If this key can be extracted from the device, an attacker could clone the credential and present it from a different device, undermining the device-binding guarantee of the EUDIW. Generating and retaining the private key exclusively within the WSCD ensures that possession of the PID credential cannot be separated from physical possession of the Wallet Unit.*
- *This requirement applies specifically to the PID binding private key — the private component of the asymmetric key pair used to sign presentations of the PID credential. The WSCD's role in this context is to protect the key material that cryptographically binds the credential to the device.*
- *The requirement that the key is generated within the WSCD ensures that the private key material was never present in application-layer code or accessible memory in plaintext form. A private key generated outside the WSCD and subsequently imported does not satisfy this requirement, even if the imported key is marked as non-extractable after import.*
- *A CAB verifies this requirement by reviewing the technical architecture documentation for the Wallet Unit, confirming that PID binding key pairs are generated using the WSCD's internal key generation functionality, and confirming that the WSCD enforces non-extractability of private key material through its access control and export policy mechanisms.*

PID-8.4-02: The Wallet Provider shall ensure that all personal data stored by the Wallet Instance, including Person Identification Data, Electronic Attestations of Attributes, transaction log entries, and any other personal data of the Wallet User, is encrypted at rest using a cryptographic key whose use is authorized only after successful Wallet User authentication via the authentication mechanism established during Wallet Unit activation.

Guidelines

- *Personal data stored by the Wallet Instance -- including the issued PID claims, validity period, issuer signature, and any selective-disclosure proof material -- is held in application-layer storage of the Wallet Instance. Encryption at rest means that a copy of this storage taken at any moment outside an active authenticated session yields ciphertext that cannot be decrypted without the Wallet User's authentication factor. The decryption key is released by the WSCA only on successful authentication for the operation that requires the data. The decryption key is released by the WSCA only on successful authentication for the operation that requires the data.*
- *Without this control, an attacker who obtains a forensic copy of the device storage -- for example, by exploiting an unattended unlocked device, by extracting application data through a backup mechanism, or by recovering data from a discarded device -- could read the PID credential payload directly from disk without ever authenticating, exposing the holder's identity attributes and credential to use against the holder's interests.*
- *Acceptable approaches include encryption of the Wallet Instance's PID credential storage with a data-encryption key derived from material held in the WSCD that is released only after WSCA-verified Wallet User authentication or use of operating-*

system file-level encryption tied to the Wallet User's authenticated session combined with WSCA-verified authentication for any read access. Cross-reference: **PID-8.3-01** *covers the protection of the PID binding private key, which is a separate cryptographic asset from the credential data addressed by this requirement.*

- *A CAB verifies this requirement by reviewing the Wallet Instance's storage layout and the key-derivation or key-release path, confirming that PID credential data on disk is ciphertext and that the path requires Wallet User authentication. Where feasible, the CAB may also inspect the storage in a controlled environment and attempt to read the PID credential from the device's file system without supplying Wallet User authentication, confirming that no readable PID payload is recoverable.*

PID-8.4-03: The Wallet Provider shall ensure that the Wallet Unit requires successful Wallet User authentication before presenting any PID credential to a relying party, using the authentication mechanism established during Wallet Unit activation at the assurance level applicable to the Wallet Unit.

Guidelines

- *This requirement addresses the scenario in which an attacker who physically acquires the Wallet User's device attempts to present the PID to a relying party without the Wallet User's knowledge or consent. By requiring a fresh authentication event prior to each presentation, the Wallet Unit ensures that PID credentials can only be used by the legitimate holder who controls the authentication factors.*
- *Authentication for PID presentation is performed using the authentication mechanism established at Wallet Unit activation. The authentication event is specific to the presentation session; authentication performed for another purpose (such as unlocking the device operating system) does not satisfy this requirement unless the Wallet Unit explicitly re-invokes Wallet User authentication as part of the presentation flow.*
- *The requirement applies regardless of the relying party context or the nature of the PID attributes requested. There is no exception that permits PID presentation without prior Wallet User authentication.*
- *A CAB verifies this requirement by reviewing the documented presentation flow and confirming that a PID presentation cannot complete without Wallet User authentication on the Wallet Unit and that a session established for device unlock alone does not bypass this gate. Where feasible, the CAB may also attempt to initiate a PID presentation without first completing Wallet User authentication and confirm that the Wallet Unit refuses to complete the presentation.*

PID-8.4-04: The Wallet Provider shall ensure that the Wallet Unit requires successful Wallet User authentication, using the authentication mechanism established during Wallet Unit activation, before rendering any value of a Person Identification Data attribute in its Wallet User interface.

Guidelines

- *Wallet User-interface rendering includes the wallet's main credential view, any details or settings view exposing PID or attribute claims, and any preview of credential data shown during a presentation flow. Authentication for the operation that triggers display is the same authentication required for any operation involving the credential. The requirement applies whether the rendered value is a single attribute or the full credential payload.*
- *Without this control, anyone in physical possession of an unlocked device can open the wallet app and read the holder's PID attributes -- name, date of birth, document numbers, address -- without ever satisfying any authentication factor. The Wallet*

Unit's other authentication gates, including those before relying-party presentation, do not protect against this passive disclosure path.

- *Acceptable approaches include locking the credential view behind a fresh authentication challenge on every entry, redacting credential values until the Wallet User authenticates within the view, and applying a session timeout shorter than the operating-system device-lock timeout for credential-display authentication. Cross-reference:* **PID-8.3-03** *establishes the same obligation for presentation to relying parties; this requirement extends the principle to in-app display.*
- *A CAB verifies this requirement by reviewing the documented PID credential view behaviour and confirming that credential values are not rendered until the Wallet User supplies the wallet authentication factor, even after operating-system unlock without prior wallet authentication. Where feasible, the CAB may also open the Wallet Unit on a test device after operating-system unlock, navigate to the PID credential view, and confirm that the values are not rendered until the wallet authentication factor is supplied.*

8.5 Wallet User Activation of PID

PID-8.5-01: The Wallet Provider shall ensure that the PID activation process verifies, through the authentication mechanism established during Wallet Unit Activation, that the Wallet User completing the activation is the same individual who initiated PID issuance, before the Wallet Unit transitions to a state in which PID presentation is permitted.

Guidelines

- *The activation step is the final transition that makes a received PID available for presentation to relying parties. The authentication mechanism referenced is the Wallet User authentication method established during Wallet Unit Activation — for example, a device PIN or biometric — which is bound to the Wallet Unit and has the assurance level required for PID operations. The activation verification ensures that the Wallet Unit is in the possession of the Wallet User whose identity was verified during PID binding at the time of activation.*
- *In a scenario where the PID activation step does not verify the identity of the activating Wallet User, an individual who gains temporary access to a device that contains a received but not yet activated PID — for example, through device theft between PID delivery and activation — can complete the activation and gain use of another person's PID credential for presentation to relying parties. The risk increases in scenarios where PID delivery and activation occur as separate sessions, with a temporal gap during which the device could be accessed by a third party.*
- *Verification of the activating Wallet User is typically implemented by requiring a fresh authentication against the Wallet Unit's authentication mechanism as part of the activation flow — for example, a biometric verification or PIN entry. A fresh authentication is performed even if the Wallet User was recently authenticated for another purpose. The Wallet Unit records the authentication event and the timestamp of activation. Where the activation step occurs as part of a single uninterrupted session that began with Wallet User authentication, a session-continuation model can be used, provided the authentication assurance is maintained throughout.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's technical documentation of the activation flow and confirming that it requires a fresh authentication event bound to the Wallet Unit's established authentication mechanism and that no alternative pathway to activation exists. Where feasible, the CAB may also attempt to activate a PID on a test Wallet Unit while bypassing or substituting the*

Wallet User authentication step - for example, by replaying an authentication token - and confirm that the activation is refused.

PID-8.5-02: The Wallet Provider shall ensure that the Wallet Unit requires the Wallet User's explicit confirmation before marking a received PID credential as active and available for presentation to relying parties.

Guidelines

- *A received PID becomes usable for presentation only after the Wallet User has explicitly confirmed it; until then the Wallet Unit holds the PID but does not offer it to relying parties.*
- *Without an explicit activation step, a PID delivered to the Wallet Unit — including one issued through a flow the Wallet User did not fully intend — could immediately be presented, giving effect to an issuance the Wallet User had not consciously accepted.*
- *The confirmation is a deliberate action distinct from receipt of the credential; the Wallet Unit marks the PID active and available only once that action has been taken.*
- *A CAB verifies this requirement by reviewing the documented activation behaviour and confirming that a delivered PID cannot be presented until the Wallet User has explicitly confirmed activation. Where feasible, the CAB may also deliver a test PID to a Wallet Unit and confirm that it cannot be presented until the Wallet User has explicitly confirmed activation.*

9 Lifecycle Event: Wallet Unit Management and Maintenance

9.1 Software Updates and Patches

MAINT-9.1-01: The Wallet Provider shall apply the same documented change-control, code-signing, and distribution-channel controls to every Wallet Instance software update as those required for initial deployment, such that no update bypasses or relaxes the controls established for the original software release.

Guidelines

- *Update parity means that approval workflows, signing-key custody, supply-chain checks, and operator-action logging that govern the first release also govern every subsequent update -- including emergency hotfixes. The same accredited ISMS scope continues to apply during the maintenance phase.*
- *Without this control, attackers and insiders may target the less-scrutinised update process to push a compromised binary, knowing that initial-release controls (multi-person signing, SBOM verification, publisher checks) are routinely waived under time pressure to ship a fix.*
- *Acceptable approaches include treating every update as a release subject to the standard release pipeline, requiring documented exceptions to be authorised at the level that approves initial releases, and exercising the emergency update path during periodic rehearsals to confirm that controls do not silently degrade.*
- *A CAB verifies this requirement by reviewing the update history of the previous 12 months, by sampling change-records to confirm that signing, supply-chain, and operator-logging controls were applied to each, and by interviewing release engineers to confirm no informal expedited path exists outside the documented process.*

MAINT-9.1-02: The Wallet Provider shall ensure that each update to the Wallet Instance is verified, before deployment, to confirm that the update does not remove or reduce the operating system-level isolation mechanisms that protect data stored by the Wallet Instance from access by co-located applications, and shall refuse to apply an update that would reduce the Wallet Instance's isolation capabilities below the level verified during installation.

Guidelines

- *Software updates to the Wallet Instance may introduce changes to the application's storage configuration, permissions model, or inter-process communication interfaces that could inadvertently weaken or remove the isolation that prevents co-located applications from accessing Wallet Instance data. Pre-deployment verification of updates is a precautionary step to confirm that the isolation model remains intact across software versions.*
- *Without this control, an update to the Wallet Instance could modify the application's storage configuration in a way that exposes previously protected data to co-located applications. A malicious application that monitors for such configuration changes could then read PID credentials or other personal data that were previously inaccessible due to OS-enforced sandboxing.*
- *Verification of isolation mechanisms in the updated Wallet Instance can be performed through code review, automated static analysis of the application's manifest and storage declarations, or dynamic testing in a controlled environment. The Wallet Provider's update verification procedure is documented and reproducible. Where a*

third-party penetration test or code audit is used to verify isolation, the audit scope explicitly includes inter-application data isolation.

- *A CAB verifies this requirement by reviewing the Wallet Provider's update verification procedure and confirming that the procedure explicitly includes a check for changes to application storage configuration, permissions, and inter-process communication interfaces. The CAB may additionally apply a test update that introduces an intentional weakening of isolation and confirm that the Wallet Provider's verification process detects and rejects such an update.*

MAINT-9.1-03: [CONDITIONAL] Where the Wallet Provider permits rollback to a previous software version of the Wallet Instance, the Wallet Provider shall ensure that the rollback does not result in the reinstatement of a version with known security vulnerabilities or a reduction of the security baseline established by the version in force before the rollback.

Guidelines

- *Where the Wallet Provider allows the Wallet Instance to be rolled back to an earlier version, that rollback never reinstates a version with known security weaknesses or otherwise lowers the security level that was in force beforehand.*
- *Without this constraint, an attacker able to trigger a downgrade could return the Wallet Instance to a version whose vulnerabilities are publicly known and then exploit them, undoing the protection a security update had provided.*
- *Acceptable approaches include refusing rollback to versions below a defined minimum security baseline, and blocking downgrade to any version superseded for security reasons, while still permitting rollback for functional problems that do not reduce security.*
- *A CAB verifies this requirement by reviewing the documented rollback controls and confirming that rollback to a version with a known vulnerability is refused or constrained to a version that preserves the security baseline. Where feasible, the CAB may also attempt to roll back a test Wallet Instance to a version with a known vulnerability and confirm that the rollback is refused or so constrained.*

MAINT-9.1-04: The Wallet Provider shall notify the Wallet User when an update to the Wallet Instance is available.

Guidelines

- *The Wallet Provider brings an available Wallet Instance update to the Wallet User's attention through the ordinary update channel, so that the Wallet User is aware an update exists.*
- *Without notification, a Wallet User could remain unaware that an update - including one that improves security - is available, and go on running an outdated Wallet Instance longer than necessary.*
- *Notification reaches the Wallet User by the platform's normal update-notification means. Whether an available update has to be installed is a separate matter: a security-remediating update is handled by the following requirement, which can make its installation a precondition for continued use.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's update-notification process and confirming that Wallet Users are informed when an update is available, for instance by examining the notification design and records of past notifications, and, where feasible, by observing a notification on a test device.*

MAINT-9.1-05: [CONDITIONAL] Where an update to the Wallet Instance remediates a security vulnerability or is necessary to maintain the security baseline of the Wallet Unit, the Wallet Provider shall make the installation of that update a precondition for continued use of the Wallet Unit.

Guidelines

- *For an update that closes a security vulnerability or is otherwise needed to keep the Wallet Unit at its required security baseline, the Wallet Provider does not leave installation to the Wallet User's discretion: continued use of the Wallet Unit is made conditional on the update being installed, so the superseded, weaker version cannot go on being used.*
- *If a security-remediating update could be declined indefinitely, a Wallet Unit with a publicly known vulnerability would stay in use and exploitable - the very situation the update exists to end - and an attacker could rely on unpatched Wallet Units remaining in the field.*
- *This requirement concerns only updates that remediate a vulnerability or preserve the security baseline; it works together with the rollback constraint in clause 9.1, which prevents returning to a version below that baseline. Updates that merely change functionality without affecting security are outside its scope, and the Wallet User is still notified that the update is available under the preceding requirement.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's update policy and its classification of security-remediating updates, and confirming that such an update is made a precondition for continued use, for instance by examining the enforcement design and records of a past mandatory update, and, where feasible, by confirming on a test device that the Wallet Unit does not continue to operate on the superseded version once such an update is available.*

9.2 Re-authentication and Session Management

MAINT-9.2-01: The Wallet Provider shall define and enforce a maximum inactivity period after which an authenticated session within the Wallet Unit is automatically invalidated and the Wallet User is required to re-authenticate before any Wallet Unit operation may proceed.

Guidelines

- *An authenticated session in the Wallet Unit is automatically ended after a defined period of inactivity, and the Wallet User authenticates again before any further Wallet Unit operation.*
- *A session that stayed open indefinitely would let anyone who picked up an unattended, unlocked device operate the Wallet Unit — presenting credentials or changing settings — as though they were the Wallet User.*
- *The maximum inactivity period is defined and enforced by the Wallet Provider; on expiry the Wallet Unit clears the authenticated state so that the next operation requires re-authentication.*
- *A CAB verifies this requirement by reviewing the documented session timeout design and confirming that an operation after the defined idle period requires re-authentication. Where feasible, the CAB may also leave a test Wallet Unit idle past the defined period and confirm that a subsequent operation requires re-authentication.*

MAINT-9.2-02: The Wallet Provider shall ensure that the Wallet Unit requires Wallet User re-authentication before performing any sensitive operation, including presentation of credentials to a relying party, modification of enrolled authentication factors, and access to stored PID or attestation data following session expiry.

Guidelines

- *The Wallet Unit requires the Wallet User to authenticate again before any sensitive operation, including presenting credentials, changing enrolled authentication factors, and reaching stored PID or attestation data after a session has expired.*
- *Without re-authentication at these points, an attacker with brief access to an already-open Wallet Unit could present the Wallet User's credentials, lock the Wallet User out by changing the authentication factors, or read the stored identity data.*
- *The Wallet Unit treats the listed operations as sensitive and gates each behind a fresh authentication, rather than relying on a single authentication at the start of a session.*
- *A CAB verifies this requirement by reviewing the documented session handling and confirming that each listed operation on a Wallet Unit with an expired session requires re-authentication before it proceeds. Where feasible, the CAB may also attempt each listed operation on a Wallet Unit with an expired session and confirm that re-authentication is required before it proceeds.*

MAINT-9.2-03: The Wallet Provider shall ensure that the Wallet Unit does not retain PID data or other personal data in unprotected memory or storage beyond the scope of a single presentation transaction, and that any temporary copies of such data created during a transaction are securely erased upon completion or termination of that transaction.

Guidelines

- *Retaining personal data beyond the transaction scope creates a persistent exposure risk: if the device is later compromised or examined without authorisation, cached data could be recovered and disclosed. Secure erasure immediately after each transaction limits the window during which personal data is accessible outside the WSCD.*
- *'Unprotected memory or storage' means any location where personal data is held in decrypted or plaintext form during processing, including RAM buffers, application-layer caches, temporary files, clipboard entries, and screenshot capture surfaces. This is distinct from the primary encrypted credential storage of the Wallet Unit, where PID credentials and personal data are retained in encrypted form.*
- *Secure erasure means overwriting or cryptographically invalidating the memory location used to hold the data, not merely releasing the reference or marking the memory as available for reuse. A conformant implementation uses platform APIs or memory management routines that guarantee the data content is overwritten.*
- *A CAB verifies this requirement by reviewing the Wallet Unit's data handling implementation for presentation flows and confirming that personal data is not retained in application-layer storage after the transaction. The CAB also tests this by inspecting device memory state or application storage after a completed presentation transaction.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

9.3 Key Rotation and Renewal

MAINT-9.3-01: The Wallet Provider shall ensure that all cryptographic key material subject to rotation is generated within the WSCD and remains within the WSCD throughout the key rotation process, and that superseded key material is irrevocably deleted from the WSCD upon successful completion of rotation.

Guidelines

- *Keeping key material within the WSCD throughout the rotation process prevents an attacker who monitors the device or intercepts communications during rotation from obtaining the new or old private key in extractable form. The WSCD's non-extractability property ensures that even if the rotation process is observable, no usable key material can be captured.*
- *Irrevocable deletion of superseded key material ensures that old keys cannot be used after rotation — whether to decrypt captured historical communications, to sign forged credentials, or to perform unauthorised operations using the Wallet Unit. Merely marking a key as inactive or deregistering it from application logic is not sufficient; deletion of the key material itself from the WSCD is required.*
- *The key rotation process will be implemented as a transactional operation: if rotation fails before the new key is fully established, the old key material will remain active and the rotation will be rolled back or retried. Partial rotation states where neither old nor new key material is definitively in control will not persist.*
- *A CAB verifies this requirement by reviewing the key rotation implementation and confirming that key generation occurs within the WSCD, that key material does not pass through application-layer code in plaintext during rotation, and that completion of rotation is confirmed before the superseded key is deleted.*

MAINT-9.3-02: The Wallet Provider shall ensure that key rotation and Wallet Unit software update operations are performed in a manner that preserves the security level of the Wallet Unit throughout the operation, such that no transient or permanent reduction in cryptographic strength occurs, and that any operation that cannot be completed without reducing security is automatically aborted and the Wallet Unit restored to its pre-operation security state.

Guidelines

- *Security level preservation during the operation means that replacement key material is generated within the WSCD and its registration is confirmed before the currently active key material is deactivated. At no point during the operation is the Wallet Unit placed in a state where attestation operations are only possible using key material weaker than the pre-operation baseline, whether measured by algorithm strength, key length, or WSCD certification level.*
- *A scenario this requirement addresses is one in which a key rotation or software update is triggered during an adverse hardware or software condition — such as degraded entropy availability, a partial WSCD failure, or an interrupted firmware update — resulting in weaker key material being installed without the Wallet Provider detecting the degradation. A Wallet Unit operating with weakened cryptographic protection after a rotation is particularly difficult to detect, as the wallet continues to function normally while offering reduced resistance to key extraction attacks.*
- *Atomicity of the operation is typically achieved by completing the full sequence of new key generation, WSCD registration, and attestation update before issuing any deactivation command for the current key. The rollback procedure restores the previous key to active status and removes any partially generated material from the WSCD. A health check confirming that the WSCD is operating within its certified*

parameters is performed before initiating a rotation; if the check fails, the operation is deferred rather than attempted with degraded hardware.

- *A CAB verifies this requirement by reviewing the key rotation and update procedure documentation and confirming that the procedure specifies the conditions under which a rollback is triggered and how the restoration of the pre-operation state is verified. Where feasible, the CAB may also test failure scenarios, such as interrupting the rotation at different stages, and confirm that the Wallet Unit remains fully operational at the original security level after each aborted attempt.*

MAINT-9.3-03: The Wallet Provider shall implement and document procedures for renewing Wallet Instance Attestations and Key Attestations before their expiry date and shall ensure that the expiry of such an attestation does not cause an unplanned interruption to Wallet Unit availability.

Guidelines

- *The Wallet Provider has documented procedures to renew Wallet Instance Attestations and Key Attestations before they expire, so that an expiry never causes an unplanned loss of Wallet Unit availability.*
- *If an attestation were allowed to lapse before renewal, the Wallet Unit could suddenly stop functioning — unable to present credentials or prove its integrity — through nothing the Wallet User did wrong.*
- *Renewal is scheduled ahead of the expiry date and follows the same security process as the original issuance; the procedure is documented so that timing and responsibility are defined rather than left to chance.*
- *A CAB verifies this requirement by reviewing the renewal procedure and its timing and by confirming, on a test Wallet Unit, that an attestation approaching expiry is renewed before availability is affected.*

MAINT-9.3-04: The Wallet Provider shall ensure that renewal of the Wallet Instance Attestation and the Key Attestation and re-issuance of PID credentials and Electronic Attestations of Attributes during the maintenance phase applies the same security controls, cryptographic key generation procedures, and assurance requirements as the initial issuance process for the same credential type, and shall not implement a renewal path that bypasses or reduces any security requirement that applied during initial issuance.

Guidelines

- *Renewal of the WUA follows issuance process of the same strength as the initial WUA issuance during activation, including device attestation and the Wallet Provider's authentication of the WSCD. Re-issuance of a PID credential during maintenance — for example, following key rotation — follows a similar strength identity verification and cryptographic binding process as the initial PID issuance, including any identity proofing required for the applicable credential type. The fact that the Wallet User's identity was established during the previous issuance does not reduce the security requirements applicable to the renewal.*
- *Without this control, a simplified or expedited renewal path could omit critical security steps — for example, renewing a PID credential without repeating the identity proofing at Assurance Level High, or renewing the WUA without repeating device attestation with a certified WSCD. An attacker could exploit a weakened renewal path to obtain a valid credential without meeting the security requirements that apply to fresh issuance.*
- *A compliant renewal process generates a fresh key pair in the WSCD, produces a new proof of possession, and submits the renewal request through a similar strength issuance protocol as the initial request. The Wallet Provider maintains documented*

renewal procedures for each credential type, and each renewal step is mapped to the corresponding step in the initial issuance process. Audit logs from renewals include the same audit evidence as audit logs from initial issuances, enabling a CAB to verify equivalence.

- *A CAB verifies this requirement by reviewing the Wallet Provider's documented renewal procedures for each credential type and confirming that each renewal step is equivalent to the corresponding initial issuance step with no steps omitted or simplified. The CAB may additionally perform a renewal in a test environment, inspect the resulting credential and audit log, and confirm that all required security steps were completed and logged at the same level of evidence as an initial issuance.*

9.4 PID and EAA Lifecycle Management

MAINT-9.4-01: The Wallet Provider shall ensure that, upon expiry of the validity period of a PID credential or Electronic Attestation of Attributes, the Wallet Unit refuses to present the expired credential to any Relying Party.

Guidelines

- *An expired PID credential or Electronic Attestation of Attributes is one whose validity period set by its Provider has passed. Refusing presentation means that the Wallet Unit does not include the expired credential in any presentation candidate set offered to a Relying Party, and rejects any presentation request that would result in transmitting the expired credential, regardless of the Relying Party's stated intent.*
- *Without this control, an expired credential could be presented to a Relying Party that fails to verify the validity period correctly, resulting in identity decisions taken against stale data.*
- *Acceptable approaches include filtering expired credentials out of the presentation candidate set, refusing presentation requests that would target an expired credential, and propagating the expiry status from the credential's metadata to the presentation logic.*
- *A CAB verifies this requirement by reviewing the documented validity-checking behaviour and confirming that the Wallet Unit refuses to present an expired credential to a Relying Party. Where feasible, the CAB may also issue a test credential with a short validity period, advance the system clock past the expiry date, and confirm that the Wallet Unit refuses to present the expired credential to a test Relying Party.*

MAINT-9.4-02: The Wallet Provider shall ensure that, upon revocation of a PID credential or Electronic Attestation of Attributes by its Provider, the Wallet Unit refuses to present the revoked credential to any Relying Party, and shall implement a mechanism to check and maintain awareness of the revocation status of all PID credentials and Electronic Attestations of Attributes stored in the Wallet Unit.

Guidelines

- *A revoked PID credential or Electronic Attestation of Attributes is one that has been explicitly invalidated by its Provider before the end of its validity period — for example, because the subject's identity data changed, the credential was issued in error, the Wallet User requested revocation, or the credential was associated with a compromised Wallet Unit. Unlike expiry, which occurs at a defined point in time, revocation may occur at any moment without advance notice and requires the Wallet Unit to actively check or receive the current status of each credential it holds.*
- *This requirement is distinct from MAINT-8.4-02, which addresses refusal to present expired credentials. An expired credential has passed a known end date; a revoked*

credential has been explicitly invalidated by its Provider and must not be presented even if it has not yet expired. Without active revocation-status checking, the Wallet Unit could present a revoked credential to a Relying Party, potentially enabling claims the Wallet User is no longer authorised to make.

- *Acceptable revocation-checking mechanisms include: regularly polling the Provider's revocation status endpoint or status list; verifying an embedded status token or status assertion in the credential at presentation time; subscribing to Provider-pushed revocation notifications; or any equivalent mechanism that ensures the Wallet Unit's awareness of revocation status is kept current within a defined maximum staleness interval. The specific mechanism is determined by the credential format and the Provider's revocation infrastructure, and is documented in the Wallet Provider's technical implementation.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented revocation-checking architecture and confirming it is appropriate for each credential format and Provider in use and that a revoked credential is detected within the documented maximum staleness interval and no longer presented. Where feasible, the CAB may also revoke a test PID credential or Electronic Attestation of Attributes on the Provider's system while the Wallet Unit holds a valid copy and confirm that the Wallet Unit detects the revocation within that interval and subsequently refuses to present the credential.*

MAINT-9.4-03: The Wallet Provider shall ensure that the Wallet Unit clearly indicates the expired or revoked status of any PID credential or Electronic Attestation of Attributes in any Wallet User interface that displays the credential.

Guidelines

- *Indication of expired or revoked status means an unambiguous visual marker — a label, badge, banner, or equivalent — present on every view of the credential that shows its identity fields or claims. The marker must distinguish between an expired credential (whose validity period has elapsed) and a revoked credential (which has been explicitly invalidated by its Provider), so that the Wallet User understands the reason the credential can no longer be used. The marker must be visible without the Wallet User needing to navigate to a separate details screen.*
- *Without this control, the Wallet User could believe an expired credential is still active and rely on its content for purposes that require currently valid identity, leading to incorrect decisions or misunderstandings about their digital identity status.Without this control, the Wallet User could believe a credential that is expired or revoked is still active and rely on its content for purposes such as identity verification or access, when in fact the credential can no longer be presented. Clear visual indication also supports the Wallet User's ability to initiate renewal or understand the action required in response to revocation.*
- *Acceptable approaches include rendering an 'Expired' or 'Revoked' label or banner across the credential view, applying visual desaturation or greying of the credential card to indicate invalid status, or any combination of these that makes the status immediately visible to the Wallet User. The specific visual treatment must distinguish expired from revoked so that the Wallet User understands the appropriate response.*
- *A CAB verifies this requirement by reviewing the Wallet Unit's user interface design and confirming that expired and revoked states are each clearly indicated to the Wallet User and that the indicators distinguish between expired and revoked status. Where feasible, the CAB may also issue a test credential with a short validity period and separately revoke a test credential and confirm that both states are clearly and distinctly indicated in the Wallet User interface.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

MAINT-9.4-04: The Wallet Provider shall apply, to every renewal or re-issuance of a PID credential or Electronic Attestation of Attributes to the Wallet Unit, the same authentication, identity-proofing, and cryptographic-binding requirements as those required for the initial issuance of that credential type.

Guidelines

- *Renewal occurs when an existing PID or attestation approaches the end of its validity period and is replaced by a fresh issuance from the same Provider. Re-issuance occurs when a credential is reissued for any other reason -- such as a Wallet User request after data correction or after device migration. In both cases the issuance flow runs end-to-end as if it were the first issuance: identity proofing at LoA High where applicable, fresh binding key generation in the WSCD, secure delivery, integrity verification on receipt, and binding-step Wallet User authentication.*
- *Without this control, the Wallet Provider could implement a simplified renewal flow that omits identity proofing -- relying on the existing credential's validity as proof of identity -- or that reuses cryptographic key material from the expiring credential. An attacker who has compromised the Wallet Unit between initial issuance and renewal can then exploit the simplified renewal flow to extend the lifetime of attacker-controlled access, since each step that would have detected the compromise during a fresh issuance has been skipped.*
- *Acceptable approaches include sharing the same issuance pipeline between initial issuance and renewal with no renewal-specific shortcuts, requiring fresh proofing assertions for each renewal of a PID credential, and generating a new PID binding key pair in the WSCD for each renewal so the resulting credential is not cryptographically related to its predecessor. Cross-reference:* **PID-8.5-02** *establishes the LoA High proofing requirement that applies equally to renewal.*
- *A CAB verifies this requirement by reviewing the renewal flow documentation, comparing the implementation steps of renewal and initial issuance to confirm equivalence, and sampling renewal records to confirm that fresh proofing assertions and fresh binding keys are present. Where feasible, the CAB may also attempt on a test Wallet Unit to initiate renewal of an expired PID without supplying fresh proofing and confirm that the renewal is refused.*

MAINT-9.4-05: The Wallet Provider shall ensure that the Wallet Unit provides the Wallet User with the ability to delete individual attestations, and that deletion results in the removal of the credential data from the Wallet Unit.

Guidelines

- *The Wallet Unit lets the Wallet User delete an individual attestation, and deleting it removes the credential data from the Wallet Unit.*
- *Without a reliable delete function, a Wallet User could not remove a credential they no longer want or that was issued in error, and stale credential data would accumulate in the Wallet Unit beyond the Wallet User's control.*
- *Deletion removes the credential data from the Wallet Unit's storage; the withdrawal of any operating-system-level registration of a deleted credential is addressed by the following requirement in this clause.*
- *A CAB verifies this requirement by deleting a test attestation and confirming that its data no longer resides in the Wallet Unit.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

MAINT-9.4-06: The Wallet Provider shall ensure that, upon deletion of a PID credential or an Electronic Attestation of Attributes from the Wallet Unit, every registration of that credential with an operating system interface through which relying parties can request its presentation is removed.

Guidelines

- *Where the operating system offers a shared interface through which any application can request the presentation of a credential held by another application, credentials held by the Wallet Unit are advertised through that interface. Deleting the credential from the Wallet Unit also withdraws that advertisement. A concrete example is the credential-registration facility that mobile operating systems provide for this purpose — such as an Android Identity Credential / Credential Manager entry, or the equivalent facility on other platforms — through which an installed wallet application registers the mdoc or SD-JWT credentials it holds so that another application on the device, or a website using the platform's digital credential presentation mechanism, can request their presentation directly from the operating system without the Wallet Instance's own user interface being opened first.*
- *Without withdrawal, the operating system continues to advertise a credential that no longer exists. A relying party is offered a credential that cannot be presented, and metadata about a credential the Wallet User has deliberately deleted remains visible to any application able to query the interface.*
- *The withdrawal is performed as part of the same operation as the deletion, so that no window exists in which the credential is deleted but still advertised. The deletion capability itself is specified in* **MAINT-9.4-05***.*
- *A CAB verifies this requirement by deleting a credential on a test device and then querying the operating system presentation interface to confirm that the credential is no longer offered.*

9.5 Wallet User Support

MAINT-9.5-01: The Wallet Provider shall ensure that all Wallet User support processes for Wallet Unit-related requests include verification of the Wallet User's identity before any action affecting the Wallet Unit account is taken by support staff.

Guidelines

- *Before support staff take any action affecting a Wallet Unit account, the support process verifies the identity of the Wallet User making the request.*
- *Without identity verification at support, an attacker could telephone or message support impersonating the Wallet User and have credentials reset, the account changed, or the Wallet Unit disabled.*
- *The support process establishes that the requester is the legitimate Wallet User before acting; the strength of that verification matches the sensitivity of the action requested.*
- *A CAB verifies this requirement by reviewing the support procedures and confirming that a support action affecting an account is refused until the Wallet User's identity has been verified. Where feasible, the CAB may also test that such a support action is refused until the Wallet User's identity has been verified.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

MAINT-9.5-02: The Wallet Provider shall ensure that any process by which a Wallet User who is unable to authenticate using an existing enrolled authentication factor resets that authentication factor requires identity re-verification at an assurance level equivalent to the assurance level of the Wallet Unit before the reset is permitted.

Guidelines

- *When a Wallet User who can no longer authenticate with an existing factor asks to reset that factor, the reset is allowed only after identity re-verification at an assurance level equal to that of the Wallet Unit.*
- *A weaker reset path would become the easiest way to take over a Wallet Unit: an attacker who could not defeat the authentication factor directly would simply request a reset and pass a lower bar than the Wallet Unit itself requires.*
- *Re-verification for a factor reset reaches the same assurance level as the Wallet Unit's own, for example by repeating the identity proofing used at activation, before the new factor is enrolled.*
- *A CAB verifies this requirement by reviewing the documented factor-reset process and confirming that it requires identity re-verification at an assurance level equivalent to the Wallet Unit's before the reset completes. Where feasible, the CAB may also exercise the factor-reset process and confirm that it requires such identity re-verification before completing.*

MAINT-9.5-03: The Wallet Provider shall establish, maintain, and communicate to the Users a clear and accessible procedure through which a Wallet User can report the confirmed or suspected loss or theft of the device hosting the Wallet Unit without requiring physical access to the original device.

Guidelines

- *The notification procedure provides the means by which the Wallet User triggers the revocation process. Acceptable notification channels include the Wallet Provider's website, a telephone support line, an authenticated session from a different device, or any other channel that does not require the Wallet User to possess the original device.*
- *The procedure must be communicated to Users at Wallet Unit activation so that Users know how to report loss or theft before such a situation arises. A Wallet User who has lost their device and does not know how to report this cannot be expected to locate this information under stress.*
- *The notification procedure must not rely on the lost or stolen device for authentication. Requiring the original device PIN, biometrics, or the Wallet Unit itself to initiate notification defeats the purpose of the procedure.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented notification procedure and confirming that: the procedure does not require the original device; the procedure is communicated to Users at Wallet Unit activation; and the procedure leads to revocation of the Wallet Unit without unreasonable delay.*

MAINT-9.5-04: The Wallet Provider shall, upon receiving a credible report of loss or theft of the device hosting a Wallet Unit, revoke that Wallet Unit promptly and prior to establishing any replacement Wallet Unit for the same Wallet User.

Guidelines

- *The revocation must be completed before any replacement Wallet Unit is established for the same Wallet User. This sequence ensures the compromised Wallet Unit cannot be used during or after the replacement process.*
- *The revocation takes effect within one hour after the notification is accepted. Revocation promptness is a condition for the procedure's effectiveness: an interval*

that is too long allows the finder or thief a window of opportunity to use the Wallet Unit.

- *Upon revocation, the revocation status is propagated to the Provider's revocation service without undue delay.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented revocation procedure for lost and stolen devices and confirming that: revocation precedes any replacement issuance; the defined maximum revocation interval is respected; and revocation is verified in a conformance test scenario.*

MAINT-9.5-05: The Wallet Provider shall ensure that the process for establishing a replacement Wallet Unit following a confirmed or suspected compromise of the existing Wallet Unit or its authentication factors applies the same security requirements as the initial installation and activation process, including identity verification at the applicable Assurance Level for each credential type to be re-issued.

Guidelines

- *A replacement following compromise is treated as a fresh installation and activation: the Wallet Provider applies all initial security requirements, including identity proofing at the required Assurance Level for any PID credential or Electronic Attestation of Attributes to be re-issued to the replacement Wallet Unit. Using a shortcut that bypasses identity re-verification — such as restoring from a backup or re-issuing based on the previous issuance record alone — is not permitted.*
- *Without this control, a replacement process might use a simplified path — for example, allowing PID re-issuance without repeating the identity proofing, or transferring authentication factors from the compromised Wallet Unit. Such shortcuts undermine the security assurance that the applicable Assurance Level is intended to provide for the new Wallet Unit.*
- *The Wallet Provider maintains documented procedures for establishing replacement Wallet Units, specifying how each re-issuance step meets the requirements of the initial issuance process. For each credential type, the required Assurance Level determines the minimum identity verification that must be re-performed. The replacement procedure treats the old Wallet Unit as untrusted: its credential records are not used to shortcut new issuance.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented replacement procedure and confirming that each step required during initial activation is also required during replacement. The CAB may also simulate a replacement scenario and verify that the Wallet Provider does not offer any shortcut path to re-issuance that would omit required verification steps.*

MAINT-9.5-06: The Wallet Provider shall ensure that a revocation of a Wallet Unit, or the establishment of a replacement Wallet Unit under **MAINT-9.5-05**, that support staff carry out on behalf of a Wallet User takes effect only after a second member of staff has approved it.

Guidelines

- *A recovery or revocation done by the helpdesk needs a second employee to approve it.*
- *A single employee who is manipulated by a caller, or who acts with bad intent, could take over or disable a Wallet Unit.*
- *The four-eyes check is part of the support tooling. A revocation that the Wallet User performs without support is not covered.*
- *A CAB verifies this requirement by reviewing the support procedure and the tooling and by examining a sample of cases.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

MAINT-9.5-07: The Wallet Provider shall record the two approvals under **MAINT-9.5-06** in a log that is protected against undetected modification.

Guidelines

- *Both approvals are logged in a way that cannot be altered unnoticed.*
- *If approvals can be changed afterwards, an insider can hide misuse of the four-eyes principle.*
- *The log is the tamper-evident log of* **INST-5.1-05** *or a separate log with equal protection.*
- *A CAB verifies this requirement by reviewing the logging design and by examining log samples.*

MAINT-9.5-08: The Wallet Provider shall determine, as part of its risk assessment, the maximum time within which the second approval under **MAINT-9.5-06** is given.

Guidelines

- *The Wallet Provider decides how long the second approval takes at most.*
- *A revocation that protects a victim is not slowed by the approval process, because every hour gives the attacker more time.*
- *The time is aligned with* **MAINT-9.5-04***; the Wallet Provider arranges the availability of approvers.*
- *A CAB verifies this requirement by reviewing the risk assessment and the documented maximum time.*

MAINT-9.5-09: The Wallet Provider shall ensure that the second approval under **MAINT-9.5-06** is given within the maximum time determined under **MAINT-9.5-08**.

Guidelines

- *Approvals are given within the maximum time.*
- *A time limit that is not enforced gives the victim no protection.*
- *The Wallet Provider monitors pending approvals and escalates those that approach the maximum time.*
- *A CAB verifies this requirement by reviewing the monitoring and by examining records of approval times.*

9.6 Backup and Restore

NOTE: *In the current document we only treat backup and restore from the Wallet User point of view. We do not treat backup and restore related to Wallet Provider infrastructure (e.g. backup and restore of keys stored in the remote WSCD in case of device failure).*

MAINT-9.6-01: The Wallet Provider shall document the scope and limitations of the Wallet Unit backup mechanism (the Migration Object), including which data elements are included in and excluded from the backup, and shall communicate these limitations to the Wallet User before the Wallet User activate the automated backup creation.

Guidelines

- *The Wallet Provider documents what the backup mechanism — the Migration Object — does and does not include, and communicates those limits to the Wallet User before the Wallet User turns on automated backup.*
- *A Wallet User who believed the backup captured everything could later find, at the worst possible moment, that key-bound credentials were not recoverable from it, and would have made decisions about device replacement on a false assumption.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *The documentation lists the data elements included in and excluded from the backup, and the Wallet User is shown these limits before enabling automated backup rather than discovering them at restore time.*
- *A CAB verifies this requirement by reviewing the backup documentation and confirming, in the Wallet User flow, that the limitations are communicated before automated backup is activated.*

MAINT-9.6-02: The Wallet Provider shall ensure that any backup is encrypted before being stored or transmitted outside the Wallet Unit, using an encryption password that is known only to the Wallet User.

Guidelines

- *Encrypting backup data before storage ensures that access to the physical or logical backup storage location alone is insufficient to expose PID or credential data. An attacker who obtains the encrypted backup without the corresponding decryption key cannot derive any usable personal data from it.*
- *The encryption password used for backup encryption is stored and managed separately from the backup data itself. Co-locating the encryption password with the backup — for example, in the same file directory, the same cloud storage account, or the same device — negates the protection provided by encryption.*
- *Backup of private cryptographic keys from within the WSCD is not allowed. This requirement therefore primarily applies to PID credential data, attestation payloads, and associated metadata that is backed up in encrypted form outside the Wallet Unit.*
- *A CAB verifies this requirement by reviewing the backup implementation and confirming that PID and attestation data is encrypted before being stored or transmitted outside the Wallet Unit, that the backup encryption key is stored separately from the backup data, and that the encryption key itself is protected with access controls appropriate to its sensitivity.*

MAINT-9.6-03: The Wallet Provider shall inform the Wallet User that the encryption password should be stored separately from the backup in a location that is only accessible to the Wallet User.

Guidelines

- *The Wallet Provider advises the Wallet User to keep the backup encryption password somewhere separate from the backup itself, in a location only the Wallet User can reach.*
- *If the password were stored alongside the backup, anyone who obtained the backup would also obtain the means to decrypt it, and the encryption would provide no protection at all.*
- *The guidance directs the Wallet User to hold the password independently of the backup storage, so that compromise of the backup location alone does not expose its contents.*
- *A CAB verifies this requirement by confirming that the Wallet User is informed, as part of the backup flow, to store the encryption password separately from the backup.*

MAINT-9.6-04: The Wallet Provider shall ensure that the confidentiality of the backup data does not depend on the storage location, such that the backup remains unreadable to the Wallet Provider and to the operator of any storage location offered or used, and the ability to decrypt it rests solely on a secret held by the Wallet User.

Guidelines

- *The protection of the backup rests entirely on a secret held only by the Wallet User (the encryption requirement earlier in this clause), not on who hosts the file. A storage*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

location offered by the Wallet Provider, a third-party cloud service, or any other location is therefore acceptable, because none of these parties can read the backup.

- *The failure this prevents is a backup whose confidentiality depends on trusting the host - for example one stored in plaintext, or under a key the host holds - so that whoever operates the storage, the Wallet Provider included, could read the Wallet User's collected data.*
- *Because the ciphertext may be held by a party other than the Wallet User, the strength of the user secret and of the key derivation matters: a weak password invites offline guessing by anyone holding the file, which the encryption and password-handling requirements in this clause address. Subject to that, the Wallet Provider may offer a storage location as a convenience, provided it retains no means to decrypt the backup.*
- *A CAB verifies this requirement by reviewing the backup key-management design and confirming that decryption depends only on a Wallet-User-held secret and that neither the Wallet Provider nor any offered storage operator holds that secret, for instance by inspecting the key-management documentation and, where feasible, by retrieving a stored backup and confirming no plaintext is recoverable without the user secret.*

MAINT-9.6-05: The Wallet Provider shall ensure that when a Wallet User restores a backup to a different device the target Wallet Unit will remind the Wallet User to revoke the source Wallet Unit if it will no longer be used by the Wallet User and provide him with any information that the Wallet Provider may collect that would help the Wallet User to do so.

Guidelines

- *When a Wallet User restores a backup onto a different device, the new Wallet Unit reminds the Wallet User to revoke the old Wallet Unit if it will no longer be used, and passes on whatever information the Wallet Provider holds that would help the Wallet User do so.*
- *If the old Wallet Unit were left valid and forgotten after a restore to a new device, a lost, sold, or stolen old device would keep working credentials, leaving two live Wallet Units for one Wallet User.*
- *The reminder appears as part of the restore flow on the new device; the information provided is whatever the Wallet Provider legitimately holds that assists revocation of the old Wallet Unit, consistent with the decommissioning steps in clause 10.5.*
- *A CAB verifies this requirement by reviewing the documented restore flow and confirming that, on restoring a backup to a new device, the Wallet User is reminded to revoke the old Wallet Unit and given the available supporting information. Where feasible, the CAB may also restore a backup to a new test device and confirm that the reminder and supporting information are provided.*

MAINT-9.6-06: The Wallet Provider shall update the Migration Object to reflect the current state of all PID credentials, attestations, and transaction log entries after every transaction performed by the Wallet Unit. A transaction for the purposes of this requirement includes any presentation of a PID or EAA to a relying party, any issuance or deletion of an attestation, and any key rotation event.

Guidelines

- *The Migration Object functions as a continuously updated backup of the wallet state. Because the transaction log changes with every transaction, the Migration Object becomes outdated after each transaction. Automated updates after each transaction ensure that the Migration Object at any given time accurately represents the most recently confirmed wallet state, minimising the data loss window in a device failure scenario.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *The designated storage location for the Migration Object needs to accommodate ongoing growth as the transaction log accumulates. If storage constraints require earlier transaction log entries to be pruned, the Wallet User is informed of the retention period and the implications for historical auditability.*
- *Without continuous update of the Migration Object after every transaction, the backup represents a stale snapshot that might miss crucial information that might be needed as digital forensic evidence, evidence in court case, etc.*
- *A CAB verifies MAINT-8.7-01 by reviewing the documented Migration Object update behaviour and confirming that the Migration Object at the designated storage location is updated after each transaction, with the updated content reflecting the transaction just completed. Where feasible, the CAB may also perform a sequence of transactions with a test Wallet Unit that has a Migration Object configured and confirm that the object is updated after each transaction.*

MAINT-9.6-07: The Wallet Provider shall not present a Migration Object to the Wallet User as current if the Migration Object does not reflect the most recently confirmed wallet state, without displaying an accompanying notification that the Migration Object is outdated.

Guidelines

- *An outdated Migration Object is one whose transaction log does not include the most recently confirmed wallet transaction. The notification informs the Wallet User of the last update timestamp so that the Wallet User can assess the data loss window before deciding to proceed with a migration.*
- *Presenting an outdated Migration Object as current without notification creates the risk that a Wallet User initiates migration based on a stale backup, believing all credentials and transaction history are preserved. If the Migration Object is missing the most recent transactions, data loss occurs at the point of migration even though the Wallet User expected a complete recovery and the new Wallet Unit might miss important information for security analysis.*
- *The notification distinguishes between temporary staleness (e.g. an in-flight update not yet confirmed at the storage location) and persistent staleness (e.g. automatic updates have repeatedly failed). Where the Migration Object is persistently outdated, the Wallet User is presented with the option to investigate the cause, trigger a manual update, or proceed with the understanding that recent data will not be recovered.*
- *A CAB verifies this requirement by examining a test Wallet Unit whose Migration Object update timestamp predates the most recently confirmed transaction, and confirming that: (i) the object is not displayed to the Wallet User as current or up to date; (ii) the staleness notification is displayed and includes the last update timestamp; (iii) the notification cannot be dismissed in a way that causes the object to subsequently appear as a current backup.*

MAINT-9.6-08: [CONDITIONAL] The Wallet Provider shall ensure that, where the Wallet Unit cannot update the Migration Object because the storage location selected by the Wallet User is no longer accessible to it, the Wallet Unit prompts the Wallet User to restore access to that location or to select a new storage location.

Guidelines

- *When the Wallet Unit finds it can no longer write the Migration Object to the location the Wallet User chose - the account was closed, the credentials changed, the service is gone - it does not fail silently; it tells the Wallet User and offers to re-establish access or move to a new location.*

- *If an update failure were silent, the Wallet User would believe a current backup exists while the stored object quietly goes stale or missing, and would discover the gap only when trying to recover after losing the device - the moment it can no longer be fixed.*
- *This complements the staleness notification earlier in this clause: staleness covers an object that is merely out of date, while this requirement covers the case where the location itself can no longer be reached. Prompting for a new location lets the Wallet User restore a working backup path.*
- *A CAB verifies this requirement by reviewing the Wallet Unit's handling of a failed Migration Object update and confirming that an inaccessible location leads to a Wallet User prompt to restore access or choose a new location, for instance by inspecting the error-handling design and, where feasible, by making the selected location unreachable on a test device and observing the prompt.*

9.7 Security and Compliance Monitoring

MAINT-9.7-01: The Wallet Provider shall monitor the continued adequacy of the authentication factors associated with each Wallet Unit for the applicable Assurance Level and shall require the Wallet User to establish new or updated authentication factors — through a process that meets the same security requirements as the initial activation — where the operating system, Wallet Secure Cryptographic Device, or applicable conformity framework indicates that existing factors no longer meet the requirements for the applicable Assurance Level.

Guidelines

- *Authentication factors may become inadequate due to: compromise of a knowledge factor such as an observed PIN; revocation or expiry of the WSCD's security certification; expiry of the WSCD attestation certificate; or changes to the applicable conformity framework that raise the minimum requirements for the Assurance Level. The Wallet Provider's monitoring process detects each of these conditions and triggers the corresponding update procedure for affected Wallet Units before the degraded factors continue to be relied upon.*
- *If authentication factors are not updated when they become inadequate, the Wallet Unit continues to operate on the basis of factors that no longer meet the assurance requirements. A Wallet Unit that presents credentials as issued at Assurance Level High while its authentication mechanism uses outdated or compromised factors provides a false level of assurance to relying parties and undermines the integrity of the identity ecosystem.*
- *Detection of WSCD certification changes can be achieved by monitoring the WSCD manufacturer's notification channels and checking WSCD attestation certificate validity against the applicable trust list. Where a WSCD attestation expires or is revoked, the Wallet Provider requires the Wallet User to complete re-attestation before the Wallet Unit can be used for credential presentations. The update process for authentication factors uses the same procedures as the initial activation, including the device security assessment and factor binding steps.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's monitoring procedures and confirming that the procedure covers all conditions under which authentication factors may become inadequate, that the procedure triggers an update requirement when any monitored condition is detected, and that the update process applies the same security requirements as initial activation. The CAB may additionally present a Wallet Unit whose WSCD attestation has expired (if available) and confirm that the Wallet Unit requires re-attestation before presentations are permitted.*

MAINT-9.7-02: The Wallet Provider shall conduct documented periodic reviews of the security controls and procedures governing the Wallet Unit infrastructure, at intervals not exceeding twelve months, to verify that the controls remain effective and continue to satisfy the requirements for the applicable Assurance Level, and shall document identified findings and implement remediation within a timeframe commensurate with the severity of each finding.

Guidelines

- *The periodic security review covers the Wallet Provider's technical infrastructure, operational procedures, personnel security, and third-party service provider controls relevant to the Wallet Unit service. The review compares the current state of each control against the requirements applicable at the time of the review and notes any changes in the threat environment, underlying platform, or applicable regulations that may require control updates. The output of each review is a documented findings report with a remediation plan assigning each finding to an owner with a target completion date.*
- *Security management degradation can occur gradually over time: staff turnover reduces institutional knowledge of security procedures; infrastructure changes outpace documented security controls; or third-party providers reduce their security posture without notification. Without periodic review, the gap between required and implemented controls may grow undetected until a security incident reveals it, at which point affected Wallet Units may already have operated with insufficient controls for an extended period.*
- *The twelve-month interval is a minimum; higher-risk environments or significant operational changes — such as migration to a new WSCD platform, a change in PID Provider, or a major software update — may require ad hoc reviews. The review may be performed by internal security personnel, an external auditor, or a combination. Where the applicable Assurance Level requires a formal conformity assessment, the periodic security review aligns with the conformity assessment cycle and may be conducted as part of that assessment.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documentation of recent security reviews and confirming that: (i) reviews have been conducted at intervals not exceeding twelve months; (ii) findings are documented with severity ratings; (iii) remediation has been completed within the defined timeframes or escalated with documented justification. The CAB also reviews the most recent security review report to assess its scope and confirm that it covers the areas specified in this requirement.*

9.8 Data Management and Retention

MAINT-9.8-01: The Wallet Provider shall maintain a documented data management policy that specifies, for each category of operational record generated during the Wallet Unit's active lifetime, the legal basis for retention, the defined retention period, the storage protection requirements, and the deletion or anonymisation mechanism, and shall implement and consistently apply this policy across all Wallet Units and associated backend systems.

Guidelines

- *Operational records generated during a Wallet Unit's active lifetime include, but are not limited to: authentication event logs, transaction records, credential issuance and renewal records, and records of communications with the Wallet Provider's backend systems. Each category has its own applicable legal basis for retention — contractual necessity, legal obligation, or legitimate interest — and the Wallet Provider documents*

each basis with its corresponding retention period separately. The policy is reviewed and updated as part of the periodic security management review.

- *Without a documented and enforced data management policy, the Wallet Provider may retain records beyond the period permitted under the applicable data protection framework, creating liability for unauthorised data retention. Alternatively, records may be deleted prematurely, failing to meet legal retention obligations and leaving the Wallet Provider unable to demonstrate compliance in an audit. Both failures can result in regulatory enforcement action or inability to defend against legal claims.*
- *The scope of the data management policy includes records held in backend systems, logs retained by infrastructure components, and any records related to wallet operations that are retained beyond the wallet session. Changes in applicable data protection regulations are assessed against the current policy and trigger updates where necessary. Anonymisation used as an alternative to deletion must meet a standard at which re-identification of the individual is not reasonably achievable using available means.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented data management policy and confirming that: (i) all operational record categories are enumerated with documented legal basis, retention period, storage protection requirements, and deletion mechanism for each; (ii) the policy is implemented and consistently applied across all systems. The CAB may additionally inspect records for a sample of active Wallet Units to verify that retention periods and protection requirements are applied in accordance with the documented policy.*

9.9 Trust Anchor Management

MAINT-9.9-01: The Wallet Provider shall retrieve, at intervals not exceeding 24 hours, the current version of each trusted list as specified in [8] and of each list of trusted entities established in accordance with [12] that is applicable to the parties with which its Wallet Units interact.

Guidelines

- *The trust anchors a Wallet Unit needs in order to authenticate providers and relying parties are published centrally and change over time. Retrieving the lists on a fixed cycle is what keeps the Wallet Provider's own view of those anchors current.*
- *Where retrieval is occasional or event-driven only, the Wallet Provider works from a stale view. Anchors withdrawn after a compromise stay in circulation, and newly recognised providers cannot be authenticated, which the Wallet User experiences as an unexplained refusal.*
- *The retrieval interval is documented and monitored, and a failed retrieval is treated as an operational incident rather than silently skipped until the next cycle. A shorter interval than 24 hours is compatible with this requirement.*
- *A CAB verifies this requirement by reviewing the retrieval schedule and its monitoring, and by sampling the retrieval logs over a representative period to confirm that the interval was respected and that failures were followed up.*

MAINT-9.9-02: The Wallet Provider shall distribute to every non-revoked Wallet Unit each trust anchor that has been newly published in a list retrieved under **MAINT-9.9-01**.

Guidelines

- *Retrieval by the Wallet Provider is only the first half of the operation. The anchors have to reach the Wallet Units, which are the components that actually validate the certification paths.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *Where new anchors are not distributed, Wallet Units cannot authenticate providers and relying parties that have since been recognised. The Wallet User is unable to obtain or present attestations and has no way of telling a legitimate refusal from a stale configuration.*
- *Distribution takes place over the existing authenticated channel between the Wallet Provider and the Wallet Unit, and is integrity-protected so that the set of anchors cannot be altered in transit. The channel is established as specified in clause 6.2.*
- *A CAB verifies this requirement by observing, on a test Wallet Unit, that an anchor newly added to a source list becomes available to the Wallet Unit, and by reviewing the distribution mechanism and its integrity protection.*

MAINT-9.9-03: The Wallet Provider shall withdraw from every valid Wallet Unit each trust anchor that has been removed from, or invalidated in, a list retrieved under **MAINT-9.9-01**.

Guidelines

- *Withdrawal is the security-critical direction of trust anchor management: an anchor is removed from a published list precisely because it is no longer to be relied upon.*
- *Where withdrawal does not happen, a Wallet Unit continues to accept credentials and presentation requests authenticated under a compromised or decommissioned anchor. An attacker in possession of the corresponding private key can impersonate a provider or a relying party for as long as the anchor remains on the device, and the Wallet User has no means of noticing.*
- *Withdrawal is applied with the same urgency as distribution of new anchors and is not deferred to a periodic full refresh. The Wallet Provider records which Wallet Units have confirmed the withdrawal so that Wallet Units that have not connected can be identified.*
- *A CAB verifies this requirement by removing an anchor from a source list, confirming on a test Wallet Unit that credentials authenticated under it are subsequently refused, and by reviewing the records of Wallet Units that have not yet confirmed the withdrawal.*

MAINT-9.9-04: The Wallet Provider shall ensure that a Wallet Unit accepts only the trust anchors distributed to it by the Wallet Provider under **MAINT-9.9-02**.

Guidelines

- *The set of anchors on the Wallet Unit is closed and is controlled exclusively by the Wallet Provider. Anchors present in the operating system trust store, or added locally by the Wallet User or by another application, are not used for validating attestations and certificates in the European Digital Identity framework.*
- *Where the Wallet Unit also relies on the operating system trust store, any party able to add an anchor there — including a Wallet User persuaded to install a configuration profile, or a device management system under an attacker's control — can cause forged provider and relying party credentials to be accepted as genuine.*
- *A conformant implementation maintains its own anchor store, separate from the operating system trust store, and validates every certification path in this domain exclusively against that store. The corresponding rejection obligation for PID credentials is specified in* **PID-8.3-02***.*
- *A CAB verifies this requirement by adding an anchor to the operating system trust store of a test device and confirming that material authenticated under that anchor is not accepted by the Wallet Unit.*

10 Lifecycle Event: Device Change / Migration

NOTE: This clause covers two scenarios. In the first, the source device is still accessible to the Wallet User and the Wallet Unit is migrated to the new device with the source device's participation (clauses 10.1 to 10.6). In the second, the source device is no longer accessible to the Wallet User - for example lost or stolen - and the Wallet Unit is recovered to a new device from a Migration Object without the source device (clause 10.7); that recovery is itself a trigger to revoke the source Wallet Unit.

10.1 Migration Initiation and Authorisation

MIG-10.1-01: The Wallet Provider shall ensure that migration of a Wallet Unit is initiated solely by the Wallet User from the source Wallet Unit, including where the target Wallet Unit is operated by a different Wallet Provider, and that no authorisation, approval, or notification by the Wallet Provider is required as a precondition for initiating migration.

Guidelines

- *Migration is the act by which the Wallet User transfers the Wallet Unit's state -- the list of PID and attestation credentials, the transaction log, and any non-device-bound attestation data -- from one device to another, by exporting the Migration Object on the source device and importing it on the target device. The Wallet User may target a Wallet Unit operated by the same Wallet Provider or by a different Wallet Provider; this requirement does not differentiate between the two cases.*
- *Without this control, a Wallet Provider could refuse to permit migration to a different Wallet Solution, or could impose a notification or approval step that operates as a barrier to migration. Either practice undermines the Wallet User's right to data portability and the EUDIW model's requirement that wallet ecosystems be interoperable.*
- *Acceptable approaches include exposing a migration or export action in the Wallet Unit Wallet User interface that the Wallet User can invoke at any time without contacting the Wallet Provider, ensuring that the Migration Object is automatically maintained so that initiating migration does not require any preparatory step on the Wallet Provider side, and treating any contact with the Wallet Provider as voluntary on the Wallet User's part.*
- *A CAB verifies this requirement by inspecting the Wallet Unit Wallet User interface for a Wallet User-accessible migration trigger and reviewing the Wallet Provider's documentation for any policy or procedure that would gate Wallet User-initiated migration, confirming that no Wallet-Provider-side authorisation or approval step is required. Where feasible, the CAB may also initiate migration on a test Wallet Unit and confirm that no such authorisation or approval step is encountered.*

10.2 Secure Data Transfer Mechanisms

MIG-10.2-01: The Wallet Provider shall ensure that at all times an updated Migration Object will be available in the storage location selected by the Wallet User.

Guidelines

- *An up-to-date Migration Object is kept available at all times in the storage location the Wallet User chose, so that a current object exists whenever the Wallet User needs to migrate or recover.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *If the stored object were allowed to fall out of date, a Wallet User migrating after a loss would recover a stale state — missing recently added credentials or settings — or find no usable object at all.*
- *The Wallet Unit refreshes the stored object as the Wallet Unit's contents change, writing it to the Wallet-User-selected location, so that the latest recoverable state is always present.*
- *A CAB verifies this requirement by changing the contents of a test Wallet Unit and confirming that the Migration Object in the selected storage location is updated to reflect the change.*

MIG-10.2-02: The Wallet Provider shall ensure that the Migration Object is stored in external or remote storage only in an encrypted form that protects its confidentiality, integrity, and authenticity, and that only the Wallet User holds the cryptographic material required to decrypt it.

Guidelines

- *The Migration Object is composed entirely of Wallet Instance app-layer data — specifically a transaction log, re-issuance metadata for PIDs and device-bound attestations, and optionally full data for non-device-bound attestations. It contains no private keys, no WSCD-generated secrets, and is unrelated to WSCD operations. Encryption is applied within the Wallet Instance before the Migration Object leaves the device, so the data is never stored in plaintext outside the Wallet User's device.*
- *A scenario this requirement addresses is one in which the external or remote storage provider — or an attacker who gains access to it — retrieves the Migration Object and reads the transaction history, re-issuance metadata, or non-device-bound attestation data it contains. Exposure of this data reveals the PID and EAA providers the Wallet User is registered with, provider endpoint information, and a chronological record of wallet activity. For users who opted in to non-device-bound attestation storage, the full content of those attestations is also at risk. A storage provider holding multiple users' Migration Objects in plaintext represents a centralised target.*
- *Password-based cryptography is one acceptable approach, where the Wallet User's chosen password is the sole source of the decryption password and the Wallet Provider has no access to it. An alternative is to derive the encryption key from a secret bound to the Wallet Unit — for example, a key stored within the WSCD — so that only the Wallet Unit can decrypt the Migration Object. In either case, the Wallet Provider holds no decryption password. Confidentiality, integrity, and authenticity protection are achieved together using an authenticated encryption scheme such as AES-GCM. or upon expiry of the migration session window.*
- *A CAB verifies this requirement by retrieving a stored Migration Object from the external or remote storage location and confirming that it is stored in an encrypted form from which no plaintext data is recoverable without the Wallet User's secret. The CAB additionally reviews the Wallet Provider's documentation to confirm that the decryption key is not stored on or derivable by the Wallet Provider's infrastructure, and that no Wallet Provider-side pathway exists to access the plaintext content of the Migration Object.*

MIG-10.2-03: Prior to presenting the Wallet User with the option to finalise migration and revoke the source Wallet Unit, the Wallet Provider shall verify that the target Wallet Unit is in an active state.

Guidelines

- *An active state for the target Wallet Unit requires that: (i) the target Wallet Unit has completed the activation process, including WSCA/WSCD initialisation and WUA*

issuance on the new device; (ii) the PID credential has been delivered to and confirmed as validated by the target Wallet Unit, including verification of the issuer signature and the credential binding to the target Wallet Unit's keys.

- *Active state verification is distinct from a check that all attestations have been transferred. The presence and validation of the PID credential on the target Wallet Unit is the criterion; Electronic Attestations of Attributes are not required to be present for the active state check to pass.*
- *Allowing the source Wallet Unit to be revoked without the target Wallet Unit being in an active state, will bring the Wallet User in a position without any active Wallet Unit with potentially a more complex setup process for obtaining a new active Wallet Unit as there is no source Wallet Unit that can be used to authenticate the Wallet User.*
- *A CAB verifies MIG-9.2-01 by confirming that: (i) the Wallet Provider does not present the finalisation option until the target Wallet Unit has passed the active state check; (ii) a target Wallet Unit that has not yet received and validated the PID credential does not pass the active state check; (iii) the active state check result is recorded in the migration log.*

MIG-10.2-04: The Wallet Provider shall revoke the source Wallet Unit upon the Wallet User's explicit decision to finalise the migration.

Guidelines

- *The revocation of the source Wallet Unit is triggered by the Wallet User's explicit decision to finalise migration, not by the Wallet Provider unilaterally. This decision is recorded in the migration log and is available for audit.*
- *The risk addressed by this requirement is premature or automatic revocation of the source Wallet Unit. If revocation is triggered by any automated step in the migration flow — such as installation of the Wallet Instance on the new device — rather than by the Wallet User's explicit finalisation decision, the Wallet User may find the source Wallet Unit revoked before they intended to abandon it, leaving a gap where neither device has a fully operational Wallet Unit.*
- *The finalisation decision screen explicitly states that selecting the finalisation action will result in permanent, irreversible revocation of the source Wallet Unit. The screen does not present other migration steps or decisions alongside the finalisation action, to avoid any ambiguity about what the Wallet User is confirming with their action.*
- *A CAB verifies this requirement by reviewing the documented migration flow and its logging and confirming that: (1) the finalisation screen describes the revocation consequence in clear terms; (2) revocation is recorded in the migration log with the authenticated Wallet User session timestamp. Where feasible, the CAB may also test the migration flow to confirm this behaviour.*

MIG-10.2-05: The Wallet Provider shall not prevent or delay revocation of the source Wallet Unit on the grounds that the Wallet User has not yet requested reissuance of some or all Electronic Attestations of Attributes held in the source Wallet Unit.

Guidelines

- *EAA reissuance requires separate interaction with each Attestation Provider and may not be immediately possible at the time of migration. This requirement prevents the EAA reissuance status from blocking the revocation of the source Wallet Unit once the Wallet User has decided to finalise migration.*
- *The Wallet Provider presents the Wallet User with an overview of EAA from the source Wallet Unit that have not yet been reissued to the target device, so the Wallet User is informed of follow-up actions required after migration.*

- *The risk of delaying revocation until all EAA have been reissued on the target device is that the source Wallet Unit remains live for an indeterminate period after the Wallet User has decided to complete migration. An active source Wallet Unit that the Wallet User believes to be decommissioned remains exploitable by a party with physical access to the source device.*
- *A CAB verifies this requirement by reviewing the documented finalisation behaviour and confirming that, when a test Wallet Unit has at least one EAA not yet reissued on the target device: (i) the Wallet Provider does not prevent the Wallet User from selecting the finalisation action; (ii) revocation of the source Wallet Unit proceeds upon the Wallet User's finalisation decision regardless of the EAA reissuance status on the target device. Where feasible, the CAB may also attempt to finalise migration in this state and confirm this behaviour.*

10.3 New Device Security Verification

MIG-10.3-01: The Wallet Provider shall ensure that, before completing Wallet Unit re-establishment on the target device, the target device undergoes the same device security assessment as is required during Wallet Instance installation, including verification that the device meets the minimum hardware and software security requirements defined in the Wallet Provider's security policy and that a WSCD meeting the applicable security certification requirements is available on the target device.

Guidelines

- *Wallet Unit re-establishment on a new device is functionally equivalent to a new Wallet Instance installation on that device in terms of the security requirements that must be met before the Wallet Unit is considered established. The security assessment includes device integrity checks, operating system version requirements, and verification that the WSCD available on the target device holds the security certification applicable at Assurance Level High.*
- *Without this control, a migration could result in a Wallet Unit that operates on a target device that does not meet the security requirements originally verified during installation. An actor who controls the migration process or a Wallet User who migrates to a less secure device could end up with a Wallet Unit on a device that lacks a certified WSCD, runs a compromised operating system, or otherwise does not provide the security baseline required for a valid Wallet Unit at the applicable Assurance Level.*
- *The device security assessment on the target device mirrors the pre-installation checks defined in the installation lifecycle event. If any check fails on the target device, the migration process does not complete and the Wallet User is informed of the specific check that failed. The source Wallet Unit is not revoked if the target device fails the security assessment, ensuring the Wallet User is not left without a functional Wallet Unit.*
- *A CAB verifies this requirement by reviewing the documented migration security criteria and confirming that the migration flow refuses to complete Wallet Unit re-establishment on a target device that fails one or more of the security criteria required during installation - for example, a device with a non-certified WSCD or a device showing indicators of operating system compromise - and that the source Wallet Unit remains active. Where feasible, the CAB may also present such a target device and confirm that re-establishment is refused and the source Wallet Unit remains active.*

10.4 Wallet Unit Re-establishment on New Device

MIG-10.4-01: The Wallet Provider shall issue a new Wallet Instance Attestation and a new Key Attestation for the new device following the same security verification process applied during their initial issuance, including WSCD certification verification and platform attestation.

Guidelines

- *For the new device, the Wallet Provider issues a fresh Wallet Instance Attestation and Key Attestation using the same security verification as the original issuance, including checking the secure cryptographic device's certification and the platform attestation.*
- *If migration reused the old device's attestations or skipped the verification steps, a new device that does not meet the security requirements could be admitted, or attestations could be bound to hardware whose properties were never checked.*
- *Issuance for the new device repeats the activation-time verification — secure-hardware certification and platform attestation — before the new attestations are issued, rather than treating migration as a lightweight transfer.*
- *A CAB verifies this requirement by reviewing the documented migration flow and confirming that new attestations are issued only after the same verification steps as initial issuance. Where feasible, the CAB may also perform a migration to a test device and confirm that new attestations are issued only after those same verification steps.*

MIG-10.4-02: The Wallet Provider shall ensure that device binding on the new device is established using a key pair newly generated within the WSCD of the new device and that no device-bound private key is transferred from the old device to the new device.

Guidelines

- *Device binding on the new device uses a key pair freshly generated inside that device's secure hardware, and no device-bound private key is copied from the old device to the new one.*
- *If a device-bound private key were transferred between devices, the key would no longer be confined to a single piece of secure hardware, breaking the guarantee that a bound credential can only be used from the device it was bound to.*
- *The new device generates its own binding keys within its secure cryptographic hardware, and the migration transfers only data that is not device-bound, with device-bound credentials re-issued against the new keys.*
- *A CAB verifies this requirement by inspecting a migration and confirming that the new device's binding keys were generated on that device and that no device-bound private key was transferred from the old device.*

MIG-10.4-03: The Wallet Provider shall require the Wallet User to establish authentication factors on the target device through a procedure that meets the same security requirements as the initial setup of authentication factors during Wallet Unit activation, prior to the migration process being considered complete.

Guidelines

- *Authentication factors are bound to the device on which they are established and cannot be transferred from the source device to the target device. A fresh authentication factor setup is therefore mandatory on the target device as part of the migration process. This ensures that authentication factors associated with the source device — potentially compromised or observed by an attacker — cannot be used to access the Wallet Unit on the target device.*
- *The security requirements for authentication factor setup on the target device need to be the same as those applicable during initial Wallet Unit activation, including binding*

of the factors to the WSCD and confirmation that the factors are under the exclusive control of the legitimate holder. The security baseline for authentication factor setup on the target device is not lower than that required for initial activation.

- *This requirement complements* **MIG-10.1-01***, which requires verification of the Wallet User's identity before migration is authorised. The present requirement addresses the security of the authentication mechanism that will protect the Wallet Unit on the target device after migration has been completed.*
- *A CAB verifies this requirement by reviewing the technical specification of the migration flow and confirming that authentication factor setup on the target device is a mandatory, documented step subject to the same security controls as initial activation. The CAB also tests that authentication on the target device uses factors freshly established on that device, and not any credentials transferred from the source device.*

10.5 Old Device Decommissioning

MIG-10.5-01: The Wallet Provider shall point out the dangers to the Wallet User of a valid Wallet Unit that is not under control of the Wallet User and ask the Wallet User if the old Wallet Unit should be revoked.

Guidelines

- *As part of decommissioning, the Wallet Provider explains to the Wallet User the risks of leaving a valid Wallet Unit on a device no longer under their control, and asks whether to revoke the old Wallet Unit.*
- *A Wallet User unaware of the danger might leave a fully valid Wallet Unit on a device they have sold or replaced, where it could later be used by whoever holds that device.*
- *The explanation is given in plain terms at the point of migration or decommissioning, and the Wallet User is asked to decide whether to revoke; the actions that follow from that decision are covered by the remaining requirements of this clause.*
- *A CAB verifies this requirement by reviewing the documented decommissioning flow and confirming that the risk is explained and that the Wallet User is asked whether to revoke the old Wallet Unit. Where feasible, the CAB may also run the decommissioning flow and confirm that the risk is explained and the Wallet User is asked whether to revoke the old Wallet Unit.*

MIG-10.5-02: [CONDITIONAL] If the Wallet User has indicated a need for the old Wallet Unit to be revoked and the old Wallet Unit is managed by the same Wallet Provider, the Wallet Provider shall start the process to revoke the old Wallet Unit.

Guidelines

- *Where the Wallet User asks for the old Wallet Unit to be revoked and it is managed by the same Wallet Provider, the Wallet Provider starts the revocation of that old Wallet Unit.*
- *If a Wallet User's explicit request to revoke were not acted upon, an old device the Wallet User has deliberately given up would keep a working Wallet Unit, exactly the outcome the Wallet User asked to prevent.*
- *On the Wallet User's request, the Wallet Provider initiates its revocation process for the old Wallet Unit; the permanent effect and timing of revocation are covered in clause 12.*
- *A CAB verifies this requirement by requesting revocation of an old Wallet Unit managed by the same Wallet Provider during decommissioning and confirming that revocation is initiated.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

MIG-10.5-03: [CONDITIONAL] If the Wallet User has indicated a need for the old Wallet Unit to be revoked and the old Wallet Unit is not managed by the same Wallet Provider, the Wallet Provider shall give the best possible instructions to the Wallet User what actions the Wallet User should undertake in order to get the old Wallet Unit revoked.

Guidelines

- *Where the Wallet User asks for the old Wallet Unit to be revoked but it is managed by a different Wallet Provider, the Wallet Provider gives the Wallet User the best possible instructions on how to get that old Wallet Unit revoked.*
- *A Wallet User who cannot revoke an old Wallet Unit held at another provider, and receives no guidance, might simply leave it active, so that a device out of their control keeps usable credentials.*
- *The Wallet Provider cannot revoke a Wallet Unit it does not manage, so it instead directs the Wallet User to the steps and the other provider's channels needed to achieve revocation there.*
- *A CAB verifies this requirement by requesting revocation of an old Wallet Unit managed by a different provider and confirming that the Wallet User is given actionable instructions on how to obtain that revocation.*

MIG-10.5-04: The Wallet Provider shall ensure that all key material held by the WSCD, all PID credentials and Electronic Attestations of Attributes, and all personal data stored by the Wallet Instance are permanently and irrecoverably deleted from the device before the Wallet Instance uninstallation process completes.

Guidelines

- *The scope of data subject to deletion includes all items created or managed by the Wallet Unit: private and secret key material within the WSCD; PID credentials and Electronic Attestations of Attributes in all on-device storage locations, regardless of format; personal profile data associated with the wallet account; transaction data; and any other application data attributable to the Wallet User. Deletion is performed before the uninstallation process completes, not deferred to a later OS-level cleanup.*
- *A scenario this requirement addresses is one in which the Wallet Instance is removed from the device — for example as part of a device resale, a factory reset circumvention, or an OS reinstallation — but residual credential data, transaction logs, or key material from the previous installation remains recoverable from the device storage. A subsequent Wallet User of the device, or an attacker with forensic access to the storage, could reconstruct the previous Wallet User's identity credentials or transaction history from the undeleted data.*
- *Deletion of WSCD-bound key material is achieved by issuing the appropriate key deletion command to the WSCD. Deletion of application-layer data is achieved by invoking the OS-level secure deletion capability or by overwriting the data with a secure wipe pattern. Where the Wallet Unit has associated data in remote storage — such as a Migration Object — the uninstallation flow includes a step that prompts the Wallet User to confirm deletion of remote data, or deletes it automatically with Wallet User notification. The Wallet Instance logs the completion of each deletion step.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's uninstallation procedure documentation and confirming that it specifies a defined deletion step for each category of stored data. Where a forensic examination is feasible, the CAB may also perform a guided uninstallation of a test Wallet Unit and conduct a forensic examination of the device storage to confirm that no recoverable credential data, key material, or personal data attributable to the wallet remains after uninstallation.*

MIG-10.5-05: [CONDITIONAL] If the Wallet User has indicated a need for the old Wallet Unit to be revoked and the old Wallet Unit is managed by the same Wallet Provider, the Wallet Provider shall ensure that that all cryptographic key material and personal data stored in the old Wallet Unit are irrecoverably deleted from the old device and that the Wallet Instance is uninstalled from the old device the next time when the Wallet Instance connects again with the WSCA.

Guidelines

- *Where the Wallet User asks for revocation and the old Wallet Unit is managed by the same Wallet Provider, the Wallet Provider ensures that the old device's key material and personal data are irrecoverably deleted and the Wallet Instance is uninstalled the next time it reconnects to the secure cryptographic application.*
- *If the old Wallet Unit were revoked in the ecosystem but its data left in place on the device, the personal data and key material would remain recoverable from a device the Wallet User no longer controls.*
- *Because the old device might be offline at the moment of decommissioning, the deletion and uninstallation are carried out at its next reconnection; verification that deletion completed, and revocation where it does not, are covered in clause 10.6.*
- *A CAB verifies this requirement by revoking an old Wallet Unit and confirming that, on the old device's next reconnection, its key material and personal data are deleted and the Wallet Instance is uninstalled.*

10.6 Secure Deletion of Keys and Attestations on Old Device

MIG-10.6-01: The Wallet Provider shall verify that the deletion of all cryptographic key material and personal data from the source Wallet Unit has completed, and shall record the outcome of that verification.

Guidelines

- *Deletion is instructed at the end of migration but executed on a device the Wallet Provider does not control. The verification establishes whether the instruction was actually carried out, and the record makes that determination available afterwards.*
- *Without verification, a source device that acknowledged the instruction but failed to complete it — because it lost connectivity mid-operation, or because the Wallet Instance was terminated — retains key material while the Wallet Provider's records show the migration as cleanly completed.*
- *Verification normally takes the form of a confirmation returned by the source Wallet Instance after the deletion completes, correlated with the migration record. The deletion obligation itself is specified in clause 10.5.*
- *A CAB verifies this requirement by reviewing the documented deletion-confirmation handling and confirming that the recorded verification outcome is marked unconfirmed when the source device is disconnected during deletion. Where feasible, the CAB may also complete a migration on test devices, inspect the recorded verification outcome, and repeat the migration with the source device disconnected during deletion to confirm that the outcome is recorded as unconfirmed.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

MIG-10.6-02: [CONDITIONAL] Where the deletion of key material and personal data from the source Wallet Unit has not been confirmed within a period defined and documented by the Wallet Provider, the Wallet Provider shall revoke the source Wallet Unit irrespective of that confirmation.

Guidelines

- *A source device that never reconnects cannot confirm deletion. Revocation after a defined period ensures that an unconfirmed source Wallet Unit does not remain valid indefinitely.*
- *Where revocation waits for a confirmation that never arrives, a device that was lost, sold, or retained by an attacker keeps a valid Wallet Unit with usable key material, and the migration leaves two live Wallet Units for one Wallet User.*
- *The defined period is short enough to bound the exposure and long enough to accommodate a Wallet User who simply has not switched the old device on. Revocation of the source Wallet Unit on completion of migration is specified in clause 10.2.*
- *A CAB verifies this requirement by reviewing the documented period and confirming that a source Wallet Unit is revoked once the period has elapsed without the source device being reconnected. Where feasible, the CAB may also complete a migration in which the source device is never reconnected and confirm that the source Wallet Unit is revoked once the period has elapsed.*

MIG-10.6-03: [CONDITIONAL] Where the deletion of key material and personal data from the source Wallet Unit has been confirmed under **MIG-10.6-01**, the Wallet Provider shall revoke the source Wallet Unit if it has not already been revoked.

Guidelines

- *MIG-9.6-01 requires the Wallet Provider to verify and record whether deletion on the source device completed. This requirement ties a confirmed deletion outcome directly to revocation of the source Wallet Unit, alongside* **MIG-10.6-02***, which revokes the source Wallet Unit when deletion is not confirmed within a defined period. Between the two, whatever the verification outcome, the source Wallet Unit does not remain valid once its data is gone or once the confirmation period has lapsed.*
- *Without this requirement, a source Wallet Unit whose deletion is confirmed could still be left in a valid state. A Wallet Unit that presents as valid and recognised after its holder has moved to a new device and its local data is gone is an exploitable inconsistency between the device's actual state and its ecosystem-visible status, with no offsetting benefit to the Wallet User.*
- *The condition "if it has not already been revoked" makes the requirement idempotent: where revocation of the source Wallet Unit was already triggered on completion of migration, this requirement is satisfied by that earlier revocation and needs no further action; where the source Wallet Unit instead reached this point through the decommissioning flow of clause 10.5 without an explicit finalisation step, confirmed deletion is itself the trigger for revocation.*
- *A CAB verifies this requirement by reviewing the documented decommissioning path in clause 10.5 and confirming that, once deletion on the source device is confirmed, the source Wallet Unit's status changes to revoked without further Wallet User action, and that where the source Wallet Unit was already revoked no conflicting or duplicate revocation attempt is made. Where feasible, the CAB may also complete a migration through the clause 10.5 decommissioning path and confirm this behaviour.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

10.7 Recovery to a New Device When the Source Device Is Unavailable

MIG-10.7-01: [CONDITIONAL] Where the source Wallet Unit is no longer accessible to the Wallet User, the Wallet Provider shall enable the Wallet User to re-establish the Wallet Unit on a new device by restoring a Migration Object, without requiring any participation by the source device.

Guidelines

- *This is the recovery path for a lost, stolen, broken, or otherwise unreachable source device. The Wallet User brings the Migration Object they hold to a new device and re-establishes the Wallet Unit there; nothing is asked of the old device, because it cannot respond. The restore mechanics are those of clause 6.6.*
- *Without this path, a Wallet User whose only device is gone would be stranded - unable to migrate in the ordinary way (which needs the source device) and left to start over entirely, or worse, with an old Wallet Unit still live on a device now in someone else's hands.*
- *The recovery reuses the Migration Object restore and re-issuance flow of clause 6.6; because device-bound keys never leave the device that created them, the credentials are re-issued on the new device rather than transferred. Identity re-proofing and revocation of the source unit are covered by the requirements that follow.*
- *A CAB verifies this requirement by reviewing the documented recovery flow and confirming that a Wallet Unit can be re-established from a Migration Object with no action by the source device, for instance by inspecting the flow design and, where feasible, by performing a recovery on a new device while the source device is kept offline.*

MIG-10.7-02: The Wallet Provider shall require identity proofing at the assurance level applicable to initial PID issuance before any PID credential is re-issued during a recovery performed under this clause.

Guidelines

- *A recovery to a new device re-establishes a strong identity means; it is therefore gated by the same identity proofing as a first issuance, rather than trusting possession of the Migration Object alone.*
- *If possession of the Migration Object were sufficient, anyone who obtained a copy of it and guessed or learned its password could stand up the Wallet User's identity on a device of their own; requiring full proofing ties the recovery back to the real person.*
- *The proofing is the same as for initial PID issuance under clause 8. This requirement concerns only the identity check on recovery; the restore of non-device-bound data follows clause 6.6.*
- *A CAB verifies this requirement by reviewing the recovery flow and confirming that PID re-issuance is preceded by identity proofing at the initial-issuance assurance level, for instance by inspecting the flow and proofing records and, where feasible, by attempting a recovery without valid proofing and confirming that no PID is re-issued.*

MIG-10.7-03: [CONDITIONAL] Where a recovery under this clause is performed and the source Wallet Unit is managed by the same Wallet Provider, the Wallet Provider shall revoke the source Wallet Unit, treating the Wallet User’s assertion that the source device is no longer under their control as the trigger for that revocation.

Guidelines

- *Because a recovery under this clause is undertaken precisely when the source device is out of the Wallet User’s control, a source Wallet Unit managed by the same Wallet*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Provider is revoked as part of the recovery rather than left to time out. The Wallet User's act of recovering to a new device is taken as the signal that the old unit is no longer theirs to use.

- *If the source unit were left valid, a lost or stolen device would keep a usable Wallet Unit in the hands of whoever now holds it, at the same time as the Wallet User stands up a new one — exactly the two-live-units exposure the migration controls exist to prevent, but now with the old device outside anyone's supervision.*
- *Deletion on the source device cannot be confirmed here because that device is unreachable, so revocation does not wait for the confirmation or the time-out of clause 10.6; the recovery itself is the trigger. Where the source Wallet Unit is managed by a different Wallet Provider, its revocation is handled under the following requirement instead. Revocation follows clause 12.10.612*
- *A CAB verifies this requirement by reviewing the recovery flow and confirming that completing a recovery revokes a source Wallet Unit managed by the same Wallet Provider without waiting for source-device confirmation, for instance by inspecting the flow and revocation records and, where feasible, by performing a recovery and confirming the source unit's status becomes revoked.*

MIG-10.7-04: [CONDITIONAL] Where a recovery under this clause is performed and the source Wallet Unit is managed by a different Wallet Provider, the Wallet Provider shall give the Wallet User the best possible instructions on the actions the Wallet User should undertake in order to get the source Wallet Unit revoked.

Guidelines

- *Where the Wallet User recovers onto a Wallet Unit operated by one Wallet Provider while the lost source Wallet Unit is managed by a different Wallet Provider, the Wallet Provider gives the Wallet User the best possible instructions on how to get that source Wallet Unit revoked. A recovery can cross providers in the same way a migration can, so the source unit is not necessarily one this Wallet Provider can act on directly.*
- *A Wallet User who cannot revoke a lost Wallet Unit held at another provider, and receives no guidance, might leave it active, so that a device now outside their control keeps usable credentials — the same lost-device exposure, left unresolved because the provider that performed the recovery is not the one that can revoke the source.*
- *The Wallet Provider cannot revoke a Wallet Unit it does not manage, so it directs the Wallet User to the steps and the other provider's channels needed to obtain revocation there. This mirrors the decommissioning handling of clause 10.5 where a migration is to a different Wallet Provider. Revocation, once obtained, follows clause 12.*
- *A CAB verifies this requirement by performing a recovery in which the source Wallet Unit is managed by a different provider and confirming that the Wallet User is given actionable instructions on how to obtain that revocation, for instance by inspecting the recovery flow and the guidance presented to the Wallet User.*

MIG-10.7-05: The Wallet Provider shall apply to the re-establishment of the Wallet Unit on the new device under this clause the same new device security verification and re-establishment controls that apply to a migration, as set out in clauses 10.3 and 10.4.

Guidelines

- *A recovery re-establishes the Wallet Unit on a new device just as a migration does, so the same conditions apply before the new Wallet Unit is treated as established: the new device security verification of clause 10.3, and the re-establishment controls of clause 10.4 — a new Wallet Instance Attestation and Key Attestation, device binding on a key pair freshly generated on the new device with no device-bound private key*

carried over, and authentication factors set up on the new device to the standard required at activation.

- *If recovery skipped these checks, a Wallet Unit could be re-established on a device that does not meet the installation security baseline, or on attestations and keys never verified against the new hardware — admitting a weaker or attacker-controlled device through the recovery path precisely when the ordinary migration checks are otherwise absent because the source device cannot take part.*
- *The new device security verification and re-establishment of clauses 10.3 and 10.4 are carried out against the new device during a recovery exactly as during a migration, the only difference being that nothing is expected from the source device. A new device that fails the verification does not complete the recovery; the lost source Wallet Unit is dealt with by the revocation requirements of this clause and by the Wallet User's own right to seek revocation under clause 12, independently of whether re-establishment on a new device succeeds.*
- *A CAB verifies this requirement by reviewing the recovery flow and confirming that the new device security verification and the re-establishment controls of clauses 10.3 and 10.4 are applied before a Wallet Unit is re-established through recovery, for instance by inspecting the recovery flow design and, where feasible, by attempting a recovery onto a device that fails the security verification and confirming that re-establishment does not complete.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

11 Lifecycle Event: Uninstallation

11.1 Wallet User-Initiated Uninstallation

UNINST-11.1-01: The Wallet Provider shall ensure that the Wallet Unit requires an explicit confirmation step from the Wallet User before proceeding with uninstallation and presents the Wallet User with a clear statement of the consequences of uninstallation, including the irreversible loss of all key bound credentials stored in the Wallet Unit.

Guidelines

- *Before uninstalling, the Wallet Unit requires the Wallet User to confirm explicitly and shows a clear statement of the consequences, including the irreversible loss of all key-bound credentials held in the Wallet Unit.*
- *Without an explicit, informed confirmation, a Wallet User could uninstall on impulse or by mistake and only afterwards discover that key-bound credentials — which cannot be recovered — were destroyed.*
- *The consequence statement makes clear which data is lost and that the loss of key-bound credentials is irreversible; uninstallation proceeds only after the Wallet User acts on that confirmation step.*
- *A CAB verifies this requirement by starting uninstallation on a test Wallet Unit and confirming that a consequence statement and an explicit confirmation step are presented before it proceeds.*

UNINST-11.1-02: The Wallet Provider shall, prior to completing the Wallet Instance uninstallation process, inform the Wallet User that all PID credentials, attestations and transaction logs stored in the Wallet Unit will be permanently deleted and are not recoverable after uninstallation, and shall require explicit Wallet User confirmation before proceeding.

Guidelines

- *The Wallet User warning is presented at a step within the uninstallation flow that allows the Wallet User to cancel and take alternative action, such as performing a migration or backing up recoverable attestations and transaction logs. A warning shown only after uninstallation has begun does not satisfy this requirement.*
- *A Wallet User who uninstalls without understanding that key-bound credentials cannot be recovered could destroy their means of identification and have to repeat full issuance for every credential, discovering the loss only when it is irreversible.*
- *PID credentials bound to the Wallet Unit's WSCD are cryptographically irrecoverable after uninstallation and WSCD wipe. The Wallet User warning reflects this fact so that the Wallet User can make an informed decision before proceeding.*
- *A CAB verifies this requirement by reviewing the uninstallation flow and confirming that a data loss warning with an explicit confirmation step is present, and that cancellation of the confirmation halts the uninstallation process without deleting any credentials.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

UNINST-11.1-03: The Wallet Provider shall ensure that, prior to completing the Wallet Instance uninstallation process, an updated Migration Object is available in the storage location selected by the Wallet User, that the Wallet User confirms to still have access to that location and verify that the Wallet User still has knowledge of the Migration Object.

Guidelines

- *Before uninstallation completes, the Wallet Unit checks that an up-to-date Migration Object exists in the Wallet-User-selected storage location, that the Wallet User confirms they still have access to that location, and that the Wallet User still holds the knowledge needed to use the object.*
- *A Wallet User who uninstalls believing they can recover later could find the Migration Object missing, the storage location no longer accessible, or the decryption knowledge lost — and, with key-bound credentials gone, no way back.*
- *These checks are performed as a pre-completion gate: the presence of a current object, confirmed access to its location, and retained knowledge of it are each established before the Wallet Unit finishes uninstalling. The handling when a check fails is covered in the following requirement.*
- *A CAB verifies this requirement by running uninstallation with each check satisfied and confirming completion, and by removing access to the stored object and confirming the check detects it.*

UNINST-11.1-04: [CONDITIONAL] If one of the checks in **UNINST-11.1-03** is not met, the Wallet Provider shall ensure that Wallet Unit uninstallation only proceeds after renewed confirmation by the Wallet User.

Guidelines

- *Where one of those pre-completion checks is not met, the Wallet Unit only proceeds with uninstallation after the Wallet User has confirmed again, in full knowledge that recovery might not be possible.*
- *Proceeding automatically when a recovery check has failed would let a Wallet User destroy key-bound credentials with no viable Migration Object, turning a routine uninstallation into permanent, unintended loss.*
- *A failed check does not silently block or silently proceed; it surfaces to the Wallet User, who gives a renewed confirmation before uninstallation continues.*
- *A CAB verifies this requirement by forcing one of the recovery checks to fail and confirming that uninstallation halts until the Wallet User provides a renewed confirmation.*

11.2 Pre-Uninstallation Security Measures

UNINST-11.2-01: The Wallet Provider shall ensure that all active sessions and pending transactions within the Wallet Unit are terminated before the uninstallation process begins.

Guidelines

- *All active sessions and any pending transactions in the Wallet Unit are ended before the uninstallation process begins.*
- *Uninstalling while a presentation or transaction was still in flight could leave a relying party with an incomplete or ambiguous result, or leave partial state behind that complicates clean deletion.*
- *The Wallet Unit closes open sessions and settles or cancels pending transactions as the first step of uninstallation, so that deletion operates on a quiescent state.*
- *A CAB verifies this requirement by reviewing the documented uninstallation behaviour and confirming that an active session or transaction is terminated before deletion*

begins. Where feasible, the CAB may also initiate uninstallation while a session or transaction is active and confirm that these are terminated before deletion begins.

UNINST-11.2-02: The Wallet Provider shall ensure that the Wallet Provider backend is notified of the uninstallation event before or upon completion of the uninstallation process, enabling the Wallet Provider to initiate appropriate deregistration or revocation actions.

Guidelines

- *The Wallet Provider backend is told of the uninstallation before or as it completes, so that the Wallet Provider can carry out any needed deregistration or revocation.*
- *If the backend were never informed, the Wallet Unit could be gone from the device while the ecosystem still treated it as live, leaving its attestations valid and unrevoked after the device-side data was destroyed.*
- *Notification reaches the backend at or before completion of uninstallation and triggers the Wallet Provider's deregistration or revocation handling; the confirmation seen by the Wallet User is covered later in this clause.*
- *A CAB verifies this requirement by uninstalling a test Wallet Unit and confirming that the backend receives the uninstallation notification and can act on it.*

11.3 Data Cleanup and Deletion

UNINST-11.3-01: The Wallet Provider shall ensure that all private keys associated with the Wallet Unit, including keys attested in a Key Attestation, credential-binding keys, and Wallet User authentication keys, are irrecoverably deleted from the WSCD and from all application storage locations during uninstallation.

Guidelines

- *During uninstallation, all private keys associated with the Wallet Unit — attested keys, credential-binding keys, and Wallet User authentication keys — are irrecoverably deleted from the secure cryptographic device and from every application storage location.*
- *Private keys left behind after uninstallation could be recovered from the device by a later holder or a forensic attacker and used to impersonate the Wallet User or present their credentials.*
- *Deletion issues the key-destruction operations to the secure cryptographic device and clears any application-layer key storage, covering every category of private key rather than only those held in one location.*
- *A CAB verifies this requirement by uninstalling a test Wallet Unit and confirming, by inspection of the device, that no associated private key material remains recoverable.*

UNINST-11.3-02: The Wallet Provider shall ensure that all PID credentials and attestations stored in the Wallet Unit are irrecoverably deleted during uninstallation.

Guidelines

- *All PID credentials and attestations held in the Wallet Unit are irrecoverably deleted during uninstallation.*
- *Credential data left on the device after uninstallation could be recovered and would expose the Wallet User's identity attributes and attestation contents to whoever next obtained the device.*
- *Deletion removes the credential payloads from every on-device store in which they were held, so that no readable copy remains after uninstallation.*
- *A CAB verifies this requirement by reviewing the documented deletion steps of the uninstallation procedure and the storage locations they cover for held credentials,*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

confirming that no credential data remains recoverable. Where a forensic examination is feasible, the CAB may also uninstall a test Wallet Unit holding credentials and inspect the device to confirm that no credential data remains recoverable.

UNINST-11.3-03: The Wallet Provider shall ensure that all cached data, temporary files, session tokens, and application state related to Wallet Unit operations are irrecoverably deleted during uninstallation.

Guidelines

- *All cached data, temporary files, session tokens, and application state relating to Wallet Unit operations are irrecoverably deleted during uninstallation.*
- *Residual caches, tokens, or state could reveal the Wallet User's activity or, in the case of session tokens, allow continued access to backend services after the Wallet Unit was supposedly gone.*
- *Deletion extends beyond the primary credential and key stores to the transient artefacts the Wallet Unit accumulates, so that operational residue is not left behind.*
- *A CAB verifies this requirement by uninstalling a test Wallet Unit and confirming that cached data, temporary files, session tokens, and application state have been removed.*

UNINST-11.3-04: The Wallet Provider shall ensure that the WSCA and WSCD are cleared of all key material, configuration data, and application-specific data stored within them as part of the uninstallation process.

Guidelines

- *As part of uninstallation, the secure cryptographic application and secure cryptographic device are cleared of all key material, configuration data, and application-specific data held within them.*
- *If the secure hardware retained key material or configuration after uninstallation, a later installation or a forensic attacker could recover cryptographic secrets that were meant to be destroyed with the Wallet Unit.*
- *The uninstallation process invokes the operations that wipe the Wallet Unit's content from the secure cryptographic application and device, not only from ordinary application storage.*
- *A CAB verifies this requirement by uninstalling a test Wallet Unit and confirming that the secure cryptographic application and device no longer hold any Wallet-Unit key material, configuration, or data.*

UNINST-11.3-05: The Wallet Provider shall ensure that, upon Wallet Instance uninstallation, all operational records and transaction logs associated with the uninstalled Wallet Unit that are held in the Wallet Provider's backend systems are either deleted or anonymised in accordance with the applicable data protection requirements, except where those records are required to be retained under a legal obligation, in which case the retained records shall be limited to what is strictly necessary, retained only for the minimum required period, and access-controlled to prevent use for any purpose other than compliance with that obligation.

Guidelines

- *The retention and disposal of operational records is governed by data protection regulations applicable to the Wallet Provider in its jurisdiction. Records that serve no purpose other than supporting wallet operation — such as transaction logs generated during normal wallet use — are not retained beyond the Wallet Unit's active lifetime unless a specific legal basis requires retention. Records subject to mandatory retention*

are held only for the minimum required period and under access controls that limit their use to the specific compliance purpose.

- *Without this control, the Wallet Provider could retain detailed transaction logs or operational records of a Wallet User's wallet use indefinitely after uninstallation, creating a risk that the data is used for purposes beyond the Wallet User's original consent — for example, profiling, secondary use, or disclosure to third parties. Indefinite retention of operational records after the termination of wallet operation is inconsistent with the data minimisation and storage limitation principles applicable to personal data.*
- *Anonymisation, where used in lieu of deletion, must reduce the data to a form from which the individual cannot be re-identified using reasonably available means. Pseudonymisation does not constitute anonymisation for this purpose. Wallet Providers with data retention obligations should document, for each retained record category: the legal basis, the retention period, the retention trigger, and the deletion trigger. The GDPR-compliant retention of audit logs after revocation is addressed separately in the revocation lifecycle event.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented data management policy and confirming that it includes procedures for handling transaction logs and operational records upon uninstallation, with enumerated record categories, documented legal bases, defined retention periods, and deletion mechanisms. The CAB may additionally verify the policy's implementation by reviewing records relating to previously uninstalled test Wallet Units and confirming deletion or anonymisation in accordance with the stated policy.*

11.4 Revocation and Deregistration

UNINST-11.4-01: The Wallet Provider shall revoke the Wallet Instance Attestation and the Key Attestation associated with a Wallet Unit at the time of Wallet Instance uninstallation regardless of whether the Wallet User intends to install the Wallet Instance again on the same or a different device.

Guidelines

- *Revocation of the WUA upon uninstallation ensures that the Wallet Unit cannot be used for credential presentations after the Wallet Instance has been removed from the device. Uninstallation terminates the Wallet Unit's operational status. If the Wallet User wishes to use an EUDIW solution after uninstallation, they must install the Wallet Instance and complete the activation process to obtain a new Wallet Unit with a new WUA — the revoked Wallet Unit cannot be reused. Consistent with* **REV-12.2-08***, this revocation applies to every Wallet Instance Attestation issued to the Wallet Unit, including those whose technical validity period has expired but whose revocation status the Wallet Provider still maintains.*
- *Without revocation upon uninstallation, the WUA remains valid for the remainder of its validity period after the Wallet Instance is removed from the device. A third party who recovers private key material from device storage before it is securely deleted, or from an unprotected backup, could use the valid WUA to make fraudulent credential presentations. The period between uninstallation and natural WUA expiry represents a window of potential fraudulent use that revocation eliminates.*
- *Revocation initiation occurs as part of the uninstallation flow, prior to the secure deletion of key material from the WSCD. Where the operating system performs uninstallation without Wallet User interaction or without invoking Wallet Provider processes (for example, automatic uninstallation by the device management system),*

the Wallet Provider establishes a mechanism for detecting such events and processing the associated revocation.

- *A CAB verifies this requirement by reviewing the Wallet Provider's documentation to confirm that the maximum revocation publication delay is defined and monitored, and by checking the Wallet Unit Attestation status list to confirm that a WUA revocation is published within the defined maximum delay. Where feasible, the CAB may also uninstall the Wallet Instance from a test device and attempt to make a presentation using key material from the uninstalled Wallet Unit, confirming that the WUA is rejected as revoked by the status check.*

11.5 Verification of Complete Removal

UNINST-11.5-01: The Wallet Provider shall provide the Wallet User with confirmation that the uninstallation process has completed, including confirmation that the Wallet Unit has been deregistered with the Wallet Provider and has been revoked.

Guidelines

- *On completion, the Wallet Unit gives the Wallet User confirmation that uninstallation has finished, including that the Wallet Unit has been deregistered with the Wallet Provider and revoked.*
- *Without an explicit completion confirmation, a Wallet User could be unsure whether their credentials were actually removed and their Wallet Unit disabled, and might leave a partially removed Wallet Unit in place believing the opposite.*
- *The confirmation reports both the device-side completion and the backend outcome — deregistration and revocation — so that the Wallet User knows the Wallet Unit is fully retired.*
- *A CAB verifies this requirement by completing uninstallation and confirming that the Wallet User is shown confirmation covering deregistration and revocation.*

UNINST-11.5-02: The Wallet Provider shall ensure that the uninstallation process results in no recoverable Wallet Unit data remaining on the device, including private keys, credentials, cached data, and application configuration files.

Guidelines

- *Uninstallation leaves no recoverable Wallet Unit data on the device, including private keys, credentials, cached data, and application configuration files.*
- *Any recoverable residue after uninstallation — keys, credentials, caches, or configuration — could be reconstructed by a later holder or forensic attacker into the Wallet User's identity data or usable credentials.*
- *This requirement is the end-state check over the deletion steps of this clause: after uninstallation, inspection of the device finds no recoverable Wallet Unit data of any listed category.*
- *A CAB verifies this requirement by reviewing the documented deletion steps of the uninstallation procedure and the Wallet Unit data they cover, confirming that no recoverable Wallet Unit data remains. Where a forensic examination is feasible, the CAB may also inspect the device after uninstallation to confirm that no recoverable Wallet Unit data remains.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

12 Lifecycle Event: Revocation (Permanent)

12.1 Revocation Triggers and Conditions

REV-12.1-01: The Wallet Provider shall implement mechanisms to detect security breaches affecting Wallet Units, including monitoring for indicators of device compromise, and shall initiate revocation procedures upon confirmed detection of a breach affecting a Wallet Unit.

Guidelines

- *The Wallet Provider has mechanisms to detect security breaches affecting Wallet Units, including watching for indicators of device compromise, and begins revocation once a breach affecting a Wallet Unit is confirmed.*
- *Without breach detection and a revocation trigger, a Wallet Unit known to be compromised could stay valid, allowing an attacker to continue presenting the Wallet User's credentials unchallenged.*
- *Detection draws on the indicators available to the Wallet Provider; on confirmation of a breach affecting a Wallet Unit, the revocation procedures of this chapter are initiated. The specific interactions monitored are described in clause 13.*
- *A CAB verifies this requirement by reviewing the detection mechanisms and confirming that a confirmed breach affecting a test Wallet Unit triggers revocation.*

REV-12.1-02: The Wallet Provider shall revoke a Wallet Unit when required to do so by applicable law or by a competent supervisory authority, within the timeframes mandated by the applicable legal requirement.

Guidelines

- *The Wallet Provider revokes a Wallet Unit when law or a competent supervisory authority requires it, within the timeframe the applicable legal requirement sets.*
- *If a legally mandated revocation were not carried out, or not within the required time, the Wallet Provider would be in breach of its obligations and a Wallet Unit that authorities have required to be stopped would remain usable.*
- *The Wallet Provider maintains a process to receive and act on legal and supervisory revocation requirements and to meet the mandated timeframes for each.*
- *A CAB verifies this requirement by reviewing the process for handling legally mandated revocations and confirming that it provides for action within the applicable statutory timeframes.*

REV-12.1-03: The Wallet Provider shall establish and maintain a documented procedure for accepting and processing requests for permanent revocation of a Wallet Unit submitted by an authorised party other than the Wallet Unit holder, including requests submitted in consequence of the death or legal incapacity of the natural person to whom the Wallet Unit is issued, and shall provide a mechanism that enables such requests to be submitted and verified without requiring participation of the Wallet Unit holder.

Guidelines

- *Permanent revocation may need to be initiated by parties other than the Wallet Unit holder — including legal representatives, next of kin acting under applicable law, or competent authorities — when the Wallet Unit holder dies or loses legal capacity. The revocation procedure accommodates these cases without requiring the Wallet Unit holder to authenticate, since by definition that is not possible.*
- *Without this control, a deceased person's Wallet Unit may remain in a valid state indefinitely, enabling third parties who gain access to the device — including malicious*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

actors — to use the wallet for fraudulent transactions or identity claims. The absence of a revocation mechanism accessible to authorised third parties prevents timely deactivation of the Wallet Unit after the holder's death or incapacity.

- *Verification of an authorised third party's right to request revocation may be achieved through a notarised document, a death certificate, a court order establishing legal incapacity, or another instrument recognised under applicable national law. The Wallet Provider's procedure specifies which instruments are acceptable and the identity verification steps applicable to the requestor. The procedure does not need to be automated — a manual review and processing path is acceptable provided the procedure is documented and consistently applied.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented procedure for third-party revocation requests and confirming that: (i) the procedure exists and covers the death and legal incapacity scenarios; (ii) it specifies acceptable verification instruments; (iii) it does not require participation by the Wallet Unit holder. The CAB may additionally submit a simulated third-party revocation request with appropriate documentation and verify that the request is processed and the Wallet Unit is revoked.*

REV-12.1-04: The Wallet Provider shall establish processes for Wallet Users or other competent parties to notify suspected device compromise.

Guidelines

- *The Wallet Provider provides ways for Wallet Users and other competent parties to report a suspected device compromise.*
- *If there were no route to report a suspected compromise, the Wallet User who first notices something wrong would have no way to raise the alarm, and the Wallet Provider would learn of the problem only once damage had been done.*
- *The reporting routes are reachable by the Wallet User and by other competent parties, and feed into the Wallet Provider's detection and revocation.*
- *A CAB verifies this requirement by confirming that documented reporting routes exist for Wallet Users and other competent parties and that a submitted report reaches the Wallet Provider's revocation process.*

REV-12.1-05: The Wallet Provider shall revoke a Wallet Unit for which credible evidence of fraudulent use or sufficient indication of suspected compromise has been identified and shall record the basis and supporting evidence for the revocation decision.

Guidelines

- *The Wallet Provider revokes a Wallet Unit for which there is credible evidence of fraudulent use or sufficient indication of suspected compromise, and records the basis and supporting evidence for that decision.*
- *Without acting on credible evidence of fraud or compromise, the Wallet Provider would leave an attacker-controlled Wallet Unit in service; without recording the basis, a revocation could not be justified afterwards or distinguished from an unfounded one.*
- *The decision rests on credible evidence or sufficient indication, and the Wallet Provider keeps a record of that basis and the supporting evidence so the decision is accountable and reviewable.*
- *A CAB verifies this requirement by reviewing revocation records and confirming that revocations on grounds of fraud or suspected compromise are supported by a recorded basis and evidence.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

REV-12.1-06: The Wallet Provider shall ensure that a Wallet User can initiate revocation of their own Wallet Unit through a means that does not depend on access to the Wallet Unit's device, on authentication factors or credentials that are typically kept or carried together with that device, or on any secret or credential that the Wallet User would typically only store in a fixed location such as their home.

Guidelines

- *There is at least one route by which the Wallet User can trigger revocation of their own Wallet Unit that does not need the device itself, does not rely on something normally lost with it — a revocation code stored on or beside the device, or an identity document carried in the same bag as the phone — and does not rely on anything the Wallet User could reach only by first returning to a fixed place such as home. The route works from wherever the Wallet User happens to be when they need it.*
- *The scenario this addresses is a device stolen away from home, often together with the Wallet User's identity documents — a bag taken abroad. If the only way to revoke needs the phone, needs a passport or code that was taken with it, or needs a code the Wallet User keeps safely at home, the Wallet User cannot stop the wallet from being abused while travelling, and being unable to revoke leaves it open to attack for far longer than any denial-of-service would cost.*
- *Acceptable approaches include a revocation route knowledge the Wallet User carries in memory (for instance answers on questions that only the user should be able to give), or re-verification by the Wallet Provider through channels that need no pre-stored token.*
- *A CAB verifies this requirement by reviewing the Wallet User-initiated revocation design and confirming that at least one route does not depend on the device, on credentials typically lost with it, or on a secret the Wallet User would keep only at a fixed location such as home, for instance by inspecting the design and, where feasible, by initiating revocation from a different device, and from a different location, without the original authentication means.*

REV-12.1-07: The Wallet Provider shall, after authenticating the PID Provider as the sender, revoke a Wallet Unit when the PID Provider forwards a request for revocation of that Wallet Unit on behalf of the person in whose name a PID was issued to it.

Guidelines

- *The Wallet Provider acts on a revocation request that the PID Provider forwards for the person.*
- *A person recognises a stolen Wallet Unit from an overview at the PID Provider, and a Wallet Provider that ignores the forwarded request leaves the Wallet Unit active.*
- *The request is received through an authenticated interface between the PID Provider and the Wallet Provider. The revocation then follows clause 11.2, including* **REV-12.2-02***.*
- *A CAB verifies this requirement by reviewing the interface and its authentication and by examining records of requests received and the revocations that followed.*

REV-12.1-08: The Wallet Provider shall treat a notice from the PID Provider of the decease of a Wallet Holder as a request under **REV-12.1-03** for permanent revocation of the Wallet Unit to which the notice relates.

Guidelines

- *A decease notice from the PID Provider has the same effect as a request submitted by an authorised third party.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *Without it, a deceased person's Wallet Unit stays active until someone else asks for revocation, and can be used for fraud.*
- *The Wallet Provider authenticates the sender as in* **REV-12.1-07** *and does not require participation of the holder.*
- *A CAB verifies this requirement by reviewing the procedure and by examining records of past notices.*

12.2 Revocation Procedures

REV-12.2-01: The Wallet Provider shall ensure that revocation requests submitted by parties other than the Wallet User are subject to verification of the authority of the requesting party to trigger revocation before the request is acted upon.

Guidelines

- *A revocation request from anyone other than the Wallet User is acted on only after the Wallet Provider has verified that the requesting party has the authority to trigger revocation.*
- *The control guards against a denial-of-service in which a party with no standing has a Wallet User's Wallet Unit revoked, or the service is disrupted by spurious requests. It is balanced against timeliness: where verifying authority - or, for the Wallet User's own request, authenticating - imposes a threshold a legitimate requester cannot meet in time, the harm of a Wallet Unit that stays active and open to attack can far outweigh the harm of an unwarranted revocation. The accessibility of the Wallet User's own revocation path under adverse conditions is the subject of a separate requirement in clause 12.1.*
- *The Wallet Provider establishes the requesting party's authority — legal standing or a defined role — before acting on a third-party revocation request, distinguishing it from a request by the Wallet User themselves.*
- *A CAB verifies this requirement by submitting third-party revocation requests with and without demonstrated authority and confirming that only the authorised request is acted upon.*

REV-12.2-02: The Wallet Provider shall ensure that a revoked Wallet Unit is disabled within a defined maximum timeframe following the revocation decision.

Guidelines

- *A revoked Wallet Unit is disabled within a defined maximum time after the revocation decision.*
- *If disabling could be delayed indefinitely, a Wallet Unit already decided to be revoked — perhaps because it is compromised — would stay usable in the gap, and the revocation would not achieve its purpose in time.*
- *The Wallet Provider bounds the interval between the revocation decision and the effective disabling of the Wallet Unit by a defined maximum, and operates so that disabling occurs within it.*
- *A CAB verifies this requirement by reviewing the documented revocation mechanism and confirming that a triggered revocation disables the Wallet Unit within the defined maximum timeframe, corroborating this against revocation records. Where feasible, the CAB may also trigger a revocation and confirm that the Wallet Unit is disabled within the defined maximum timeframe.*

REV-12.2-03: The Wallet Provider shall document and enforce that maximum permissible delay between the revocation decision and the effective disabling of the Wallet Unit.

Guidelines

- *The Wallet Provider documents the maximum permissible delay between a revocation decision and the effective disabling of the Wallet Unit, and enforces it.*
- *An undocumented or unenforced delay would leave the timeliness of revocation undefined, so that neither the Wallet User nor an auditor could tell how long a revoked Wallet Unit might remain usable.*
- *The maximum delay is written down as a defined value and the Wallet Provider's operations are arranged to keep within it, making the disabling timeframe of the preceding requirement concrete and auditable.*
- *A CAB verifies this requirement by reviewing the documented maximum delay and confirming, against revocation records, that the effective disabling times observed fall within it.*

REV-12.2-04: The Wallet Provider shall ensure that, upon revocation of a Wallet Unit, the revocation status of the associated Wallet Instance Attestation and Key Attestation is published to the applicable revocation status mechanism without undue delay, enabling parties interacting with the Wallet Unit to detect the revocation prior to accepting transactions with the revoked Wallet Unit.

Guidelines

- *This requirement addresses the window between the moment a Wallet Unit is revoked and the moment that revocation becomes observable to parties querying the WUA revocation status. During this window a party checking the status mechanism would not detect the revocation and would treat the Wallet Unit as valid. The requirement obliges the Wallet Provider to minimise this window by publishing the updated revocation status to the applicable mechanism as promptly as possible after the revocation decision is confirmed.*
- *Publication of the WUA revocation status is achieved through the status mechanism defined in the relevant ecosystem trust infrastructure.*
- *Relying parties that cache revocation status responses and check them at a lower frequency than the WUA revocation publishing interval may not detect revocation immediately. This is acceptable provided the Wallet Provider’s documented publishing latency falls within the agreed ecosystem parameters.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented maximum publishing delay and corroborating, against revocation records, that revocation status becomes observable through the applicable status mechanism within that delay. Where feasible, the CAB may also revoke a Wallet Unit and measure the time until the revocation status is observable, confirming it falls within the documented maximum publishing delay.*

REV-12.2-05: The Wallet Provider shall ensure that the Wallet Instance ceases to display the European Digital Identity Wallet Trust Mark referred to in [13] from the moment the Wallet Instance Attestation of that Wallet Unit is revoked.

Guidelines

- *The Trust Mark signals to the Wallet User, and to anyone the Wallet User shows the application to, that the wallet in use is a recognised European Digital Identity Wallet. Once the Wallet Unit is revoked that statement is no longer true and the mark is withdrawn.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *A revoked Wallet Unit that keeps displaying the mark misleads the Wallet User into continuing to rely on it, and can be used by an attacker in possession of the device to convince a third party in a face-to-face situation that a revoked wallet is still recognised.*
- *A conformant implementation ties the display of the mark to the current revocation state of the Wallet Instance Attestation rather than to a value cached at installation, so that the mark disappears at the next launch after revocation even when the Wallet Unit is offline at the moment of revocation.*
- *A CAB verifies this requirement by reviewing the documented Trust Mark behaviour and confirming that the Trust Mark is no longer displayed once a Wallet Unit is revoked. Where feasible, the CAB may also revoke a test Wallet Unit and confirm, on the device, that the Trust Mark is no longer displayed.*

REV-12.2-06: The Wallet Provider shall ensure that revocation of a Wallet Unit is permanent and irreversible, and shall not provide any mechanism, interface, process, or administrative function through which a permanently revoked Wallet Unit can be restored to an active or operational state.

Guidelines

- *Permanent revocation terminates the Wallet Unit's validity definitively. The Wallet Unit cannot be re-activated, re-registered, or otherwise returned to an operational state following permanent revocation. If the same natural person wishes to use an EUDIW solution after their Wallet Unit has been permanently revoked, they undergo the full installation and activation process to obtain a new Wallet Unit, which constitutes a new Wallet Unit rather than a restoration of the previously revoked one.*
- *Without this control, an administrative override or software interface that restores a revoked Wallet Unit would undermine the integrity of the revocation mechanism. An attacker who gains access to the Wallet Provider's backend systems — or an insider with administrative access — could reverse a revocation performed in response to a security compromise, re-enabling a Wallet Unit whose associated private key material or credentials may have been exposed to an adversary.*
- *Systems and procedures that would otherwise allow administrative restoration of revoked Wallet Units — such as database entries, administrative panels, or API endpoints capable of toggling revocation status — should be identified and their absence confirmed through audit. Where a Wallet Provider offers a re-issuance service enabling a Wallet User to obtain a new Wallet Unit after revocation, this is distinct from re-activation: re-issuance produces a new Wallet Unit with new WUA and new key material, not a restoration of the previously revoked Wallet Unit.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's system documentation and confirming the absence of any functionality that permits reversal of permanent revocation. The CAB also attempts to re-activate a test Wallet Unit that has been permanently revoked and confirms that no pathway — including administrative or technical — allows this. The CAB additionally reviews the Wallet Provider's access control documentation to confirm that no personnel role has the capability to reverse a permanent revocation.*

REV-12.2-07: The Wallet Provider shall ensure that the Wallet Instance Attestation issued to each Wallet Unit contains a reference to the revocation status mechanism maintained by the Wallet Provider, enabling relying parties and PID Providers to determine the current revocation status of the Wallet Unit at the time of any transaction.

Guidelines

- *The Wallet Unit Attestation (WUA) serves as the primary artefact by which relying parties and PID Providers verify the legitimacy and current status of a Wallet Unit. Including a reference to the revocation status mechanism in the WUA enables these parties to check the current revocation status at the point of transaction, rather than relying solely on the expiry date of the WUA. This is particularly relevant in the period between revocation and WUA expiry, during which the WUA remains technically valid but the Wallet Unit must not be accepted.*
- *Without this control, a relying party or PID Provider that receives a presentation from a revoked Wallet Unit cannot determine from the WUA alone where to check whether that Wallet Unit has been permanently revoked. This increases the risk that transactions are accepted from permanently revoked Wallet Units, undermining the intended effect of revocation and potentially enabling continued fraudulent use of a Wallet Unit whose private key material has been compromised.*
- *The revocation status mechanism reference is typically a URL pointing to a revocation status list, an OCSP endpoint, or an equivalent status service. The format and content of this reference are determined by the applicable ecosystem trust framework and credential format specification. The Wallet Provider maintains this endpoint and ensures it is accessible to relying parties and PID Providers without requiring authentication.*
- *A CAB verifies this requirement by inspecting the WUA of a test Wallet Unit and confirming the presence of a revocation status mechanism reference. The CAB then uses that reference to query the revocation status of the Wallet Unit and confirms that the response correctly reflects the Wallet Unit's current status, including after the test Wallet Unit has been permanently revoked. The CAB also confirms that the revocation status endpoint is publicly accessible without requiring authentication.*

REV-12.2-08: The Wallet Provider shall, whenever it revokes the Wallet Instance Attestation of a Wallet Unit — on revocation of the Wallet Unit under this clause, on uninstallation of the Wallet Instance, or on revocation of a source Wallet Unit during migration — set to revoked the revocation status of every Wallet Instance Attestation it has issued to that Wallet Unit, including any such attestation whose technical validity period has expired but whose revocation status the Wallet Provider still maintains, so that the revocation status reference recorded by a PID Provider or Attestation Provider at issuance reflects the revocation throughout the lifetime of the PID or attestation issued against it.

Guidelines

- *A Wallet Unit is issued many Wallet Instance Attestations over its lifetime through successive re-issuance under* **ACT-6.2-10***, each carrying its own revocation status reference under* **ACT-6.2-05***. A PID Provider or Attestation Provider detects revocation of the Wallet Unit through the revocation status reference of the specific Wallet Instance Attestation it validated at issuance. A Wallet Instance Attestation has a technical validity period of less than 24 hours under* **ACT-6.2-09***, while the PID or attestation it supports remains valid for far longer, so for most of that lifetime the recorded reference identifies a Wallet Instance Attestation that has passed its technical validity. Setting the revoked status on every Wallet Instance Attestation issued to the*

Wallet Unit, including expired ones whose revocation status remains maintained, keeps the recorded reference meaningful for the whole life of the PID or attestation.

- *Without this control, revocation of a Wallet Unit sets the revoked status only on the currently valid Wallet Instance Attestation. A PID Provider that checks the reference it recorded at issuance, which by then identifies an expired Wallet Instance Attestation, does not observe the revocation and continues to treat the Wallet Unit as valid. An attacker who retains a revoked Wallet Unit thereby keeps its already-issued PID acceptable until that PID separately expires or is revoked, defeating the purpose of the revocation.*
- *Acceptable approaches include recording, for each Wallet Unit, the status list entries of all Wallet Instance Attestations issued to it and setting every such entry to revoked in a single revocation action; and retaining those entries on the status list for as long as any PID or attestation issued against the Wallet Unit remains in use, independently of the technical validity period of the individual Wallet Instance Attestation.*
- *A CAB verifies this requirement by reviewing the Wallet Provider's documented revocation procedure and confirming that a single revocation action sets to revoked the status of every Wallet Instance Attestation issued to the Wallet Unit, including those past their technical validity period whose status is still maintained, and by inspecting revocation records for a revoked Wallet Unit to confirm that the status list entries of its earlier, expired Wallet Instance Attestations were also set. Where feasible, the CAB may issue to a test Wallet Unit more than one Wallet Instance Attestation, allow the earlier attestation to expire, revoke the Wallet Unit, and confirm that both the expired and the current entries reflect revocation within the maximum publication delay documented under* **REV-12.3-01**.

12.3 Impact on PIDs and Attestations

REV-12.3-01: The Wallet Provider shall ensure that the revocation status of the Wallet Instance Attestation and of the Key Attestation is published to the applicable attestation status list within a defined and documented maximum time period following the triggering event for revocation, and shall make that attestation status list available in a format and at a location that enables PID Providers and Attestation Providers to query the revocation status of any such attestation without requiring authenticated access to the status service.

Guidelines

- *PID Providers and Attestation Providers that have issued credentials to a Wallet Unit need to be able to determine whether that Wallet Unit's attestation has been revoked, in order to decide whether to revoke or suspend the credentials they issued. The primary mechanism for this determination is the Wallet Unit Attestation status list, which the Wallet Provider maintains and updates. Timely publication of the revocation status to this list enables the pull-based discovery model that allows PID Providers and Attestation Providers to act on the revocation without direct notification.*
- *A delayed update to the Wallet Unit Attestation status list creates a window during which PID Providers and Attestation Providers, querying the status list, incorrectly conclude that a revoked Wallet Unit's attestation is still valid. During this window, PID Providers may continue to issue or accept renewal requests from the revoked Wallet Unit, and relying parties may continue to accept credential presentations from it. The length of this window is directly determined by the Wallet Provider's publication delay.*
- *The maximum time period for revocation status publication is defined based on the operational requirements and risk profile of the Wallet Provider. Where revocation is triggered by a security compromise, the publication delay is minimised. The Wallet*

Provider documents the maximum publication delay for each trigger type and monitors compliance. The status list is accessible publicly — without authentication — to enable any PID Provider or Attestation Provider to query it.

- *A CAB verifies this requirement by reviewing the Wallet Provider's documented maximum revocation publication delay for each trigger type and confirming, against revocation records, that the updated revocation status is published on the status list within that delay and that the status list is accessible without authentication. Where feasible, the CAB may also trigger a test revocation, measure the time between the trigger event and publication of the updated status, and attempt to access the status list without authentication, confirming that the query succeeds and returns the correct status for the revoked Wallet Unit Attestation.*

REV-12.3-02: [CONDITIONAL] Where the Wallet Instance Attestation or the Key Attestation is issued in the mobile document format specified in [11], the Wallet Provider shall publish its revocation status by means of an attestation status list or an attestation revocation list as specified in [12].

Guidelines

- *The mechanism through which revocation status is published depends on the format in which the attestation was issued, because each format defines its own status representation. For the mobile document format both a status list and a revocation list are available.*
- *Where a Wallet Provider publishes status in a representation the receiving party cannot parse for the format at hand, that party cannot determine the revocation state and either accepts a revoked attestation or rejects a valid one, in both cases without detecting that the check itself failed.*
- *A conformant implementation selects the publication mechanism from the attestation format at issuance time and records that choice in the attestation itself, so that a receiving party knows where and how to look.*
- *A CAB verifies this requirement by determining the format of the attestations issued in production, retrieving the published status information, and confirming that its representation is the one specified for that format.*

REV-12.3-03: [CONDITIONAL] Where the Wallet Instance Attestation or the Key Attestation is issued in the selectively disclosable JSON Web Token verifiable credential format, the Wallet Provider shall publish its revocation status by means of an attestation status list as specified in [10].

Guidelines

- *For the selectively disclosable JSON Web Token format a status list is the only defined representation; a revocation list is not an available alternative.*
- *Where a revocation list is published for this format, a receiving party following the specification looks for a status list, does not find one, and is not able to proceed by lack of usable revocation check, so a possibly valid attestation is refused, leading to an unusable Wallet Unit.*
- *A conformant implementation publishes a status list and records its location and the index of the attestation within it in the attestation itself.*
- *A CAB verifies this requirement by retrieving the status information referenced by an attestation issued in this format and confirming that it is a status list in the specified representation.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

12.4 Data Deletion Requirements

REV-12.4-01: The Wallet Provider shall ensure that all private keys stored in the remote WSCD that are associated with a revoked Wallet Unit are irrecoverably deleted and that the revocation event is recorded in a tamper-evident audit log.

Guidelines

- *All private keys in the remote secure cryptographic device that belong to a revoked Wallet Unit are irrecoverably deleted, and the revocation event is written to a tamper-evident audit log.*
- *If a revoked Wallet Unit's server-held private keys were left in place, they could still be used to produce valid signatures for the Wallet User; without a tamper-evident log, a revocation could be quietly reversed or denied.*
- *On revocation, the Wallet Provider destroys the associated keys in the remote secure cryptographic device and records the event in a log whose entries cannot be altered undetectably.*
- *A CAB verifies this requirement by reviewing the documented server-side key handling and confirming that revocation of a Wallet Unit whose keys are held server-side deletes those keys and that a tamper-evident log entry records the revocation. Where feasible, the CAB may also revoke a test Wallet Unit whose keys are held server-side and confirm that those keys are deleted and that a tamper-evident log entry records the revocation.*

REV-12.4-02: The Wallet Provider shall ensure that, following permanent revocation of a Wallet Unit, all personal data associated with the revoked Wallet Unit that is held in the Wallet Provider's backend systems is deleted or anonymised in accordance with the applicable data protection requirements, except where those records are required to be retained under a legal obligation, in which case the retained data shall be limited to what is strictly necessary, retained only for the minimum required period, and access-controlled to prevent use for any purpose other than compliance with that obligation.

Guidelines

- *Personal data held by the Wallet Provider following revocation may include identity-related records generated during PID issuance, transaction logs, correspondence relating to the Wallet Unit's operation, and records of the revocation event itself. Following revocation, the legal basis for retaining personal data — typically the contractual relationship between the Wallet User and the Wallet Provider — terminates, triggering data subject rights including the right to erasure, except where a separate legal basis mandates retention.*
- *Without this control, the Wallet Provider may retain personal data associated with a permanently revoked Wallet Unit beyond the period for which there is a legal basis to do so. This exposes the data to risks of secondary use, unauthorised access, or data breaches affecting individuals who have terminated their relationship with the Wallet Provider — whether by choice or as a consequence of a security incident that triggered the revocation.*
- *Retention obligations that may apply after revocation include, but are not limited to, audit logs required by national e-government regulations, tax or financial records, and records required by anti-money laundering legislation. For each category of retained data, the Wallet Provider documents the specific legal basis, the retention period, and the deletion or anonymisation trigger. Anonymisation used as an alternative to deletion must meet a standard at which re-identification is not reasonably achievable using available means.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *A CAB verifies this requirement by reviewing the Wallet Provider's documented data retention policy for the post-revocation period and confirming that: (i) categories of retained data are enumerated with a documented legal basis and defined retention period for each; (ii) deletion or anonymisation is triggered at the end of the retention period; (iii) access to retained data is restricted to the specific compliance purpose. The CAB may additionally review records relating to previously revoked test Wallet Units to confirm that retention and deletion are applied in accordance with the documented policy.*

REV-12.4-03: The Wallet Provider shall retain audit logs related to Wallet Unit revocation for a period sufficient to support legal proceedings, supervisory audit, and incident investigation, and shall ensure that the retention period does not exceed the maximum period permitted under applicable data protection law.

Guidelines

- *The Wallet Provider keeps revocation audit logs long enough to support legal proceedings, supervisory audit, and incident investigation, but no longer than the maximum period the applicable data protection law allows.*
- *Logs discarded too soon would leave the Wallet Provider unable to demonstrate that a revocation was justified or to support an investigation; logs kept too long would breach data protection limits and create needless exposure of personal data.*
- *The retention period is set to meet the legal, supervisory, and investigative need while staying within the maximum permitted by the applicable data protection framework, and is applied consistently to revocation logs.*
- *A CAB verifies this requirement by reviewing the retention policy for revocation logs and confirming that the period is sufficient for the stated purposes and does not exceed the maximum permitted by applicable data protection law.*

13 Monitoring and Fraud Management

NOTE: The requirements in the present clause apply to a Wallet Unit throughout its active lifetime and in every lifecycle state, except where an individual requirement is explicitly conditioned on a particular state. They address the detection of, and response to, compromise and fraudulent use of a Wallet Unit and its ecosystem. Monitoring of whether the solution remains sufficiently secure and compliant as its technical and regulatory environment evolves is a distinct activity, addressed in clause 9.7.

13.1 General Monitoring and Fraud Detection

MON-13.1-01: The Wallet Provider shall operate a monitoring capability that detects, across every lifecycle state of a Wallet Unit, patterns indicative of compromise or fraudulent use in the backend interactions it receives from that Wallet Unit, including a frequency of those interactions inconsistent with normal operation and a device or Wallet Secure Cryptographic Device profile presented in an interaction that is inconsistent with the profile recorded for that Wallet Unit at activation or at a subsequent re-attestation.

Guidelines

- *The monitoring capability draws only on interactions the Wallet Provider actually receives, because it operates the corresponding backend service — for example attestation status queries, software update check-ins, trust anchor distribution, migration-initiation requests, and reports of suspected compromise. Relying party interactions and credential presentations do not pass through the Wallet Provider, so how a Wallet Unit is used towards relying parties is deliberately not observable to it and is not a monitoring input. The interactions available differ by lifecycle state and are set out in clause 13.2.*
- *A Wallet Unit taken over by an attacker frequently leaves no trace in any usage record, because presentations are not visible to the Wallet Provider. The takeover surfaces instead in the pattern of the Wallet Unit's own contacts with the Wallet Provider — an unexplained burst of status queries, repeated failed update check-ins, or a device or Wallet Secure Cryptographic Device profile in a later interaction that no longer matches the one established at activation.*
- *Acceptable approaches include frequency thresholds on the interactions the Wallet Provider receives, and comparison of the device and Wallet Secure Cryptographic Device profile presented at each interaction against the profile recorded during Wallet Unit activation, established under clauses 6.1 and 6.2. The specific interactions monitored in each lifecycle state are those set out in clause 13.2.*
- *A CAB verifies this requirement by reviewing the monitoring design and the backend interactions it consumes, and by reproducing each listed condition — an abnormal interaction frequency and a mismatched device profile — against a test Wallet Unit and confirming that the monitoring capability records it.*

MON-13.1-02: The Wallet Provider shall document, for each anomaly condition detected under **MON-13.1-01**, the investigation procedure applied and the response available, up to and including revocation of the Wallet Unit.

Guidelines

- *Detection has value only where a defined response follows it. The documentation ties each condition to who acts on it, within what time, and with what powers.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *Where responses are left to the judgement of whoever is on duty, comparable incidents are handled inconsistently, the decision to revoke is deferred out of caution, and an attacker retains a usable Wallet Unit for longer than necessary.*
- *The documented responses are normally graded, from recording the observation, through notifying the Wallet User, to revocation of the Wallet Unit. The conditions under which a Wallet Unit is revoked are set out in clause 12.1.*
- *A CAB verifies this requirement by reviewing the documented conditions and responses, and by sampling recorded anomalies to confirm that the response actually applied was the documented one.*

MON-13.1-03: The Wallet Provider shall provide the Wallet User with a means of reporting suspected compromise or misuse of a Wallet Unit that does not require the Wallet User to authenticate to that Wallet Unit.

Guidelines

- *The Wallet User is frequently the first to notice that something is wrong. The reporting channel is reachable even when the Wallet Unit itself cannot be used, which is precisely the situation in a takeover.*
- *Where the only reporting route runs through the Wallet Unit, a Wallet User locked out by an attacker who has changed the authentication factors has no way to raise the alarm, and the Wallet Provider receives no signal at all.*
- *This is the same reporting channel as the one required by* **MAINT-9.5-03** *for reporting loss or theft of the device, so that the Wallet User has one route to remember rather than several, regardless of the lifecycle state the Wallet Unit is in at the time.*
- *A CAB verifies this requirement by locating the reporting channel as a Wallet User would, submitting a test report without authenticating to the Wallet Unit, and confirming that the report reaches the monitoring or support function.*

13.2 State-Specific Monitoring Inputs

MON-13.2-01: [CONDITIONAL] For a Wallet Unit that holds no PID credential, the Wallet Provider shall base the monitoring required under **MON-13.1-01** on the Wallet Instance Attestation and Key Attestation status queries, the software update check-ins, and the reports of suspected compromise that it receives from the Wallet Unit at that stage.

Guidelines

- *In no lifecycle state does the Wallet Provider observe how a Wallet Unit is used towards relying parties: credential presentations pass directly between the Wallet Unit and the relying party, and the Wallet Provider is deliberately kept outside that path, so monitoring never draws on usage data. Before a PID has been issued, the interactions the Wallet Provider does receive — because it operates the corresponding backend service — are the Wallet Instance Attestation and Key Attestation status queries, the software update check-ins, and any report of suspected compromise the Wallet Instance itself generates. This requirement fixes the monitoring inputs for the state before PID issuance to those interactions.*
- *An attacker who takes over a Wallet Unit before PID issuance leaves no trace in any usage log, because none exists yet. The only place the takeover can surface is in the pattern of the Wallet Unit's own contacts with the Wallet Provider — an unexplained burst of status queries, repeated failed update check-ins, or a device profile in a later interaction that no longer matches the one established at activation.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *Acceptable approaches include frequency thresholds on status queries and update check-ins, and comparison of the device and Wallet Secure Cryptographic Device profile presented at each interaction against the profile recorded during Wallet Unit activation, established under clauses 6.1 and 6.2.*
- *A CAB verifies this requirement by reproducing each listed condition — an abnormal query frequency and a mismatched device profile — against a test Wallet Unit that holds no PID credential and confirming that the monitoring capability records it.*

MON-13.2-02: [CONDITIONAL] For a Wallet Unit that holds a PID credential, the Wallet Provider shall extend the monitoring required under **MON-13.1-01** to the trust anchor distribution channel, the software update check-ins, and any migration-initiation request it receives from the Wallet Unit.

Guidelines

- *Once a PID credential is present, the Wallet Provider gains backend touchpoints beyond those available before PID issuance: the authenticated channel used to distribute trust anchors, the ongoing software update check-ins, and any request to initiate migration to a new device. This requirement adds those interactions to the monitoring inputs for a Wallet Unit in this state.*
- *A takeover occurring after PID issuance — for example through a compromised device later used to initiate a fraudulent migration — would otherwise go undetected until it results in a Wallet User complaint or a downstream relying party dispute.*
- *Acceptable approaches apply the same frequency and device-profile checks used before PID issuance to the trust anchor distribution channel, to update check-ins, and to migration-initiation requests, comparing the pattern of these interactions against the profile established for the Wallet Unit at activation and at each subsequent re-attestation.*
- *A CAB verifies this requirement by reproducing an anomalous condition — an abnormal trust anchor distribution or migration-initiation pattern — on a test Wallet Unit that holds a PID credential and confirming that the monitoring capability records it.*

13.3 Monitoring of the Application and Web Ecosystem

MON-13.3-01: The Wallet Provider shall monitor the application distribution channels through which the Wallet Instance is made available for counterfeit, modified, or look-alike applications that impersonate the Wallet Instance.

Guidelines

- *Monitoring covers the application stores and other distribution channels on which a Wallet User could plausibly search for and obtain the Wallet Instance. A look-alike application is one that reproduces the name, icon, branding, or description of the genuine Wallet Instance closely enough that a Wallet User could install it in mistake for the genuine one.*
- *An attacker who publishes a counterfeit Wallet Instance can capture the credentials, authentication factors, and personal data of every Wallet User who installs it in mistake for the genuine application, without ever compromising the Wallet Provider's own systems. The Wallet Provider is the party best placed to recognise an impersonation of its own application at scale.*
- *Acceptable approaches include periodic automated searches of the major application stores for the Wallet Instance's name, publisher, and iconography, third-party brand-protection monitoring services, and a channel through which Wallet Users can report a suspected counterfeit application.*

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

- *A CAB verifies this requirement by reviewing the documented monitoring process and its coverage of the distribution channels through which the Wallet Instance is offered, and by reviewing records of counterfeit applications identified over a representative period.*

MON-13.3-02: The Wallet Provider shall, upon identifying a counterfeit, modified, or look-alike application that impersonates the Wallet Instance, pursue its removal from the application distribution channel on which it is offered.

Guidelines

- *Pursuing removal means initiating and following through the takedown or abuse-reporting procedure of the distribution channel concerned, and escalating where the initial report does not result in removal. The obligation is one of diligent action, since the decision to remove ultimately rests with the operator of the distribution channel.*
- *A counterfeit application that is detected but left in place continues to harvest the data of Wallet Users who install it. Detection without a removal obligation would leave the Wallet Provider aware of an active impersonation of its application and taking no action to end it.*
- *Acceptable approaches include using the application store's established trademark and impersonation reporting mechanisms, retaining evidence of each report and its outcome, and escalating unresolved cases. Identification of the counterfeit application is addressed by* **MON-13.3-01***.*
- *A CAB verifies this requirement by reviewing records of counterfeit applications identified under* **MON-13.3-01** *and confirming that a removal request was raised for each and pursued to a recorded outcome.*

MON-13.3-03: The Wallet Provider shall monitor for websites that impersonate the Wallet Provider in order to deceive Wallet Users.

Guidelines

- *Monitoring covers websites that reproduce the Wallet Provider's name, branding, or domain closely enough to be mistaken for an official site — for example a site offering a supposed download of the Wallet Instance, or a site soliciting the Wallet User's credentials or personal data under the guise of the Wallet Provider.*
- *A convincing impersonation website can be used to distribute a counterfeit Wallet Instance, to phish authentication factors or recovery material, or to induce the Wallet User to disclose personal data. As with a counterfeit application, the Wallet Provider is the party best placed to recognise an impersonation of its own identity.*
- *Acceptable approaches include domain-monitoring and brand-protection services that detect newly registered look-alike domains, monitoring of certificate transparency logs for certificates issued against look-alike domains, and a Wallet User reporting channel. Takedown of an identified website is addressed by* **MON-13.3-04***.*
- *A CAB verifies this requirement by reviewing the documented monitoring process and reviewing records of impersonation websites identified over a representative period.*

MON-13.3-04: The Wallet Provider shall, upon identifying a website that impersonates the Wallet Provider or the Wallet Instance, pursue its takedown.

Guidelines

- *Pursuing takedown means initiating and following through the applicable abuse-reporting, registrar, or hosting-provider procedure to have the impersonation website removed, and escalating where an initial request does not result in removal. As with a counterfeit application, the obligation is one of diligent action, the final decision resting with the registrar or hosting provider.*

- *An impersonation website that is detected but left in place continues to deceive Wallet Users, distribute counterfeit software, or harvest credentials. Detection without a takedown obligation would leave the Wallet Provider aware of an active impersonation of its identity and taking no action to end it.*
- *Acceptable approaches include reporting to the domain registrar, the hosting provider, and the relevant abuse and anti-phishing services, retaining evidence of each request and its outcome, and escalating unresolved cases. Identification of the website is addressed by* **MON-13.3-03***.*
- *A CAB verifies this requirement by reviewing records of impersonation websites identified under* **MON-13.3-03** *and confirming that a takedown request was raised for each and pursued to a recorded outcome.*

13.4 Wallet User Warning Channel

MON-13.4-01: The Wallet Provider shall maintain a means of contacting the Wallet User over a push channel that the Wallet User will see without opening the Wallet Instance and that is independent of the Wallet Instance, for use in warning the Wallet User when compromise of the Wallet Unit is suspected.

Guidelines

- *A channel independent of the Wallet Instance is one that does not rely on the Wallet Instance being installed, functional, or under the Wallet User's control in order to reach the Wallet User — for example SMS, telephone call or message through a separate messaging service. The channel is a push channel: the Wallet Provider actively delivers the warning to the Wallet User rather than leaving it to be discovered. A pull channel — such as a message placed in a portal or inbox that the Wallet User has to decide to open — is not sufficient, because the Wallet User might open it only days later, by which time a warning about a suspected compromise would arrive too late to act on. The Wallet User therefore sees the warning promptly and by ordinary means, rather than only on next opening an application or web portal that could be compromised or inaccessible.*
- *An attacker who has taken over the Wallet Unit, or the device on which it runs, controls what the Wallet User sees inside the Wallet Instance and can suppress an in-application warning. A warning delivered only through the Wallet Instance therefore cannot be relied upon in exactly the circumstances — a suspected compromise — for which it is most needed.*
- *Acceptable approaches include a phone number or messaging contact obtained from the Wallet User, with consent, at or after activation, or an operating-system notification mechanism that does not depend on the Wallet Instance session. Where the Wallet Provider deliberately holds no data identifying the Wallet User, the channel is designed consistently with that data-minimisation objective — for example an alternate contact agreed in advance and stored separately from any identity data — and the design of the channel is documented.*
- *A CAB verifies this requirement by reviewing the documented contact channel and confirming it is independent of the Wallet Instance and that it actively pushes a warning rather than waiting to be read, so that a suspected compromise warning reaches the Wallet User without the Wallet Instance being opened and without the Wallet User having to open a portal or inbox to find it. Where feasible, the CAB may also trigger a test suspected-compromise warning and confirm that it reaches the Wallet User in this way.*

Annex A (informative): Lifecycle State Diagram

NOTE: This annex is informative and does not contain normative requirements.

This annex illustrates the lifecycle states of a Wallet Unit and the transitions between them. It is informative; the normative requirements are those in clauses 3.5 to 13. Figure A.1 shows the states and the lifecycle events that move a Wallet Unit between them, and the paragraphs that follow describe each state.

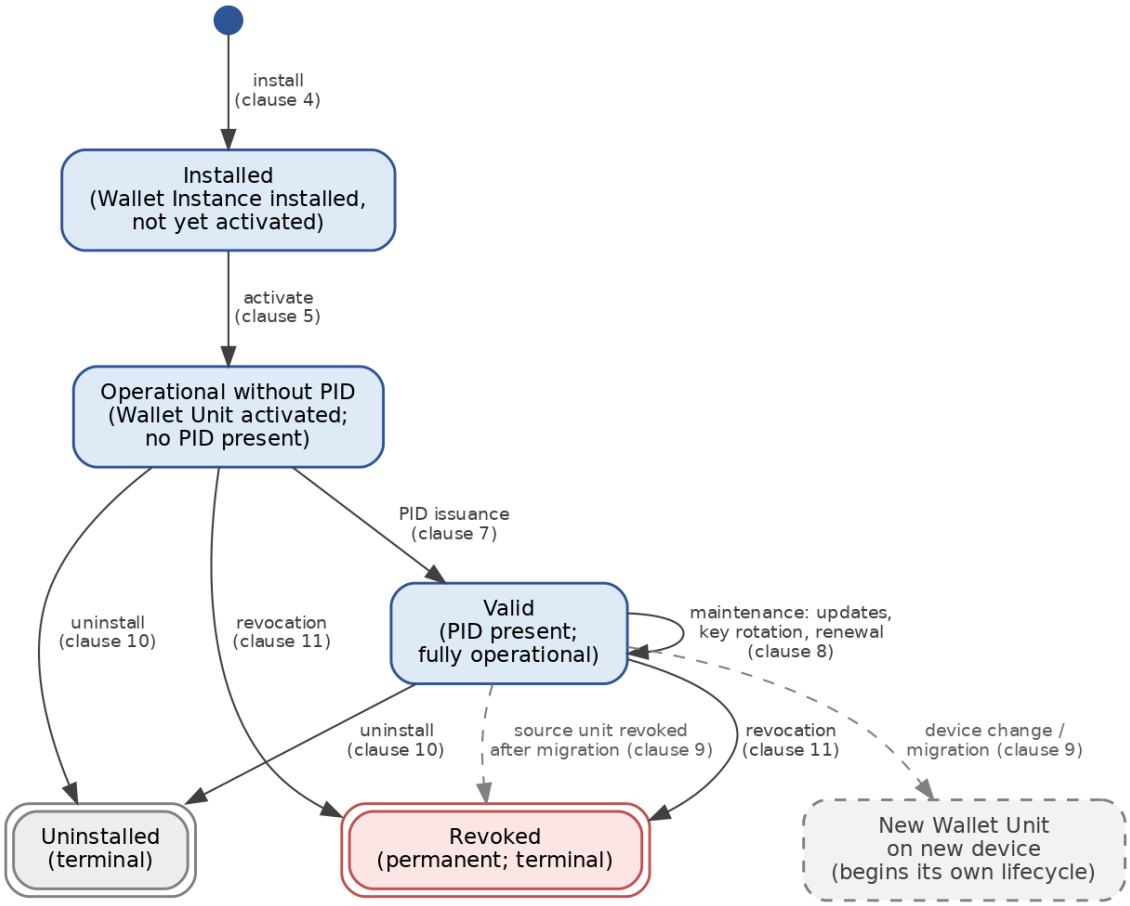


Figure A.1 — Wallet Unit lifecycle states and transitions

Installed. The Wallet Instance has been installed on the device but the Wallet Unit has not yet been activated; no keys, attestations or credentials are present. This state is governed by clause 3.5. It is entered when installation completes and left when the Wallet User activates the Wallet Unit.

Operational without PID. The Wallet Unit has been activated — the secure cryptographic device and application are initialised and the Wallet Unit holds its Wallet Instance Attestation and Key Attestation — but no PID credential is present. In this state the Wallet Unit can hold and present non-identity attestations, subject to clause 7. Activation is governed by clause 6. In implementations where the Wallet Unit Attestation is issued only at the start of PID issuance, a Wallet Unit passes through this state only briefly before PID issuance begins.

Valid. A PID credential is present and active and the Wallet Unit is fully operational for identification and for the presentation of PID-dependent attestations. The transition into this state is PID issuance, governed by clause 8. While in this state the Wallet Unit is maintained — software updates, key rotation, attestation renewal and credential lifecycle management — under clause 9, and is monitored under clause 13; these activities return the Wallet Unit to the Valid state.

Device change / migration. Migration is a transition rather than a persisting state. A Wallet User moving to a new device establishes a new Wallet Unit on that device, which begins its own lifecycle at the Installed state; device-bound credentials are re-issued rather than copied, because device-bound keys cannot leave the device that created them. The source Wallet Unit is revoked once the transfer is complete. Migration is governed by clause 10.

Uninstalled. The Wallet Instance has been removed from the device and all key material, credentials and personal data have been irrecoverably deleted. This is a terminal state; a Wallet Unit does not return from it. Uninstallation is governed by clause 11 and results in deregistration and revocation of the Wallet Unit.

Revoked. The Wallet Unit has been permanently invalidated and can no longer be used; its status is published so that relying parties reject it. Revocation is permanent and irreversible, with no reactivation. This is a terminal state, entered from any active state on the grounds set out in clause 12, including breach detection, a legal requirement, a Wallet User request, and the revocation of a source Wallet Unit after migration.

Suspension and reactivation are not part of this lifecycle model: a Wallet Unit that can no longer be trusted is revoked, and recovery is achieved by activating a new Wallet Unit and re-issuing credentials.

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Annex B (informative): Risk Register Cross-Reference

Risk ID	Risk description	Requirements
LR-001	Creation or use of an existing electronic identity	**PID-8.3-01**, **PID-8.3-04**
LR-002	Creation or use of a fake electronic identity	**PID-8.3-01**, **PID-8.3-04**, **PID-8.2-05**
LR-003	Identity theft	**ACT-6.5-01**, **ACT-6.5-02**, **ACT-6.5-03**, **ACT-6.5-04**, **MAINT-9.5-04**, **MAINT-9.5-05**, **ACT-6.4-03**, **REV-12.1-01**, **MAINT-9.5-06**
LR-004	Data theft	**ACT-6.3-03**, **PID-8.4-02**, **MAINT-9.3-01**, **MAINT-9.3-02**, **MAINT-9.6-01**, **MAINT-9.6-02**, **PID-8.4-01**, **MAINT-9.6-03**, **MAINT-9.6-04**
LR-005	Data disclosure	**ACT-6.3-01**, **ACT-6.3-02**, **ACT-6.4-02**, **ACT-6.4-04**, **PID-8.4-03**, **PID-8.4-04**, **MAINT-9.4-05**, **MAINT-9.6-04**
LR-006	Data manipulation	**PID-8.3-01**, **PID-8.3-03**, **PID-8.3-05**, **PID-8.3-06**, **PID-8.3-07**, **PID-8.3-08**
LR-007	Data loss	**ACT-6.6-01**, **ACT-6.6-02**, **ACT-6.6-03**, **ACT-6.6-04**, **ACT-6.7-01**, **ACT-6.7-02**, **ACT-6.7-03**, **ACT-6.7-04**, **ACT-6.7-05**, **MAINT-9.6-01**, **MAINT-9.6-06**, **MAINT-9.6-07**, **ACT-6.6-05**
LR-008	Unauthorised transaction	**OPS-7.1-01**, **OPS-7.1-02**, **OPS-7.1-03**, **ACT-6.5-01**, **ACT-6.5-03**, **MAINT-9.2-01**, **MAINT-9.2-02**, **MAINT-9.2-03**, **MAINT-9.4-03**
LR-009	Service disruption	**MAINT-9.1-01**, **MAINT-9.1-02**, **MAINT-9.1-03**, **MAINT-9.1-04**, **REV-12.2-02**, **REV-12.2-03**
LR-010	Compromised application distribution	**INST-5.1-01**, **INST-5.1-02**, **INST-5.1-03**, **INST-5.1-04**, **INST-5.1-05**, **INST-5.1-06**, **INST-5.3-01**, **INST-5.3-02**, **INST-5.3-03**, **INST-5.3-04**, **MON-13.3-01**, **MON-13.3-02**
LR-011	Failure in WSCD/WSCA initialisation or in Wallet Instance Attestation or Key Attestation issuance	**ACT-6.1-01**, **ACT-6.1-02**, **ACT-6.1-03**, **ACT-6.2-01**, **ACT-6.2-02**, **ACT-6.2-03**, **ACT-6.2-04**, **ACT-6.2-05**, **ACT-6.2-06**, **ACT-6.2-08**, **ACT-6.2-09**, **ACT-6.2-10**, **ACT-6.2-11**, **ACT-6.2-12**, **ACT-6.2-13**, **ACT-6.2-07**
LR-012	Unauthorized use of wallet capabilities before PID issuance	**OPS-7.1-01**, **OPS-7.1-02**, **OPS-7.1-03**, **OPS-7.2-01**, **OPS-7.2-02**, **MON-13.2-01**
LR-013	Identity verification failure during PID binding	**PID-8.2-01**, **PID-8.2-02**, **PID-8.2-03**, **PID-8.2-04**, **PID-8.2-05**
LR-014	Security degradation during updates or key rotation	**MAINT-9.3-01**, **MAINT-9.3-02**, **MAINT-9.3-03**, **MAINT-9.3-04**, **MAINT-9.4-01**, **MAINT-9.4-04**, **MAINT-9.7-02**, **MAINT-9.1-05**
LR-015	Data or credential compromise during migration	**MIG-10.2-01**, **MIG-10.2-02**, **MIG-10.2-03**, **MIG-10.2-04**, **MIG-10.2-05**, **ACT-6.7-01**, **ACT-6.7-04**, **ACT-6.7-05**, **MIG-10.6-03**, **MIG-10.1-01**, **MIG-10.4-02**

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Risk ID	Risk description	Requirements
LR-016	Incomplete data cleanup or credential revocation upon uninstallation	**UNINST-11.1-01**, **UNINST-11.1-02**, **UNINST-11.1-03**, **UNINST-11.1-04**, **UNINST-11.2-01**, **UNINST-11.2-02**, **UNINST-11.3-01**, **UNINST-11.3-02**, **UNINST-11.3-03**, **UNINST-11.3-04**, **UNINST-11.3-05**, **UNINST-11.4-01**, **UNINST-11.5-01**, **UNINST-11.5-02**, **MIG-10.6-01**, **MIG-10.6-02**, **MIG-10.6-03**
LR-017	Failure to propagate Wallet Unit revocation to PID and Attestation Providers	**REV-12.2-01**, **REV-12.2-02**, **REV-12.2-03**, **REV-12.3-01**, **REV-12.3-02**, **REV-12.3-03**, **REV-12.1-07**
LR-018	Insufficient user information at registration	**INST-5.4-01**, **INST-5.4-02**, **INST-5.4-03**
LR-019	Insecure delivery mechanism for wallet	**INST-5.1-01**, **INST-5.1-02**, **INST-5.1-03**, **INST-5.1-04**, **INST-5.1-05**, **INST-5.1-06**, **MON-13.3-03**, **MON-13.3-04**
LR-020	Activation process bypass	**ACT-6.2-01**, **ACT-6.3-01**, **ACT-6.3-04**
LR-021	Inadequate provider security management during deployment	**INST-5.2-01**, **INST-5.2-02**, **INST-5.2-03**, **INST-5.2-05**, **INST-5.2-06**, **INST-5.2-07**, **INST-5.2-05**
LR-022	Weak identity proofing during activation	**PID-8.5-02**, **PID-8.2-01**, **PID-8.2-02**, **PID-8.2-03**, **PID-8.2-04**, **PID-8.5-01**
LR-023	eID means not under exclusive holder control	**ACT-6.3-03**, **ACT-6.3-04**, **ACT-6.2-03**
LR-024	Authentication mechanism insufficient for target assurance level	**ACT-6.5-01**, **ACT-6.5-02**, **ACT-6.5-03**, **ACT-6.5-04**, **MAINT-9.7-01**
LR-025	Person identification data exposed before authentication	**PID-8.4-03**, **PID-8.4-04**, **MAINT-9.2-01**
LR-026	Stored identification data insufficiently protected	**INST-5.3-03**, **PID-8.4-01**, **PID-8.4-02**, **PID-8.4-03**, **PID-8.4-04**, **MAINT-9.2-03**, **MAINT-9.4-06**
LR-027	PID delivery interception	**PID-8.3-03**, **PID-8.3-04**, **PID-8.3-06**, **PID-8.3-07**
LR-028	Weak authentication during PID binding	**PID-8.3-08**, **ACT-6.5-01**, **ACT-6.5-02**, **ACT-6.5-03**, **ACT-6.5-04**
LR-029	Renewal process weaker than initial issuance	**MAINT-9.1-01**, **MAINT-9.3-03**, **MAINT-9.3-04**, **MAINT-9.4-04**
LR-030	Replacement after compromise insufficient	**MAINT-9.5-01**, **MAINT-9.5-02**, **MAINT-9.5-04**, **MAINT-9.5-05**, **MAINT-9.5-06**, **MAINT-9.5-07**, **MAINT-9.5-08**, **MAINT-9.5-09**
LR-031	Provider security management degradation	**MAINT-9.7-01**, **MAINT-9.7-02**, **MAINT-9.8-01**
LR-032	Records and data retention non-compliance	**MAINT-9.8-01**, **UNINST-11.3-05**, **REV-12.4-02**, **REV-12.4-03**
LR-033	Authentication factor degradation over time	**MAINT-9.7-01**, **MAINT-9.5-02**
LR-034	Migration delivery not verified against identity proofing	**MIG-10.4-01**, **MIG-10.4-03**, **MIG-10.7-02**

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Risk ID	Risk description	Requirements
LR-035	New device fails security design requirements during migration	**MIG-10.3-01**, **MIG-10.7-05**, **INST-5.2-01**, **INST-5.2-02**, **INST-5.2-03**, **INST-5.2-05**, **INST-5.2-06**, **MIG-10.4-02**
LR-036	Old device credentials not properly revoked during migration	**MIG-10.2-03**, **MIG-10.2-04**, **MIG-10.2-05**, **MIG-10.5-01**, **MIG-10.5-02**, **MIG-10.5-03**, **MIG-10.6-01**, **MIG-10.6-02**, **MIG-10.6-03**, **MIG-10.5-04**, **MIG-10.5-05:** [, **MIG-10.7-03**, **MIG-10.7-04**, **MAINT-9.6-05**
LR-037	Identity re-verification skipped during migration	**MIG-10.4-01**, **MIG-10.4-03**, **MIG-10.7-02**, **MIG-10.3-01**
LR-038	Migration treated as replacement without meeting issuance requirements	**MIG-10.3-01**, **MIG-10.4-01**, **MIG-10.4-03**, **MIG-10.7-02**, **MIG-10.7-05**
LR-039	Records not properly handled during uninstallation	**UNINST-11.3-05**, **MAINT-9.8-01**, **REV-12.4-02**
LR-040	Revocation irreversibility failure	**REV-12.2-06**, **REV-12.4-01**
LR-041	Post-revocation data not properly managed	**REV-12.4-01**, **REV-12.4-02**, **REV-12.4-03**, **UNINST-11.3-05**
LR-042	Authentication mechanism accepts revoked credentials	**REV-12.2-04**, **REV-12.2-07**, **REV-12.3-01**, **REV-12.3-02**, **REV-12.3-03**, **MAINT-9.4-02**
LR-043	Cross border identity mismatch	**PID-8.2-01**, **PID-8.2-02**, **PID-8.2-03**, **PID-8.2-05**
LR-044	Death or legal incapacity of a natural person	**REV-12.1-02**, **REV-12.1-03**, **REV-12.2-01**, **REV-12.1-07**, **REV-12.1-08**
LR-045	User attribute exposure via co-located malicious application	**INST-5.2-02**, **INST-5.2-03**, **INST-5.2-04**, **INST-5.2-07**, **INST-5.3-03**, **ACT-6.1-02**, **ACT-6.5-01**, **MAINT-9.1-02**
LR-046	Migration Object not created, not exported, or incomplete prior to device loss	**ACT-6.7-01**, **ACT-6.7-02**, **ACT-6.7-04**, **ACT-6.7-05**, **MAINT-9.6-06**, **MAINT-9.6-07**, **MAINT-9.6-08**, **MIG-10.2-01**, **MIG-10.7-01**, **ACT-6.7-06**
LR-047	Wallet User unable to initiate Wallet Unit revocation under adverse conditions	**ACT-6.4-05**, **ACT-6.4-06**, **MON-13.1-03**, **REV-12.1-06**, **REV-12.1-07**
LR-048	Wallet Provider unable to assist user who suspects their Wallet Unit is under attack, due to absence of a support function and security/fraud monitoring capability	**MON-13.1-01**, **MON-13.1-02**, **MON-13.1-03**, **MAINT-9.5-01**, **MAINT-9.5-02**, **MAINT-9.5-03**, **MAINT-9.5-04**, **MAINT-9.7-02**, **REV-12.1-04**, **REV-12.1-05**, **MON-13.2-02**, **MON-13.4-01**, **MAINT-9.5-06**, **MAINT-9.5-07**, **MAINT-9.5-08**, **MAINT-9.5-09**
LR-049	Acceptance of material authenticated under an untrusted or withdrawn trust anchor	**PID-8.3-01**, **PID-8.3-02**, **MAINT-9.9-01**, **MAINT-9.9-02**, **MAINT-9.9-03**, **MAINT-9.9-04**
LR-050	PID issuance request submitted to a provider whose registration is not established	**PID-8.1-01**, **PID-8.1-02**, **PID-8.1-03**, **PID-8.1-04**
LR-051	Revoked Wallet Unit continues to present itself as a recognised wallet	**REV-12.2-05**, **UNINST-11.4-01**

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme

Colofon

v1.2
Trust Agency – Daalstraat 164, 1852 Beigem, Belgium – info@trust-agency.eu –
VAT: BE 0792.153.666 – bank account: BE84 0689 4647 1059

EUDIW CERTIFICATION SYSTEM MANAGEMENT BOARD NL
Ensuring High Assurance of EUDI Wallets & the NL National eID Scheme